



AWS Security Reference Architecture (AWS SRA) – core architecture

AWS Prescriptive Guidance



AWS Prescriptive Guidance: AWS Security Reference Architecture (AWS SRA) – core architecture

Copyright © 2026 Amazon Web Services, Inc. and/or its affiliates. All rights reserved.

Amazon's trademarks and trade dress may not be used in connection with any product or service that is not Amazon's, in any manner that is likely to cause confusion among customers, or in any manner that disparages or discredits Amazon. All other trademarks not owned by Amazon are the property of their respective owners, who may or may not be affiliated with, connected to, or sponsored by Amazon.

Table of Contents

Introduction	1
Attachments	3
About the AWS SRA library	4
The value of the AWS SRA	6
How to use the AWS SRA	7
Key implementation guidelines of the AWS SRA	9
Security foundations	12
Security capabilities	13
Security design principles	14
How to use the AWS SRA with AWS CAF and AWS Well-Architected Framework	15
SRA building blocks – AWS Organizations, accounts, and guardrails	16
Using AWS Organizations for security	16
The management account, trusted access, and delegated administrators	20
Dedicated accounts structure	21
AWS organization and account structure of the AWS SRA	23
Apply security services across your AWS organization	26
Organization-wide or multiple accounts	28
AWS accounts	29
Virtual network, compute, and content delivery	30
Principals and resources	31
The AWS Security Reference Architecture	35
Org Management account	38
Service control policies	39
Resource control policies	39
Declarative policies	40
Centralized root access	41
IAM Identity Center	42
IAM access advisor	43
AWS Systems Manager	44
AWS Control Tower	44
AWS Artifact	45
Distributed and centralized security service guardrails	46
Security OU – Security Tooling account	47
Delegated administrator for security services	48

Centralized root access	49
AWS CloudTrail	49
AWS Security Hub CSPM	51
AWS Security Hub	54
Amazon GuardDuty	56
AWS Config	58
Amazon Macie	61
IAM Access Analyzer	62
Amazon CloudWatch	65
Amazon Security Lake	67
AWS Firewall Manager	69
Amazon EventBridge	70
Amazon Detective	71
AWS Audit Manager	72
AWS Artifact	74
AWS KMS	74
AWS Private CA	75
Amazon Inspector	77
AWS Security Incident Response	79
Deploying common security services within all AWS accounts	81
Security OU – Log Archive account	82
Types of logs	83
Amazon S3 as central log store	83
Amazon Security Lake	85
Centralized log collection	86
Amazon CloudWatch Unified Data Experience	86
Infrastructure OU – Network account	88
Network architecture	89
Inbound (ingress) VPC	90
Outbound (egress) VPC	90
Inspection VPC	90
AWS Network Firewall	90
Network Access Analyzer	92
AWS RAM	93
AWS Verified Access	94
Amazon VPC Lattice	95

Edge security	96
Amazon CloudFront	97
AWS WAF	99
AWS Shield	100
AWS Certificate Manager (ACM)	101
Amazon Route 53	101
Infrastructure OU – Shared Services account	103
AWS Systems Manager	104
AWS Managed Microsoft AD	104
IAM Identity Center	105
Workloads OU – Application account	107
Application VPC	109
VPC endpoints	110
Amazon EC2	110
AWS Nitro Enclaves	111
Application Load Balancers	112
AWS Private CA	113
Amazon Inspector	113
AWS Systems Manager	114
Amazon Aurora	115
Amazon S3	116
AWS KMS	116
AWS CloudHSM	117
AWS Secrets Manager	117
Amazon Cognito	119
Amazon Verified Permissions	120
Layered defense	121
Multi-Region Architecture	123
Key drivers	123
Regulatory and compliance requirements	123
Business continuity (BC) and disaster recovery (DR)	125
Fault isolation and event containment	126
Performance and user experience	127
Decision framework	128
Deployment approach	129
Foundational prerequisites	130

Operational recommendations	132
Amazon GuardDuty	133
Multi-Region considerations	133
Architecture	133
Amazon Inspector	135
Multi-Region considerations	135
Architecture	136
AWS CloudTrail	136
Multi-Region considerations	137
Architecture	137
AWS Config	137
Multi-Region considerations	137
Architecture	138
IAM Access Analyzer	139
Multi-Region considerations	140
Architecture	136
IAM Identity Center	141
Multi-Region considerations	141
Architecture	142
AWS Security Hub	142
Multi-Region considerations	142
Architecture	136
AWS Security Hub CSPM	144
Multi-Region considerations	144
Architecture	145
AWS Backup	145
Multi-Region considerations	146
Architecture	146
AI/ML for security	148
Provable security	149
Building your security architecture – a phased approach	152
Phase 1: Build your OU and account structure	152
Phase 2: Implement a strong identity foundation	153
Phase 3: Maintain traceability	154
Phase 4: Apply security at all layers	155
Phase 5: Protect data in transit and at rest	157

Phase 6: Prepare for security events	157
AWS SRA best practices checklist	160
AWS Organizations	160
AWS CloudTrail	161
AWS Security Hub CSPM	162
AWS Config	163
Amazon GuardDuty	163
IAM	164
IAM Access Analyzer	164
Amazon Detective	165
AWS Firewall Manager	165
Amazon Inspector	165
Amazon Macie	166
Amazon Security Lake	166
AWS WAF	167
AWS Shield Advanced	167
AWS Security Incident Response	168
AWS Audit Manager	168
AWS Security Hub	169
AWS Network Firewall	169
Amazon Route 53 Resolver DNS Firewall	170
AWS Key Management Service	170
AWS Private Certificate Authority	170
AWS IAM Identity Center	171
AWS Systems Manager	171
AWS Secrets Manager	172
IAM resources	173
Code repository for AWS SRA examples	179
Contributors	183
Previous contributors	183
Appendix: AWS security, identity, and compliance services	185
Document history	188

AWS Security Reference Architecture (AWS SRA) – core architecture

Avik Mukherjee, Amazon Web Services

The Amazon Web Services (AWS) Security Reference Architecture (AWS SRA) is a holistic set of guidelines for deploying the full complement of AWS security services in a multi-account environment. Use it to help design, implement, and manage AWS security services so that they align with AWS recommended practices. The recommendations are built around a single-page architecture that includes AWS security services—how they help achieve security objectives, where they can be best deployed and managed in your AWS accounts, and how they interact with other security services. This overall architectural guidance complements detailed, service-specific recommendations such as those found on the [AWS Security Documentation website](#).

The architecture and accompanying recommendations are based on our collective experiences with AWS enterprise customers. This document is a reference—a comprehensive set of guidance for using AWS services to secure a particular environment—and the solution patterns in the [AWS SRA code repository](#) were designed for the specific architecture illustrated in this reference. Each customer will have different requirements. As a result, the design of your AWS environment might differ from the examples provided here. **You will need to modify and tailor these recommendations to suit your individual environment and security needs.** Throughout the document, where appropriate, we suggest options for frequently seen alternative scenarios.

The AWS SRA is a living set of guidance and is updated periodically based on new service and feature releases, customer feedback, and the constantly changing threat landscape. Each update will include the revision date and the associated [change log](#).

Although we rely on a one-page diagram as our foundation, the architecture goes deeper than a single block diagram and must be built on a well-structured foundation of fundamentals and security principles. You can use this document in two ways: as a narrative or as a reference. The topics are organized as a story, so you can read them from the beginning (foundational security guidance) to the end (discussion of code samples you can implement). Alternatively, you can navigate the document to focus on the security principles, services, account types, guidance, and examples that are most relevant to your needs.

This document is divided into the following sections and an appendix:

- [About the AWS SRA library](#) provides an overview of the technical guidance and code included in the AWS SRA collection of publications.
- [The value of the AWS SRA](#) discusses the motivation for building the AWS SRA, describes how you can use it to help improve your security, and lists key takeaways.
- [Security foundations](#) reviews the AWS Cloud Adoption Framework (AWS CAF), the AWS Well-Architected Framework, and the AWS Shared Responsibility Model, and highlights elements that are especially relevant to the AWS SRA.
- [AWS Organizations, accounts, and IAM guardrails](#) introduces the AWS Organizations service, discusses the foundational security capabilities and guardrails, and gives an overview of our recommended multi-account strategy.
- [The AWS Security Reference Architecture](#) is a single-page architecture diagram that shows functional AWS accounts, and the security services and features that are generally available.
- [AI/ML for security](#) describes how different AWS services use artificial intelligence and machine learning (AI/ML) in the background to help you achieve specific security objectives. You can include these AWS services in your design to take advantage of advanced security features.
- [Building your security architecture – A phased approach](#) provides guidance on how you can build your own security architecture in six iterative phases, based on the reference provided by the AWS SRA.
- [AWS SRA best practices checklist](#) distills the recommendations discussed throughout the guide into a checklist that you can follow as you build your version of the security architecture.
- [IAM resources](#) presents a summary and set of pointers for AWS Identity and Access Management (IAM) guidance that are important to your security architecture.
- [Code repository for AWS SRA examples](#) provides an overview of the associated [GitHub repository](#) that will help developers and engineers deploy some of the guidance and architecture patterns presented in this document. You can deploy the samples by using AWS CloudFormation or Terraform by HashiCorp. They support both AWS Control Tower and non–AWS Control Tower environments.

The [appendix](#) contains a list of the individual AWS security, identity, and compliance services, and provides links to more information about each service. The [Document history](#) section provides a change log for tracking versions of this document.

Attachments

To access additional content that is associated with this document, download and unzip the following file:

[attachment.zip](#)

About the AWS SRA library

This guide is part of a library that provides architectural blueprints and technical guidance for designing and building security architectures on AWS. The library consists of implementation code ([AWS SRA code library](#)), a validation tool ([SRA Verify](#)), and two complementary categories of guides that cover the core architecture and deep dive architectures.

AWS SRA – core architecture (this guide)

This guide represents a foundation for the recommended AWS security architecture. It is the starting point that applies to all organizations, regardless of their industry, application type, or any other considerations. This foundation helps you build a strong and scalable architecture on AWS and helps create a strong AWS multi-account security baseline that securely scales as your business grows.

AWS SRA – deep dive architectures

The *AWS SRA – core architecture* guide is complemented by additional publications that provide architectural patterns aligned to specific security capabilities, application types, and compliance or regulatory requirements. These patterns extend the core architecture and should be used in conjunction with the *AWS SRA – core architecture* guide.

The following guides provide architectural patterns aligned to specific security capabilities:

- [AWS SRA – identity management](#) provides guidance on how to implement a scalable, robust, and centralized identity and access management solution on AWS.
- [AWS SRA – perimeter security](#) discusses architecture patterns and AWS services for implementing edge security in a central account or in individual accounts.
- [AWS SRA – cyber forensics](#) describes how to configure an AWS Forensics account as a starting point to develop your organization's forensic capabilities and to help improve your security incident response (IR) preparedness.

The following guides provide architectural patterns for specific application types. You might want to focus on these after you build your baseline security architecture:

- [AWS SRA – generative AI](#) provides security architectural recommendations for designing and building applications that incorporate generative AI capabilities by using AWS generative AI services.

- [AWS SRA – IoT](#) provides security architectural recommendations for designing and building IoT applications on AWS.

In addition, the following guide describes architectural patterns that are aligned with specific compliance or regulatory frameworks:

- [AWS Privacy Reference Architecture \(AWS PRA\)](#) provides a security architecture for applications that process personal data and must support broad privacy compliance requirements such as the General Data Protection Regulation (GDPR), the California Consumer Privacy Act (CCPA), or the Brazilian General Data Protection Law (LGPD). The AWS PRA provides a set of guidelines that are specific to the design and configuration of privacy controls in AWS services.
- [AWS Security Reference Architecture - Payment Card Industry \(PCI\) Data Security Standard \(DSS\)](#) extends the [AWS Security Reference Architecture \(AWS SRA\) - Core Architecture](#) to help organizations design and operate a multi-account AWS environment that aligns with the [Payment Card Industry Data Security Standard \(PCI DSS\)](#). It is an architecture guide that shows how to apply AWS SRA security best practices in a way that satisfies PCI DSS requirements for workloads that store, process, or transmit cardholder data.

We recommend that you start with the *AWS SRA – core architecture* guide to understand the foundational architecture and then consult the complementary guides to take advantage of advanced functionality and implementations. For more information about this content set, see [AWS Security Reference Architecture](#).

 Note

To customize the reference architecture diagrams in the AWS SRA library based on your business needs, you can download the .zip file in the *Attachments* section of the *Introduction* chapter.

The value of the AWS SRA

AWS has a large (and growing) [set of security and security-related services](#). Customers have expressed appreciation for the detailed information available through our service documentation, blog posts, tutorials, summits, and conferences. They also tell us that they want to better understand the big picture and get a strategic view of AWS security services. When we work with customers to get a deeper appreciation for what they need, three priorities emerge:

- Customers want more information and recommended patterns for how they can deploy, configure, and operate the AWS security services holistically. In which accounts and toward which security objectives should the services be deployed and managed? Is there one security account where all or most services should operate? How does the choice of location (organizational unit or AWS account) inform security objectives? Which trade-offs (design considerations) should customers be aware of?
- Customers are interested in seeing different perspectives for logically organizing the many AWS security services. Beyond the primary function of each service (for example, identity services or logging services), these alternate viewpoints help customers plan, design, and implement their security architecture. An example shared later in this document groups the services based on the layers of protection aligned to the recommended structure of your AWS environment.
- Customers are looking for guidance and examples to integrate security services in the most effective way. For example, how should they best align and connect AWS Config with other services to do the heavy lifting in automated audit and monitoring pipelines? Customers are asking for guidance on how each AWS security service relies on, or supports, other security services.

We address each of these in the AWS SRA. The first priority in the list (where things go) is the focus of the main architecture diagram and the accompanying discussions in this document. We provide a recommended AWS Organizations architecture and an account-by-account description of which services go where. To get started with the second priority in the list (how to think about the full set of security services), read the section, [Apply security services across your AWS organization](#). This section describes a way to group security services according to the structure of the elements in your AWS organization. In addition, those same ideas are reflected in the discussion of the [Application account](#), which highlights how security services can be operated to focus on certain layers of the account: Amazon Elastic Compute Cloud (Amazon EC2) instances, Amazon Virtual Private Cloud (Amazon VPC) networks, and the broader account. Finally, the third

priority (service integration) is reflected throughout the guidance—particularly in the discussion of individual services in the [deep dive guides in the AWS SRA library](#) and the code in the AWS SRA code repository.

How to use the AWS SRA

There are different ways to use the AWS SRA depending on where you are in your cloud adoption journey. Here is a list of ways to gain the most insight from the AWS SRA assets (architecture diagram, written guidance, and code samples).

- *Define* the target state for your own security architecture.

Whether you are just starting your AWS Cloud journey—setting up your first set of accounts—or planning to enhance an established AWS environment, the AWS SRA is the place to start building your security architecture. Begin with a comprehensive foundation of account structure and security services, and then adjust based on your particular technology stack, skills, security objectives, and compliance requirements. If you know you will be building and launching more workloads, you can take your customized version of the AWS SRA and use it as the basis for your organization's security reference architecture. To find out how you can achieve the target state described by the AWS SRA, see the section [Building your security architecture – A phased approach](#).

- *Review* (and revise) the designs and capabilities that you have already implemented.

If you already have a security design and implementation, it is worth taking some time to compare what you have to the AWS SRA. The AWS SRA is designed to be comprehensive and provides a diagnostic baseline for reviewing your own security. Where your security designs align to the AWS SRA, you can feel more confident that you are following best practices when using AWS services. If your security designs diverge or even disagree with the guidance in the AWS SRA, this isn't necessarily a sign that you're doing something wrong. Instead, this observation provides you with the opportunity to review your decision process. There are legitimate business and technology reasons why you might deviate from the AWS SRA best practices. Perhaps your particular compliance, regulatory, or organization security requirements necessitate specific service configurations. Or, instead of using AWS services, you might have a feature preference for a product from the AWS Partner Network or a custom application that you built and manage. Sometimes, during this review, you might discover that your previous decisions were made based on older technology, AWS features, or business constraints that no longer apply. This is a good opportunity to review, prioritize any updates, and add them to the appropriate place of your

engineering backlog. Whatever you discover as you assess your security architecture in light of the AWS SRA, you will find it valuable to document that analysis. Having that historical record of decisions and their justifications can help inform and prioritize future decisions.

- *Bootstrap* the implementation of your own security architecture.

The AWS SRA infrastructure as code (IaC) modules provide a fast, reliable way to start building and implementing your security architecture. These modules are described more deeply in the [code repository](#) section and in the [public GitHub repository](#). They not only enable engineers to build upon high-quality examples of the patterns in the AWS SRA guidance, but they also incorporate recommended security controls such as IAM password policies, Amazon Simple Storage Service (Amazon S3) block account public access, Amazon EC2 default Amazon Elastic Block Store (Amazon EBS) encryption, and integration with AWS Control Tower so that the controls are applied or removed as new AWS accounts are onboarded or decommissioned.

- *Learn* more about AWS security services and capabilities.

The guidance and discussions in the AWS SRA include important features as well as deployment and management considerations for individual AWS security and security-related services. One feature of the AWS SRA is that it provides a high-level introduction to the breadth of the AWS security services and how they work together in a multi-account environment. This complements the deep dive into the features and configuration for each service found in other sources. One example of this is the [discussion](#) of how AWS Security Hub Cloud Security Posture Management (CSPM) ingests security findings from a variety of AWS services, AWS Partner products, and even your own applications.

- *Drive* a discussion of organizational governance and responsibilities for security.

An important element of designing and implementing any security architecture or strategy is understanding who in your organization has which security-related responsibilities. For example, the question of where to aggregate and monitor security findings is tied to the question of which team will be responsible for that activity. Are all findings across the organization monitored by a central team that needs access to a dedicated Security Tooling account? Or are individual application teams (or business units) responsible for certain monitoring activities and therefore need access to certain alerting and monitoring tools? As another example, if your organization has a group that manages all encryption keys centrally, that will influence who has permission to create AWS Key Management Service (AWS KMS) keys and which accounts those keys will be managed in. Understanding the characteristics of your organization—the various teams and responsibilities—will help you tailor the AWS SRA to best fit your needs. Conversely, sometimes the discussion of the security architecture becomes the impetus for discussing the

existing organizational responsibilities and considering potential changes. AWS recommends a decentralized decision-making process where workload teams are responsible for defining the security controls based on their workload functions and requirements. The goal of centralized security and governance team is to build a system that allows the workload owners to make informed decisions and for all parties to get visibility of configuration, findings, and events. The AWS SRA can be a vehicle for identifying and informing these discussions.

Key implementation guidelines of the AWS SRA

Here are eight key takeaways from the AWS SRA to keep in mind as you design and implement your security.

- AWS Organizations and an appropriate multi-account strategy are necessary elements of your security architecture. Properly separating workloads, teams, and functions provides the foundations for separation of duties and defense-in-depth strategies. The guide covers this further in a [later section](#).
- Defense-in-depth is an important design consideration for selecting security controls for your organization. It helps you inject the appropriate security controls at different layers of the AWS Organizations structure, which helps minimize the impact of an issue: If there is an issue with one layer, there are controls in place that isolate other valuable IT resources. The AWS SRA demonstrates how different AWS services function at different layers of the AWS technology stack, and how using those services in combination helps you achieve defense-in-depth. This defense-in-depth concept on AWS is further discussed in a [later section](#) with design examples shown under [Application account](#).
- Use the wide variety of security building blocks across multiple AWS services and features to build a robust and resilient cloud infrastructure. When tailoring the AWS SRA to your particular needs, consider not only the primary function of AWS services and features (for example, authentication, encryption, monitoring, permission policy) but also how they fit into the structure of your architecture. A [later section](#) in the guide describes how some services operate across your entire AWS organization. Other services operate best within a single account, and some are designed to grant or deny permission to individual principals. Considering both of these perspectives helps you build a more flexible, layered security approach.
- Where possible (as detailed in later sections), make use of AWS services that can be deployed in every account (distributed instead of centralized) and build a consistent set of shared guardrails that can help protect your workloads from misuse and help reduce the impact of security events. The AWS SRA uses AWS Security Hub CSPM (centralized finding monitoring and compliance

checks), Amazon GuardDuty (threat detection and anomaly detection), AWS Config (resource monitoring and change detection), IAM Access Analyzer (resource access monitoring), AWS CloudTrail (logging service API activity across your environment), and Amazon Macie (data classification) as a base set of AWS services to be deployed across every AWS account.

- Make use of the delegated administration feature of AWS Organizations, where it is supported, as explained later in the [delegated administration](#) section of the guide. This enables you to register an AWS member account as an administrator for supported services. Delegated administration provides flexibility for different teams within your enterprise to use separate accounts, as appropriate for their responsibilities, to manage AWS services across the environment. In addition, using a delegated administrator helps you limit access to, and manage the permissions overhead of, the AWS Organizations management account.
- Implement centralized logging, monitoring, management, and governance across your AWS organizations by using [Amazon CloudWatch Unified Data Experience](#) as the preferred primary method for log data collection, security analytics, and operational observability. CloudWatch Unified Data Experience provides unified data management and analytics capabilities that consolidate operational, security, and compliance data across your AWS environment and third-party sources into a single service. By using CloudWatch Pipelines with organization-wide centralization rules, your central security, network, and cloud engineering teams can automatically aggregate AWS vended logs (such as CloudTrail, Amazon VPC Flow Logs, AWS WAF, Amazon Route 53, and Amazon EKS audit logs) and third-party security telemetry into a dedicated account within the Security OU. This helps you establish a single pane of glass for real-time visibility, anomaly detection, and incident response.
- CloudWatch Unified Data Experience natively normalizes ingested data to the Open Cybersecurity Schema Framework (OCSF) using built-in pipeline processors. This eliminates the need for custom ETL pipelines or separate normalization layers. Cross-account observability is enabled through CloudWatch Observability Access Manager (OAM), which provides linked source accounts with secure, read-only access to centralized telemetry without requiring direct access to the Monitoring account. For long-term immutable retention, CloudWatch routes log data to [Amazon S3 Tables](#) (Apache Iceberg format) in the Log Archive account, where [Amazon S3 Object Lock](#) and lifecycle policies ensure compliance with regulatory retention requirements.
- For organizations with existing Amazon Security Lake deployments or specific requirements for subscriber-based data access patterns and Parquet-based archival, Security Lake serves as a complementary secondary option. Additionally, the centralized data can be provided back to workload teams through CloudWatch cross-account dashboards, OAM links, and Logs Insights shared queries. This helps you make effective security decisions earlier in the software development lifecycle.

- Use AWS Control Tower to set up and govern your multi-account AWS environment with the implementation of pre-built security controls to bootstrap your security reference architecture build. AWS Control Tower provides a blueprint to provide identity management, federated access to accounts, centralized logging, and defined workflows for provisioning additional accounts. You can then use the [Customizations for AWS Control Tower \(CfCT\)](#) solution to baseline the accounts managed by AWS Control Tower with additional security controls, service configurations, and governance, as demonstrated by the AWS SRA code repository. The account factory feature automatically provisions new accounts with configurable templates based on approved account configuration to standardize accounts within your AWS organizations. You can also extend the governance to an individual existing AWS account by enrolling it into an organizational unit (OU) that is already governed by AWS Control Tower.
- The AWS SRA code examples demonstrate how you can automate the implementation of patterns within the AWS SRA guide by using infrastructure as code (IaC). By codifying the patterns, you can treat IaC like other applications in your organization, and automate testing before you deploy code. IaC also helps ensure consistency and repeatability by deploying guardrails across multiple (for example, SDLC or Region-specific) environments. The SRA code examples can be deployed in an AWS Organizations multi-account environment with or without AWS Control Tower. The solutions in this repository that require AWS Control Tower have been deployed and tested in an AWS Control Tower environment by using AWS CloudFormation and [Customizations for AWS Control Tower \(CfCT\)](#). Solutions that don't require AWS Control Tower have been tested in an AWS Organizations environment by using AWS CloudFormation. If you do not use AWS Control Tower, you can use the [AWS Organizations-based deployment](#) solution.

Security foundations

The AWS SRA aligns to three AWS security foundations: the AWS Cloud Adoption Framework (AWS CAF), AWS Well-Architected, and the AWS Shared Responsibility Model.

AWS Professional Services created the [AWS CAF](#) to help companies design and follow an accelerated path to successful cloud adoption. The guidance and best practices provided by the framework help you build a comprehensive approach to cloud computing across your enterprise and throughout your IT lifecycle. The AWS CAF organizes guidance into six areas of focus, called *perspectives*. Each perspective covers distinct responsibilities owned or managed by functionally related stakeholders. In general, the business, people, and governance perspectives focus on business capabilities; whereas the platform, security, and operations perspectives focus on technical capabilities.

The [security perspective of the AWS CAF](#) helps you structure the selection and implementation of controls across your business. Following the current AWS recommendations in the security pillar can help you meet your business and regulatory requirements.

[AWS Well-Architected](#) helps cloud architects build a secure, high-performing, resilient, and efficient infrastructure for their applications and workloads. The framework is based on six pillars—operational excellence, security, reliability, performance efficiency, cost optimization, and sustainability—and provides a consistent approach for AWS customers and Partners to evaluate architectures and implement designs that can scale over time. We believe that having well-architected workloads greatly increases the likelihood of business success.

The [Well-Architected Framework security pillar](#) describes how to take advantage of cloud technologies to help protect data, systems, and assets in a way that can improve your security posture. This will help you meet your business and regulatory requirements by following current AWS recommendations. There are additional Well-Architected Framework focus areas that provide more context for specific domains such as governance, serverless, AI/ML, and gaming. These are known as AWS Well-Architected lenses.

Security and compliance are a [shared responsibility between AWS and the customer](#). This shared model can help relieve your operational burden as AWS operates, manages, and controls the components from the host operating system and virtualization layer down to the physical security of the facilities in which the service operates. For example, you assume responsibility and management of the guest operating system (including updates and security patches), application

software, server-side data encryption, network traffic route tables, and the configuration of the AWS-provided security group firewall. For abstracted services such as Amazon S3 and Amazon DynamoDB, AWS operates the infrastructure layer, the operating system, and platforms, and you access the endpoints to store and retrieve data. You are responsible for managing your data (including encryption options), classifying your assets, and using IAM tools to apply the appropriate permissions. This shared model is often described by saying that AWS is responsible for the security *of* the cloud (that is, for protecting the infrastructure that runs all the services offered in the AWS Cloud), and you are responsible for the security *in* the cloud (as determined by the AWS Cloud services that you select).

Within the guidance provided by these foundational documents, two sets of concepts are particularly relevant to the design and understanding of the AWS SRA: security capabilities and security design principles.

Security capabilities

The security perspective of the AWS CAF outlines nine capabilities that help you achieve the confidentiality, integrity, and availability of your data and cloud workloads.

- *Security governance* to develop and communicate security roles, responsibilities, policies, processes, and procedures across your organization's AWS environment.
- *Security assurance* to monitor, evaluate, manage, and improve the effectiveness of your security and privacy programs.
- *Identity and access management* to manage identities and permissions at scale.
- *Threat detection* to understand and identify potential security misconfigurations, threats, or unexpected behaviors.
- *Vulnerability management* to continuously identify, classify, remediate, and mitigate security vulnerabilities.
- *Infrastructure protection* to help validate that systems and services within your workloads are protected.
- *Data protection* to maintain visibility and control over data, and how it is accessed and used in your organization.
- *Application security* to help detect and address security vulnerabilities during the software development process.
- *Incident response* to reduce potential harm by effectively responding to security incidents.

Security design principles

The [security pillar](#) of the Well-Architected Framework captures a set of seven design principles that turn specific security areas into practical guidance that can help you strengthen your workload security. Where the security capabilities frame the overall security strategy, these Well-Architected Framework principles describe what you can start doing. They are reflected very deliberately in this AWS SRA and consist of the following:

- *Implement a strong identity foundation* – Implement the principle of least privilege, and enforce separation of duties with appropriate authorization for each interaction with your AWS resources. Centralize identity management, and aim to eliminate reliance on long-term static credentials.
- *Enable traceability* – Monitor, generate alerts, and audit actions and changes to your environment in real time. Integrate log and metric collection with systems to automatically investigate and take action.
- *Apply security at all layers* – Apply a defense-in-depth approach with multiple security controls. Apply multiple types of controls (for example, preventive and detective controls) to all layers, including edge of network, virtual private cloud (VPC), load balancing, instance and compute services, operating system, application configuration, and code.
- *Automate security best practices* – Automated, software-based security mechanisms improve your ability to securely scale more rapidly and cost-effectively. Create secure architectures, and implement controls that are defined and managed as code in version-controlled templates.
- *Protect data in transit and at rest* – Classify your data into sensitivity levels and use mechanisms such as encryption, tokenization, and access control where appropriate.
- *Keep people away from data* – Use mechanisms and tools to reduce or eliminate the need to directly access or manually process data. This reduces the risk of mishandling or modification and human error when handling sensitive data.
- *Prepare for security events* – Prepare for an incident by having incident management and investigation policy and processes that align to your organizational requirements. Run incident response simulations and use tools with automation to increase your speed for detection, investigation, and recovery.

How to use the AWS SRA with AWS CAF and AWS Well-Architected Framework

The AWS CAF, AWS Well-Architected Framework, and AWS SRA are complementary frameworks that work together to support your cloud migration and modernization efforts.

- The [AWS CAF](#) leverages AWS experience and best practices to help you align the values of cloud adoption to your desired business outcomes. Use the AWS CAF to identify and prioritize transformation opportunities, evaluate and improve cloud readiness, and iteratively evolve your transformation roadmap.
- The [AWS Well-Architected Framework](#) provides AWS recommendations for building a secure, high-performing, resilient, and efficient infrastructure for a variety of applications and workloads that meet your business outcomes.
- The AWS SRA helps you understand how to deploy and govern security services in a way that aligns with the recommendations of the AWS CAF and the AWS Well-Architected Framework.

For example, the AWS CAF security perspective suggests that you evaluate how to centrally manage your workforce identities and their authentication in AWS. Based on this information, you might decide to use a new or existing corporate identity provider (IdP) solution such as Okta, Active Directory, or Ping Identity for this purpose. You follow the guidance in the AWS Well-Architected Framework and decide to integrate your IdP with the AWS IAM Identity Center to give your employees a single sign-on experience that can synchronize their group memberships and permissions. You review the AWS SRA recommendation to enable IAM Identity Center in the management account of your AWS organization and administer it through a security tooling account used by your security operations team. This example illustrates how the AWS CAF helps you make initial decisions about your desired security posture, the AWS Well-Architected Framework provides the guidance on how to evaluate the AWS services that are available for meeting that objective, and the AWS SRA then provides recommendations on how to deploy and govern the security services you select.

SRA building blocks – AWS Organizations, accounts, and guardrails

AWS security services, their controls, and interactions are best employed on a foundation of AWS [multi-account strategy](#) and identity and access management guardrails. These guardrails set the ability for your implementation of least privilege, separation of duties, and privacy, and provide the support for decisions about what types of controls are needed, where each security service is managed, and how they may share data and permissions in the AWS SRA.

An AWS account provides security, access, and billing boundaries for your AWS resources and enables you to achieve resource independence and isolation. Use of multiple AWS accounts plays an important role in how you meet your security requirements, as discussed in the [Benefits of using multiple AWS accounts](#) section of the *Organizing your AWS environment using multiple accounts* whitepaper. For example, you can organize your workloads in separate accounts and group accounts within an organizational unit (OU) based on function, compliance requirements, or a common set of controls instead of mirroring your enterprise's reporting structure. Keep security and infrastructure in mind to enable your enterprise to set common guardrails as your workloads grow. This approach provides robust boundaries and controls between workloads. Account-level separation, in combination with AWS Organizations, is used to isolate production environments from development and test environments, or to provide a strong logical boundary between workloads that process data of different classifications such as Payment Card Industry Data Security Standard (PCI DSS) or Health Insurance Portability and Accountability Act (HIPAA). Although you might begin your AWS journey with a single account, AWS recommends that you set up multiple accounts as your workloads grow in size and complexity.

Permissions let you specify access to AWS resources. Permissions are granted to IAM entities known as *principals* (users, groups, and roles). By default, principals start with no permissions. IAM principals can do nothing in AWS until you grant them permissions, and you can set up guardrails that apply as broadly as your entire AWS organization or as fine-grained as an individual combination of principal, action, resource, and conditions.

Using AWS Organizations for security

[AWS Organizations](#) helps you centrally manage and govern your environment as you grow and scale your AWS resources. By using AWS Organizations, you can programmatically create new AWS accounts, allocate resources, group accounts to organize your workloads, and apply policies

to accounts or groups of accounts for governance. An AWS organization consolidates your AWS accounts so that you can administer them as a single unit. It has one management account along with zero or more member accounts. Most of your workloads reside in member accounts, except for some centrally managed processes that must reside in either the management account or in accounts assigned as delegated administrators for specific AWS services. You can provide tools and access from a central location for your security team to manage security needs on behalf of an AWS organization. You can reduce resource duplication by sharing critical resources within your AWS organization. [You can group accounts into AWS organizational units \(OUs\)](#), which can represent different environments based on the workload's requirements and purpose. AWS Organizations also provides several policies that enable you to centrally apply additional security controls to all the member accounts in your organizations. This section focuses on service control policies (SCPs), resource control policies (RCPs), and declarative policies.

With AWS Organizations, you can use [SCPs](#) and [RCPs](#) to apply permission guardrails at the AWS organization, OU, or account level. SCPs are guardrails that apply to principals within an organization's account, with the exception of the management account (which is one reason not to run workloads in this account). When you attach an SCP to an OU, the SCP is inherited by the child OUs and accounts under that OU. SCPs do not grant any permissions. Instead, they specify the maximum permissions available for your principals in an AWS organization, OU, or account. You still need to attach [identity-based or resource-based policies](#) to principals or resources in your AWS accounts to actually grant permissions to them. For example, if an SCP denies access to all of Amazon S3, a principal affected by the SCP will not have access to Amazon S3 even if they are explicitly granted access through an IAM policy. For more information about how IAM policies are evaluated, the role of SCPs, and how access is ultimately granted or denied, see [Policy evaluation logic](#) in the IAM documentation.

RCPs are guardrails that apply to resources within an organization's accounts, regardless of whether the resources belong to the same organization. Like SCPs, RCPs don't affect the resources in the management account and do not grant any permissions. When you attach an RCP to an OU, the RCP is inherited by the child OUs and accounts under the OU. RCPs provide central control over the maximum available permissions for resources in your organization and currently support a subset of AWS services. When you design SCPs for your OUs, we recommend that you evaluate changes by using the [IAM policy simulator](#). You should also review the [service last accessed data in IAM](#) and use [AWS CloudTrail to log service usage at the API level](#) to understand the potential impact of SCP changes.

SCPs and RCPs are independent controls. You can choose to enable only SCPs or RCPs, or use both policy types together based on the access controls that you want to enforce. For example, if you

want to prevent your organization's principals from accessing resources outside your organization, you enforce this control by using SCPs. If you want to restrict or prevent external identities from accessing your resources, you enforce this control by using RCPs. For more information and use cases for RCPs and SCPs, see [Using SCPs and RCPs](#) in the AWS Organizations documentation.

You can use AWS Organizations declarative policies to centrally declare and enforce your desired configuration for a given AWS service at scale across an organization. For example, you can block public internet access to Amazon VPC resources across your organization. Unlike authorization policies such as SCPs and RCPs, declarative policies are enforced in an AWS service's control plane. Authorization policies regulate access to APIs, whereas declarative policies are applied directly at the service level to enforce durable intent. These policies help ensure that the baseline configuration for an AWS service is always maintained, even when the service introduces new features or APIs. The baseline configuration is also maintained when new accounts are added to an organization or when new principals and resources are created. Declarative policies can be applied to an entire organization or to specific OUs or accounts.

Every AWS account has a single [root user](#) that has full permissions to all AWS resources by default.

As a security best practice, we recommend that you don't use the root user except for a [few tasks](#) that explicitly require a root user. If you manage multiple AWS accounts through AWS Organizations, you can centrally disable root sign-in and then perform root privileged actions on behalf of all member accounts. After you [centrally manage root access](#) for member accounts, you can delete the root user password, access keys, and signing certificates, and deactivate multi-factor authentication (MFA) for member accounts. New accounts that are created under centrally managed root access have no root user credentials by default. Member accounts can't sign in with their root user or perform password recovery for their root user.

[AWS Control Tower](#) offers a simplified way to set up and govern multiple accounts. It automates the setup of accounts in your AWS organization, automates provisioning, applies [controls](#) (which include preventive and detective controls), and provides you with a dashboard for visibility. An additional IAM management policy, a [permissions boundary](#), is attached to specific IAM principals (users or roles) and sets the maximum permissions that an identity-based policy can grant to an IAM principal.

AWS Organizations helps you configure [AWS services](#) that apply to all your accounts. For example, you can configure central logging of all actions performed across your AWS organization by using [CloudTrail](#), and prevent member accounts from disabling logging. You can also centrally aggregate data for rules that you've defined by using [AWS Config](#), so you can audit your workloads for compliance and react quickly to changes. You can use [AWS CloudFormation StackSets](#) to centrally

manage CloudFormation stacks across accounts and OUs in your AWS organization, so you can automatically provision a new account to meet your security requirements.

The default configuration of AWS Organizations supports using SCPs as *deny lists*. By using a deny list strategy, member account administrators can delegate all services and actions until you create and attach an SCP that denies a specific service or set of actions. Deny statements require less maintenance than an allow list, because you don't have to update them when AWS adds new services. Deny statements are usually shorter in character length, so it's easier to stay within the maximum size for SCPs. In a statement where the Effect element has a value of Deny, you can also restrict access to specific resources, or define conditions for when SCPs are in effect. By contrast, an Allow statement in an SCP applies to all resources ("*") and cannot be restricted by conditions. For more information and examples, see [Strategies for using SCPs](#) in the AWS Organizations documentation.

Design considerations:

- Alternatively, to use SCPs as an *allow list*, you must replace the AWS managed FullAWSAccess SCP with an SCP that explicitly permits only those services and actions that you want to allow. For a permission to be enabled for a specified account, every SCP (from the root through each OU in the direct path to the account and even attached to the account itself) must allow that permission. This model is more restrictive in nature and might be a fit for highly regulated and sensitive workloads. This approach requires you to explicitly allow every IAM service or action in the path from the AWS account to the OU.
- Ideally, you would use a combination of deny list and allow list strategies. Use the allow list to define the list of allowed AWS services approved to be used within an AWS organization and attach this SCP at the root of your AWS organization. If you have a different set of services allowed per your development environment, you will attach the respective SCPs at each OU. You can then use the deny list to define enterprise guardrails by explicitly denying specific IAM actions.
- RCPs apply to resources for a subset of AWS services. For more information, see [List of AWS services that support RCPs](#) in the AWS Organizations documentation. The default configuration of AWS Organizations supports using RCPs as deny lists. When you enable RCPs in your organization, an AWS managed policy called RCPFullAWSAccess is automatically attached to the organization root, every OU, and every account in your organization. You cannot detach this policy. This default RCP allows all principals and actions access to pass through RCP evaluation. This means that until you start creating and attaching RCPs, all your existing IAM permissions

continue to operate as they did. This AWS managed policy does not grant access. You can then author new RCPs as a list of deny statements to block access to resources in your organization.

The management account, trusted access, and delegated administrators

The management account (also called the AWS Organization Management account or Org Management account) is unique and differentiated from every other account in AWS Organizations. It is the account that creates the AWS organization. From this account, you can create AWS accounts in the AWS organization, invite other existing accounts to the AWS organization (both types are considered *member accounts*), remove accounts from the AWS organization, and apply IAM policies to the root, OUs, or accounts within the AWS organization.

The management account deploys universal security guardrails through SCPs, RCPs, and service deployments (such as CloudTrail) that will affect all member accounts in the AWS organization. To further restrict permissions in the management account, those permissions can be delegated to another appropriate account, such as a security account, where possible.

The management account has the responsibilities of a payer account and is responsible for paying all charges that are accrued by the member accounts. You cannot switch an AWS organization's management account. An AWS account can be a member of only one AWS organization at a time.

Because of the functionality and scope of influence the management account holds, we recommend that you limit access to this account and grant permissions only to roles that need them. Two features that help you do this are [trusted access](#) and [delegated administrator](#). You can use trusted access to enable an AWS service that you specify, called the *trusted service*, to perform tasks in your AWS organization and its accounts on your behalf. This involves granting permissions to the trusted service but does not otherwise affect the permissions for IAM users or roles. You can use trusted access to specify settings and configuration details that you would like the trusted service to maintain in your AWS organization's accounts on your behalf. For example, the [Org Management account](#) section of the AWS SRA explains how to grant the CloudTrail service trusted access to create a CloudTrail organization trail in all accounts in your AWS organization.

Some AWS services support the delegated administrator feature in AWS Organizations. With this feature, compatible services can register an AWS member account in the AWS organization as an administrator for the AWS organization's accounts in that service. This capability provides flexibility for different teams within your enterprise to use separate accounts, as appropriate for their

responsibilities, to manage AWS services across the environment. The AWS security services in the AWS SRA that currently support delegated administrator include IAM Identity Center, AWS Config, AWS Firewall Manager, Amazon GuardDuty, IAM Access Analyzer, Amazon Macie, AWS Security Hub CSPM, Amazon Detective, AWS Audit Manager, Amazon Inspector, and AWS Systems Manager. Use of the delegated administrator feature is emphasized in the AWS SRA as a best practice, and we delegate administration of security-related services to the Security Tooling account.

Dedicated accounts structure

An AWS account provides security, access, and billing boundaries for your AWS resources, and enables you to achieve resource independence and isolation. By default, no access is allowed between accounts.

When designing your OU and account structure, start with security and infrastructure in mind. We recommend creating a set of foundational OUs for these specific functions, split into Infrastructure and Security OUs. These OU and account recommendations capture a subset of our broader, more comprehensive guidelines for AWS Organizations and multi-account structure design. For a full set of recommendations, see [Organizing your AWS environment using multiple accounts](#) in the AWS documentation and the blog post [Best practices for organizational units with AWS Organizations](#).

The AWS SRA utilizes the following accounts to achieve effective security operations on AWS. These dedicated accounts help ensure separation of duties, support different governance and access policies for different sensitivities of applications and data, and help mitigate the impact of a security event. In the discussions that follow, we are focused on production (*prod*) accounts and their associated workloads. Software development lifecycle (SDLC) accounts (often called *dev* and *test* accounts) are intended for staging deliverables and can operate under a different security policy set from that of production accounts.

Account	OU	Security role
Management	—	Central governance and management of all AWS Regions and accounts. The AWS account that hosts the root of the AWS organization.
Security Tooling	Security	Dedicated AWS accounts for operating broadly applicabl

e security services (such as GuardDuty, AWS Security Hub CSPM, Audit Manager, Detective, Amazon Inspector, and AWS Config), monitoring AWS accounts, and automating security alerting and response. (In AWS Control Tower, the default name for the account under the Security OU is *Audit account*.)

Log Archive

Security

Dedicated AWS accounts for ingesting and archiving all logging and backups for all AWS Regions and AWS accounts. This should be designed as immutable storage.

Network

Infrastructure

The gateway between your application and the broader internet. The Network account isolates the broader networking services, configuration, and operation from the individual application workloads, security, and other infrastructure.

Shared Services	Infrastructure	This account supports the services that multiple applications and teams use to deliver their outcomes. Examples include Identity Center directory services (Active Directory), messaging services, and metadata services.
Application	Workloads	AWS accounts that host the AWS organization's applications and perform the workloads. (These are sometimes called <i>Workload accounts</i> .) Application accounts should be created to isolate software services instead of being mapped to your teams. This makes the deployed application more resilient to organizational change.

AWS organization and account structure of the AWS SRA

The following diagram captures the high-level structure of the AWS SRA without displaying specific services. It reflects the dedicated accounts structure discussed in the previous section, and we include the diagram here to orient the discussion around the primary components of the architecture:

- All accounts that are shown in the diagram are part of a single AWS organization.
- At the upper left of the diagram is the Org Management account, which is used to create the AWS organization.
- Below the Org Management account is the Security OU with two specific accounts: one for Security Tooling and the other for Log Archive.

- Along the right side is the Infrastructure OU with the Network account and Shared Services account.
- At the bottom of the diagram is the Workloads OU, which is associated with an Application account that houses the enterprise application.

For this guidance, all accounts are considered production (prod) accounts that operate in a single AWS Region. Most AWS services (except for [global services](#)) are regionally scoped, which means that the control and data planes for the service exist independently in each AWS Region. For this reason, you must replicate this architecture across all AWS Regions that you plan to use, to ensure coverage for your entire AWS landscape. If you don't have any workloads in a specific AWS Region, you should disable the Region by using [SCPs](#) or by using logging and monitoring mechanisms. You can use Security Hub CSPM to aggregate findings and security scores from multiple AWS Regions to a single aggregation Region for centralized visibility.

When hosting an AWS organization with a large set of accounts, it's beneficial to have an orchestration layer that facilitates account deployment and account governance. AWS Control Tower offers a straightforward way to set up and govern an AWS multi-account environment. The AWS SRA code samples in the [GitHub repository](#) demonstrate how you can use the [Customizations for AWS Control Tower \(CfCT\)](#) solution to deploy AWS SRA recommended structures.



Organization



Org Management
account



OU – Infrastructure



Network
account



OU – Security



Security Tooling
account



Log Archive
account



Shared Services
account



OU – Workloads



Application
account

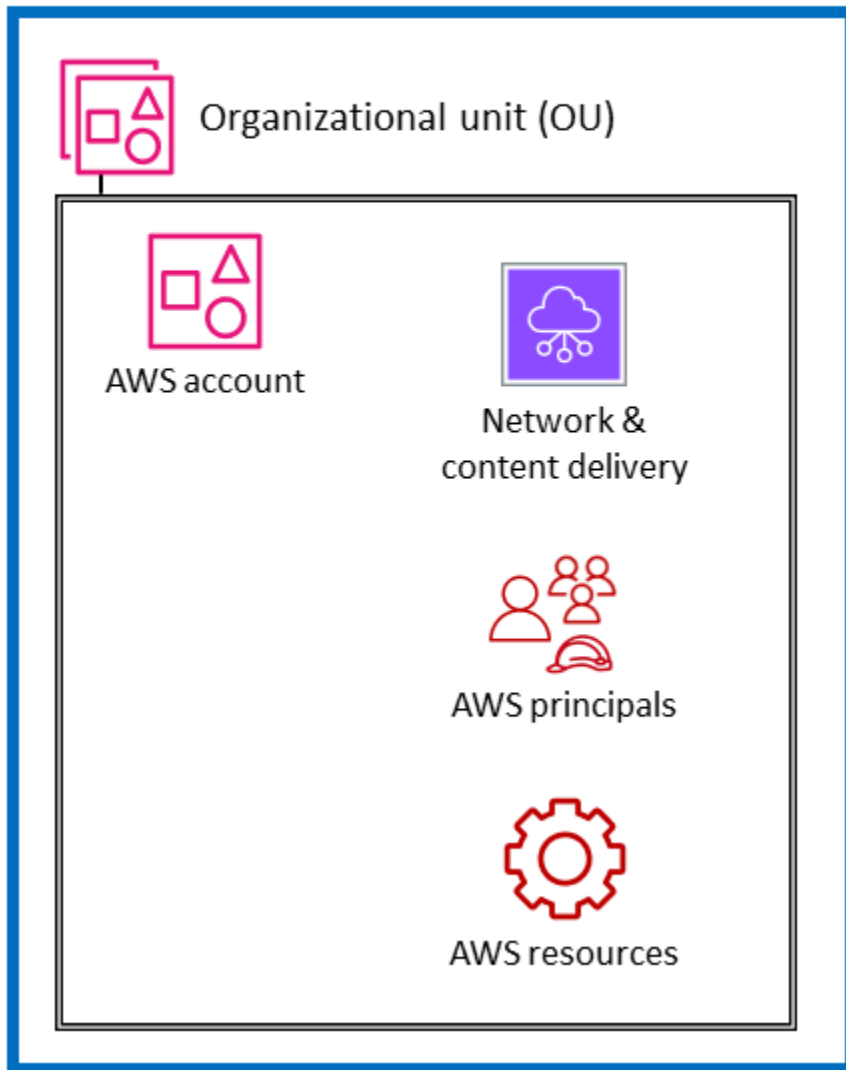
Apply security services across your AWS organization

As described in a [previous section](#), customers are looking for an additional way to think about and strategically organize the full set of AWS security services. The most common organizational approach today is to group security services by primary function—according to what each service *does*. The security perspective of the AWS CAF lists nine functional capabilities, including identity and access management, infrastructure protection, data protection, and threat detection. Matching AWS services with these functional capabilities is a practical way to make implementation decisions in each area. For example, when looking at identity and access management, IAM and IAM Identity Center are services to consider. When architecting your threat detection approach, GuardDuty might be your first consideration.

As a complement to this functional view, you can also view your security with a cross-cutting, structural view. That is, in addition to asking, "Which AWS services should I use to control and protect my identities, logical access, or threat detection mechanisms?", you can also ask, "Which AWS services should I apply across my entire AWS organization? What are the layers of defense I should put in place to protect the Amazon EC2 instances at the core of my application?" In this view, you map AWS services and features to layers in your AWS environment. Some services and features are a great fit for implementing controls across your full AWS organization. For example, blocking public access to Amazon S3 buckets is a specific control at this layer. It should preferably be done at the root organization instead of being part of the individual account setup. Other services and features are best used to help protect individual resources within an AWS account. Implementing a subordinate certificate authority (CA) within an account that requires private TLS certificates is an example of this category. Another equally important grouping consists of services that have an effect on the virtual network layer of your AWS infrastructure. The following diagram shows six layers in a typical AWS environment: AWS organization, organizational unit (OU), account, network infrastructure, principals, and resources.



AWS organization



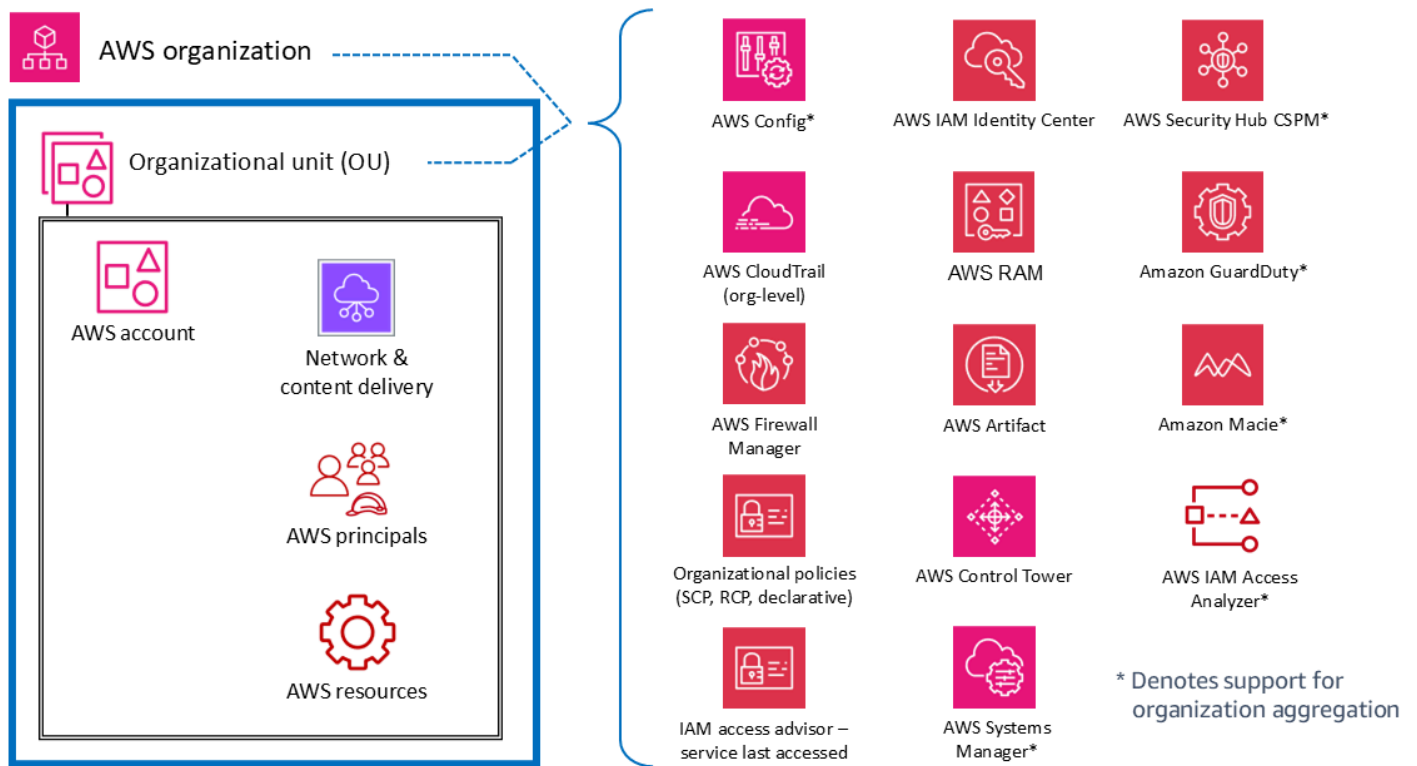
Understanding the services in this structural context, including the controls and protections at each layer, helps you plan and implement a defense-in-depth strategy across your AWS environment. With this perspective, you can answer questions both from the top down (for example, "Which services am I using to implement security controls across my entire AWS organization?") and from the bottom up (for example, "Which services manage controls on this EC2 instance?"). In this section, we walk through the elements of an AWS environment and identify associated security services and features. Of course, some AWS services have broad feature sets and support multiple security objectives. These services might support multiple elements of your AWS environment.

For clarity, we provide brief descriptions of how some of the services fit the stated objectives. The [next section](#) provides further discussion of the individual services within each AWS account.

Organization-wide or multiple accounts

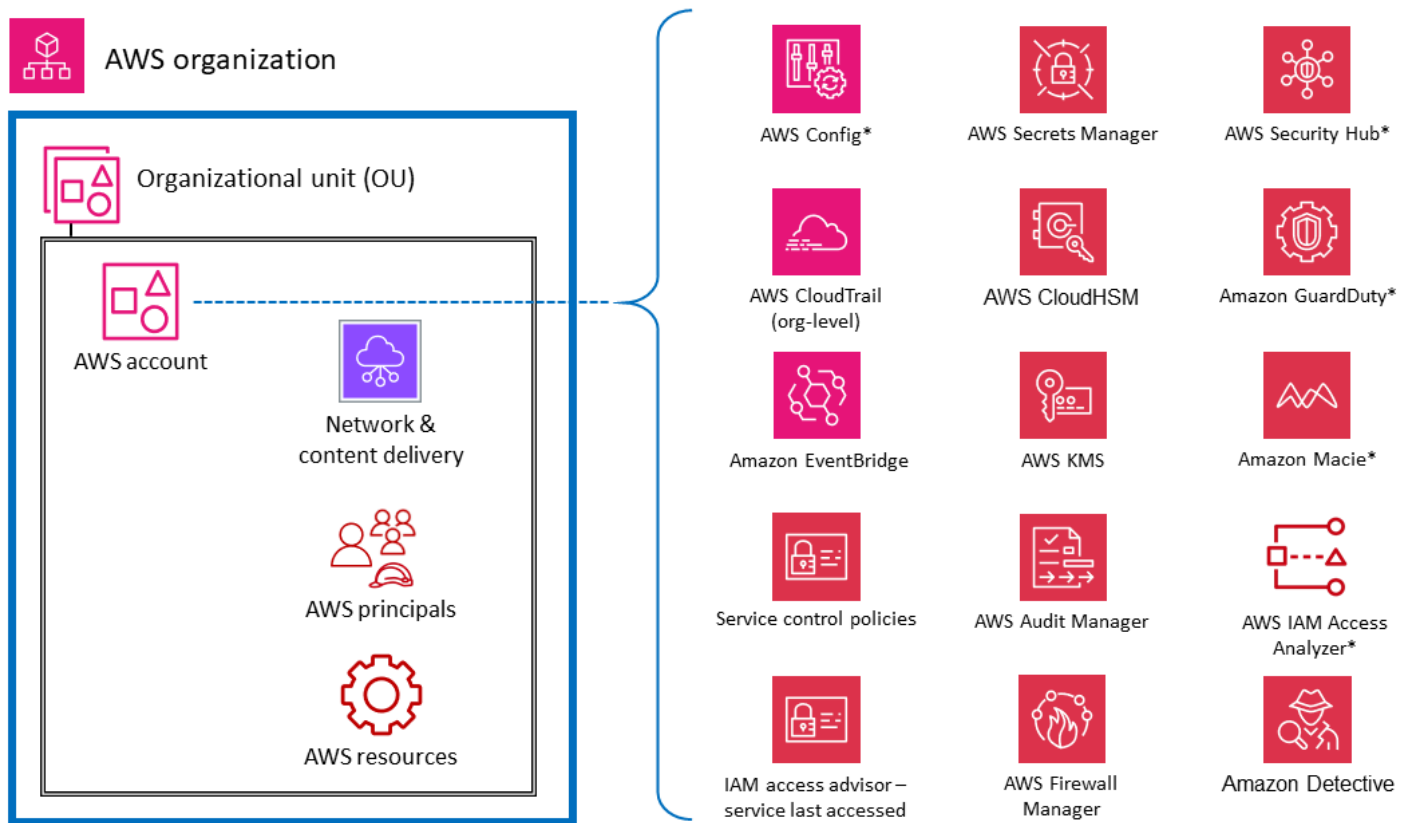
At the top level, there are AWS services and features that are designed to apply governance and control capabilities or guardrails across multiple accounts in an AWS organization (including the entire organization or specific OUs). Service control policies (SCPs) and resource control policies (RCPs) are good examples of IAM features that provide preventative, AWS organization-wide guardrails. AWS Organizations also provides a declarative policy that centrally defines and enforces the baseline configuration for AWS services at scale. Another example is CloudTrail, which provides monitoring through an *organization trail* that logs all events for all AWS accounts in that AWS organization. This comprehensive trail is distinct from individual trails that might be created in each account. A third example is AWS Firewall Manager, which you can use to configure, apply, and manage multiple resources across all accounts in your AWS organization: AWS WAF rules, AWS Shield Advanced protections, Amazon Virtual Private Cloud (Amazon VPC) security groups, AWS Network Firewall policies, and Amazon Route 53 Resolver DNS Firewall policies.

The services marked with an asterisk (*) in the following diagram operate with a dual scope: organization-wide and account-focused. These services fundamentally monitor or help control security within an individual account. However, they also support the ability to aggregate their results from multiple accounts into an organization-wide account for centralized visibility and management. For clarity, consider SCPs that apply across an entire OU, AWS account, or AWS organization. In contrast, you can configure and manage GuardDuty both at the account level (where individual findings are generated) and at the AWS organization level (by using the delegated administrator feature) where findings can be viewed and managed in aggregate.



AWS accounts

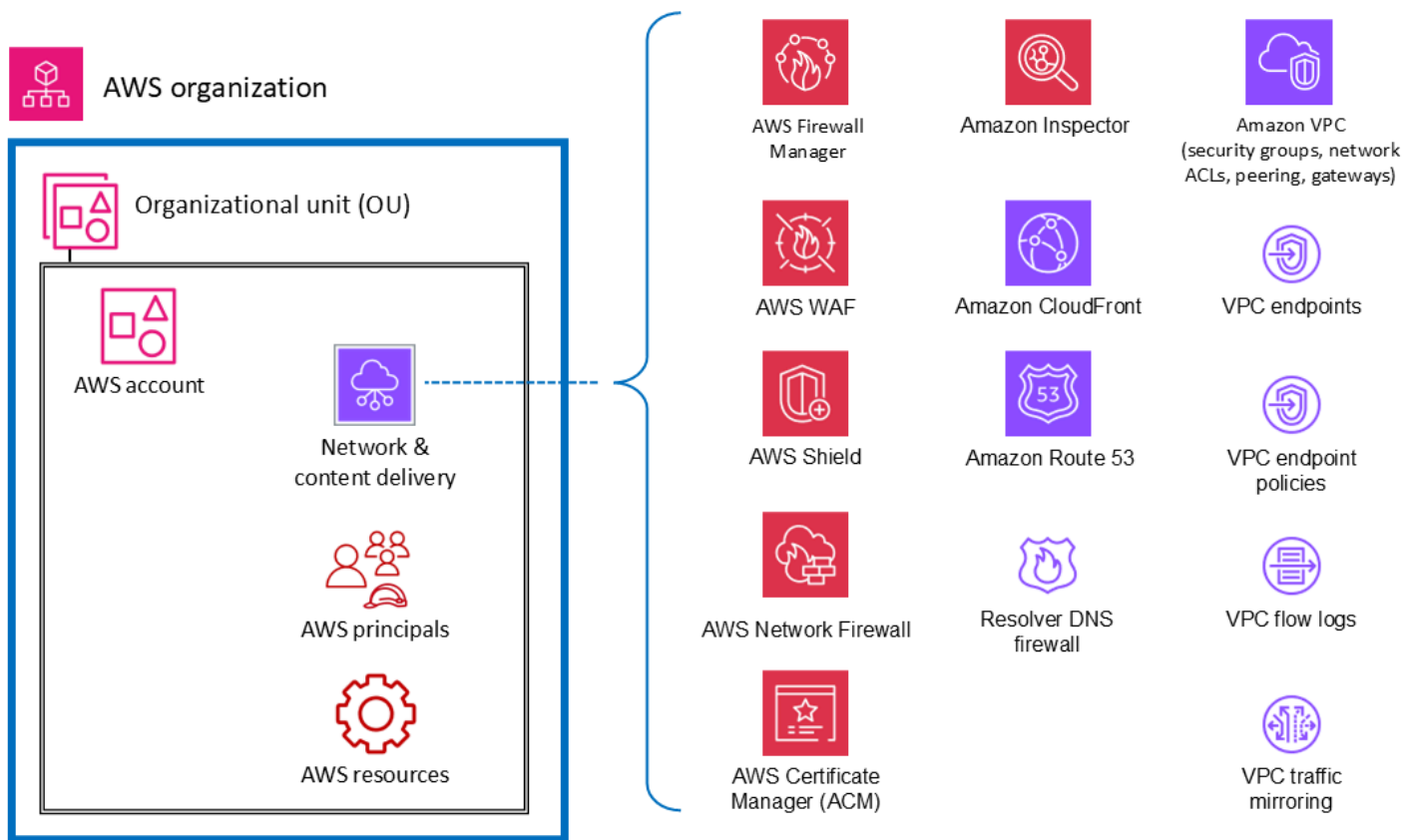
Within OUs, there are services that help protect multiple types of elements within an AWS account. For example, AWS Secrets Manager is often typically managed from a specific account and protects resources (such as database credentials or authentication information), applications, and AWS services in that account. IAM Access Analyzer can be configured to generate findings when specified resources are accessible by principals outside the AWS account. As mentioned in the previous section, many of these services can also be configured and administered within AWS Organizations, so they can be managed across multiple accounts. These services are marked with an asterisk (*) in the diagram. They also make it easier to aggregate results from multiple accounts and deliver those to a single account. This gives individual application teams the flexibility and visibility to manage security needs that are specific to their workload while also allowing governance and visibility to centralized security teams. GuardDuty is an example of such a service. GuardDuty monitors resources and activity associated with a single account, and GuardDuty findings from multiple member accounts (such as all accounts in an AWS organization) can be collected, viewed, and managed from a delegated administrator account.



* Denotes support for organization aggregation

Virtual network, compute, and content delivery

Because network access is so critical in security, and compute infrastructure is a fundamental component of many AWS workloads, there are many AWS security services and features that are dedicated to these resources. For example, Amazon Inspector is a vulnerability management service that continuously scans your AWS workloads for vulnerabilities. These scans include network reachability checks that indicate that there are allowed network paths to Amazon EC2 instances in your environment. Amazon VPC lets you define a virtual network into which you can launch AWS resources. This virtual network closely resembles a traditional network and includes a variety of features and benefits. VPC endpoints enable you to privately connect your VPC to supported AWS services and to the endpoint services powered by AWS PrivateLink without requiring a path to the internet. The following diagram illustrates security services that focus on network, compute, and content delivery infrastructure.



Principals and resources

AWS principals and AWS resources (along with IAM policies) are the fundamental elements in identity and access management on AWS. An authenticated principal in AWS can perform actions and access AWS resources. A principal can be authenticated as an AWS account root user and IAM user, or by assuming a role.

Note

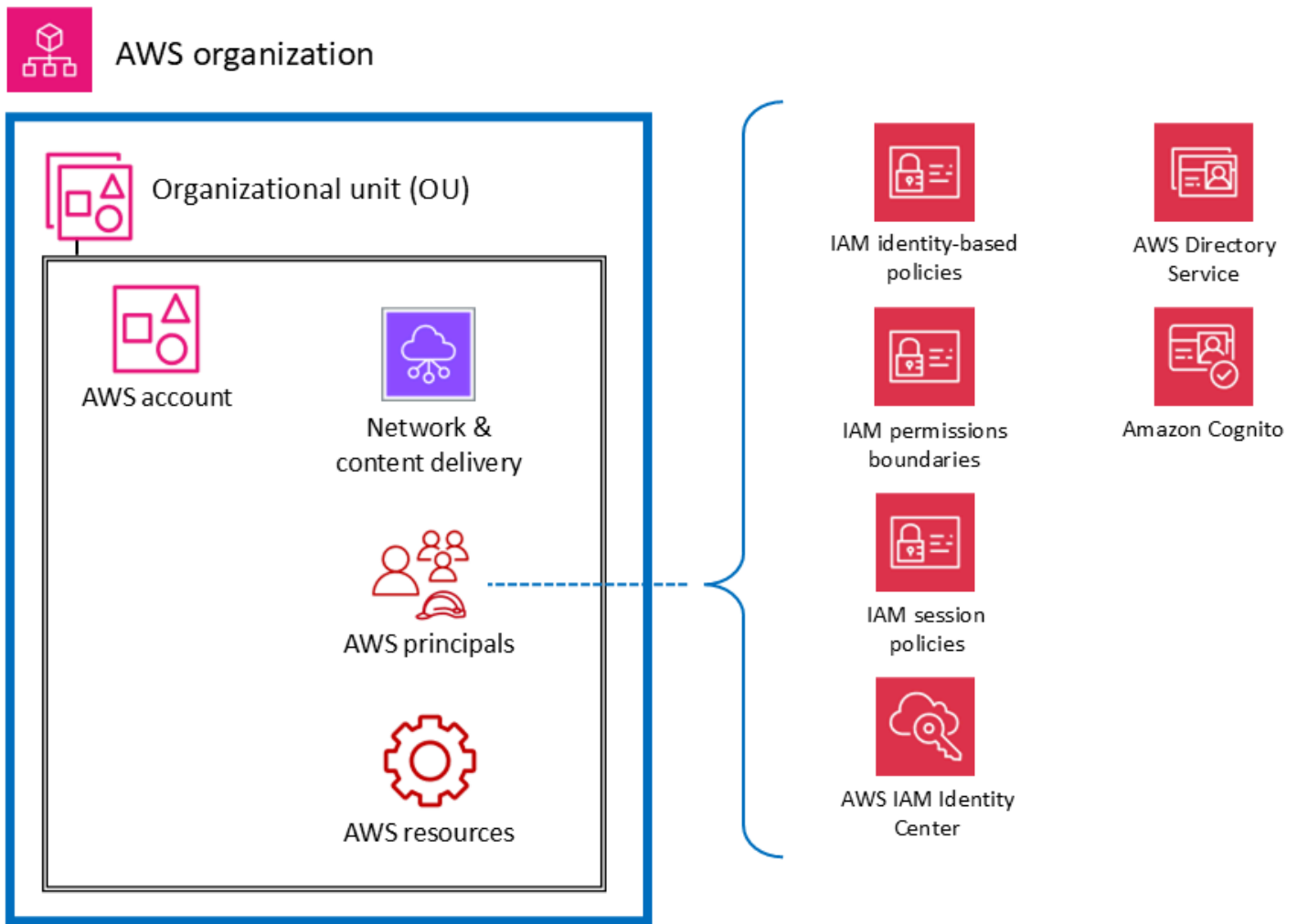
Do not create persistent API keys associated with the AWS root user account. Access to the root user account should be limited only to the [tasks that require a root user](#), and then only through a rigorous exception and approval process. For best practices to protect your account's root user, see the [IAM documentation](#).

An AWS resource is an object that exists within an AWS service that you can work with. Examples include an EC2 instance, a CloudFormation stack, an Amazon Simple Notification Service (Amazon SNS) topic, and an S3 bucket. IAM policies are objects that define permissions when they are

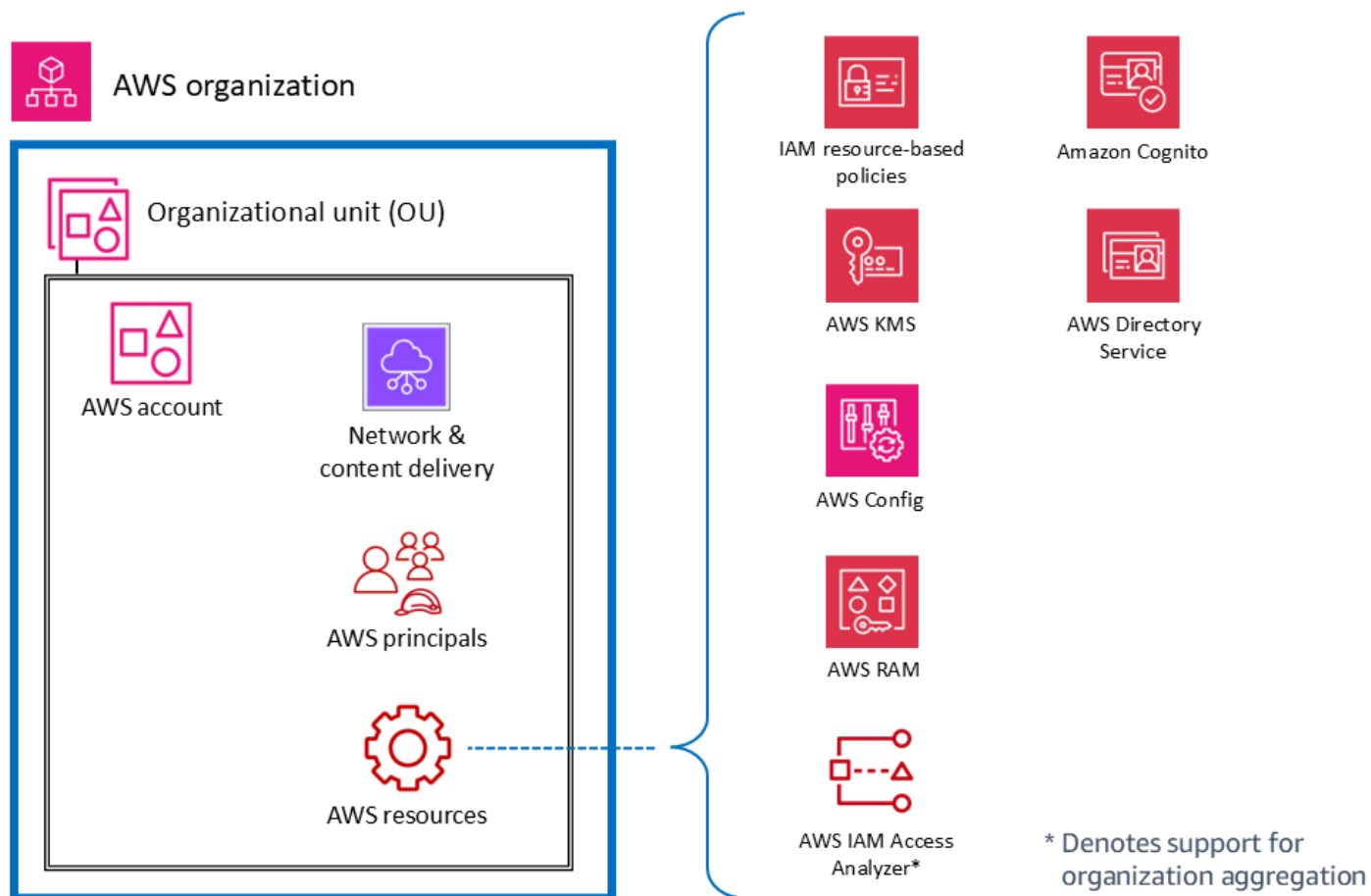
associated with an IAM principal (user, group, or role) or AWS resource. [Identity-based policies](#) are policy documents that you attach to a principal (roles, users, and groups of users) to control which actions a principal can perform, on which resources, and under which conditions. [Resource-based policies](#) are policy documents that you attach to a resource such as an S3 bucket. These policies grant the specified principal permission to perform specific actions on that resource and define the conditions for that permission. Resource-based policies are in-line policies. The [IAM resources](#) section dives deeper into the types of IAM policies and how they are used.

To keep things simple in this discussion, we list AWS security services and features for IAM principals that have a primary purpose of operating on, or applying to, account principals. We keep that simplicity while acknowledging the flexibility and breadth of effects of IAM permission policies. A single statement in a policy can have effects on multiple types of AWS entities. For example, although an IAM identity-based policy is associated with an IAM principal and defines permissions (allow, deny) for that principal, the policy also implicitly defines permissions for the actions, resources, and conditions specified. In this way, an identity-based policy can be a critical element in defining permissions for a resource.

The following diagram illustrates AWS security services and features for AWS principals. Identity-based policies are attached to an IAM user, group, or role. These policies let you specify what that identity can do (its permissions). An IAM session policy is an [inline permissions policy](#) that users pass in the session when they assume the role. You can pass the policy yourself, or you can configure your identity broker to insert the policy when your [identities federate in to AWS](#). This enables your administrators to reduce the number of roles they have to create, because multiple users can assume the same role yet have unique session permissions. The IAM Identity Center service is integrated with AWS Organizations and AWS API operations, and helps you manage SSO access and user permissions across your AWS accounts in AWS Organizations.



The following diagram illustrates services and features for account resources. Resource-based policies are attached to a resource. For example, you can attach resource-based policies to S3 buckets, Amazon Simple Queue Service (Amazon SQS) queues, VPC endpoints, and AWS KMS encryption keys. You can use resource-based policies to specify who has access to the resource and what actions they can perform on it. S3 bucket policies, AWS KMS key policies, and VPC endpoint policies are types of resource-based policies. IAM Access Analyzer helps you identify the resources in your organization and accounts, such as S3 buckets or IAM roles, that are shared with an external entity. This lets you identify unintended access to your resources and data, which is a security risk. AWS Config enables you to assess, audit, and evaluate the configurations of supported AWS resources in your AWS accounts. AWS Config continuously monitors and records AWS resource configurations, and automatically evaluates recorded configurations against desired configurations.



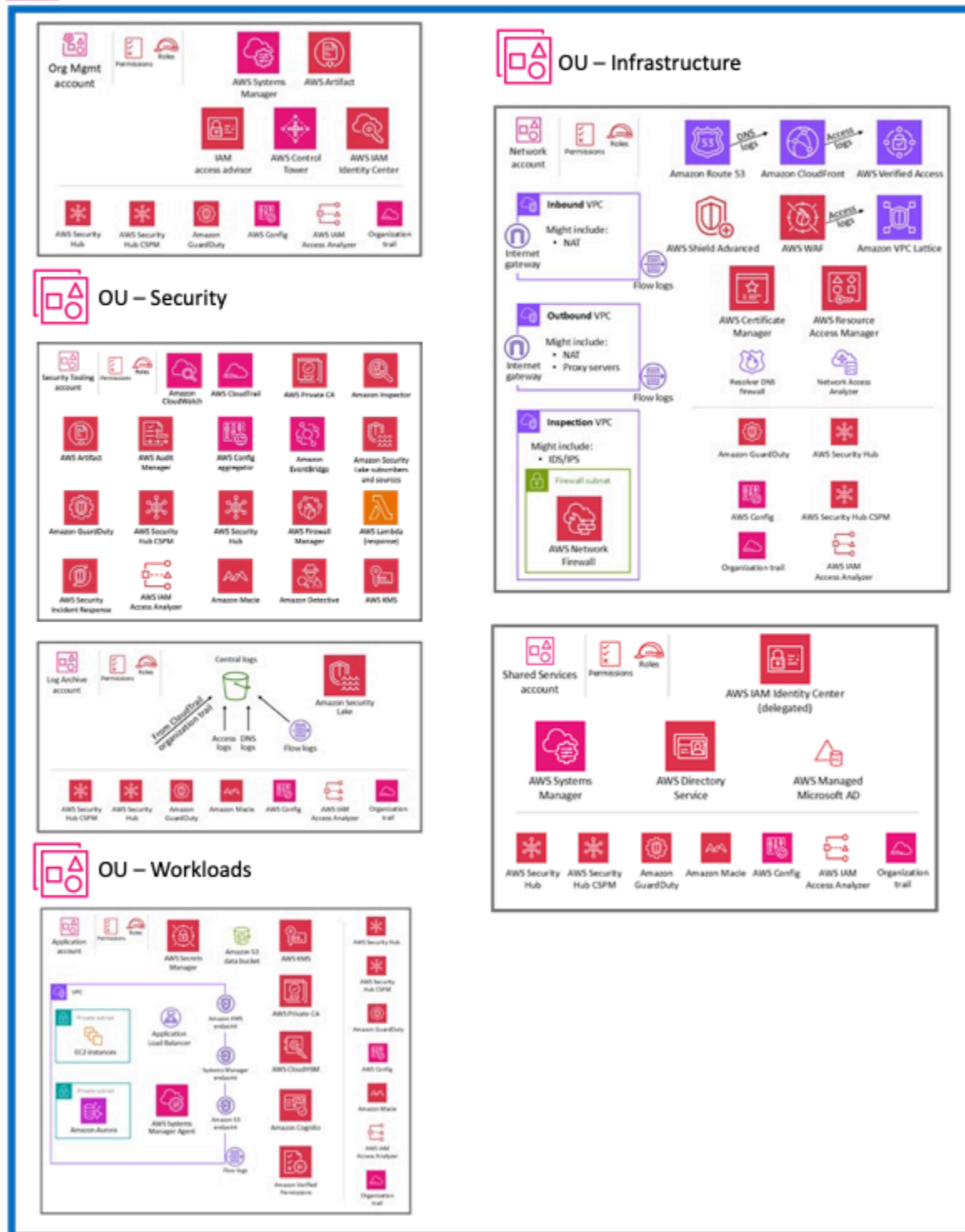
The AWS Security Reference Architecture

The following diagram illustrates the AWS SRA. This architectural diagram brings together all the AWS security-related services. It is built around a simple, three-tier web architecture that can fit on a single page. In such a workload, there is a *web tier* through which users connect and interact with the *application tier*, which handles the actual business logic of the application: taking inputs from the user, doing some computation, and generating outputs. The application tier stores and retrieves information from the *data tier*. The architecture is purposefully modular and provides high-level abstraction for many modern web applications.

Note

To customize the reference architecture diagrams in this guide based on your business needs, you can download the .zip file from the *Attachments* section of the *Introduction* chapter.

Organization



For this reference architecture, the actual web application and data tier are deliberately represented as simply as possible, through Amazon EC2 instances and an Amazon Aurora database, respectively. Most architecture diagrams focus and dive deep on the web, application, and data

tiers. For readability, they often omit the security controls. This diagram flips that emphasis to show security wherever possible, and keeps the application and data tiers as simple as necessary to show security features meaningfully.

The AWS SRA contains all AWS security-related services available at the time of publication. (See [document history](#).) However, not every workload or environment, based on its unique threat exposure, has to deploy every security service. Our goal is to provide a reference for a range of options, including descriptions of how these services fit together architecturally, so that your business can make decisions that are most appropriate for your infrastructure, workload, and security needs, based on risk.

The following sections walk through each OU and account to understand its objectives and the individual AWS security services associated with it. For each element (typically an AWS service), this document provides the following information:

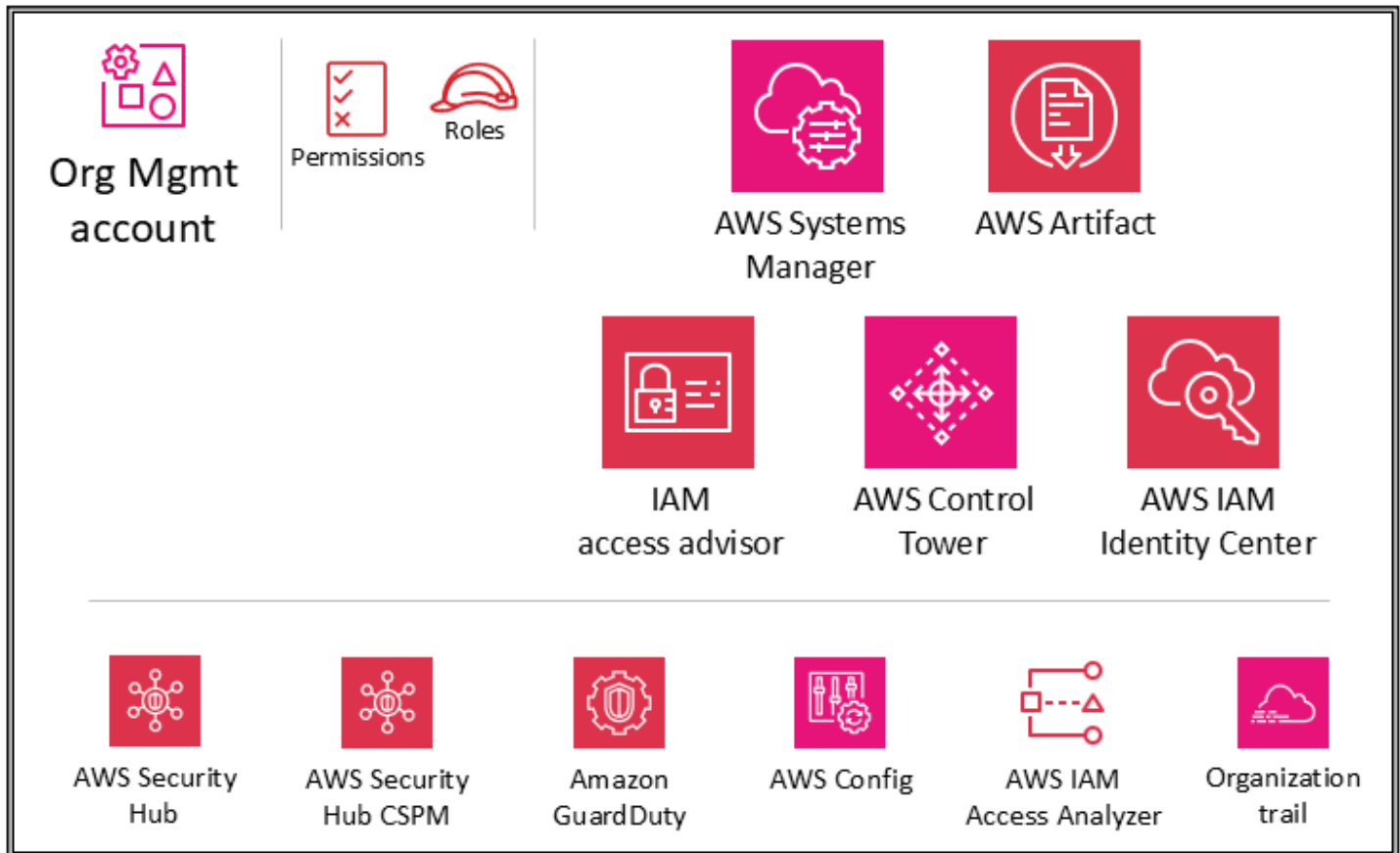
- Brief overview of the element and its security purpose in the AWS SRA. For more detailed descriptions and technical information about individual services, see [the appendix](#).
- Recommended placement to most effectively enable and manage the service. This is captured in the individual architecture diagrams for each account and OU.
- Configuration, management, and data sharing links to other security services. How does this service rely on, or support, other security services?
- Design considerations. First, the document highlights *optional* features or configurations that have important security implications. Second, where our teams' experience includes common variations in the recommendations we make—typically as a result of alternate requirements or constraints—the document describes those options.

OUs and accounts

- [Org Management account](#)
- [Security OU – Security Tooling account](#)
- [Security OU – Log Archive account](#)
- [Infrastructure OU – Network account](#)
- [Infrastructure OU – Shared Services account](#)
- [Workloads OU – Application account](#)

Org Management account

The following diagram illustrates the AWS security services that are configured in the Org Management account.



The sections [Using AWS Organizations for security](#) and [The management account, trusted access, and delegated administrators](#) earlier in this guide discussed the purpose and security objectives of the Org Management account in depth. Follow the [security best practices](#) for your Org Management account. These include using an email address that is managed by your business, maintaining the correct administrative and security contact information (such as attaching a phone number to the account in the event AWS needs to contact the owner of the account), enabling multi-factor authentication (MFA) for the all users, and regularly reviewing who has access to the Org Management account. Services deployed in the Org Management account should be configured with appropriate roles, trust policies, and other permissions so that the administrators of those services (who must access them in the Org Management account) cannot also inappropriately access other services.

Service control policies

With [AWS Organizations](#), you can centrally manage policies across multiple AWS accounts. For example, you can apply [service control policies](#) (SCPs) across multiple AWS accounts that are members of an organization. SCPs allow you to define which AWS service APIs can and cannot be run by [IAM](#) principals (such as IAM users and roles) in your organization's member AWS accounts. SCPs are created and applied from the Org Management account, which is the AWS account that you used when you created your organization. Read more about SCPs in the [Using AWS Organizations for security](#) section earlier in this reference.

If you use AWS Control Tower to manage your AWS organization, it will deploy [a set of SCPs as preventive guardrails](#) (categorized as mandatory, strongly recommended, or elective). These guardrails help you govern your resources by enforcing organization-wide security controls. These SCPs automatically use an `aws-control-tower` tag that has a value of `managed-by-control-tower`.

Design consideration:

- SCPs affect only *member* accounts in the AWS organization. Although they are applied from the Org Management account, they have no effect on users or roles in that account. To learn about how SCP evaluation logic works, and to see examples of recommended structures, see the AWS blog post [How to use service control policies in AWS Organizations](#).

Resource control policies

[Resource control policies](#) (RCPs) offer centralized control over the maximum available permissions for resources in your organization. An RCP defines a permissions guardrail or sets limits on the actions that identities can take on resources in your organization. You can use RCPs to restrict who can access your resources and enforce requirements on how your resources can be accessed in your organization's member AWS accounts. You can attach RCPs directly to individual accounts, OUs, or the organization root. For a detailed explanation of how RCPs work, see [RCP evaluation](#) in the AWS Organizations documentation. Read more about RCPs in the [Using AWS Organizations for security](#) section earlier in this reference.

If you use AWS Control Tower to manage your AWS organization, it will deploy a set of RCPs as preventative guardrails. These guardrails help you govern your resources by enforcing organization-wide security controls. These RCPs automatically use an `aws-control-tower` tag that has a value of `managed-by-control-tower`.

Design considerations:

- RCPs affect only resources in **member** accounts in the organization. They have no effect on resources in the management account. This also means that RCPs apply to member accounts that are designated as delegated administrators.
- RCPs apply to resources for a subset of AWS services. For more information, see [List of AWS services that support RCPs](#) in the AWS Organizations documentation. You can use [AWS Config Rules](#) and [AWS Lambda functions](#) to monitor and automate the enforcement of security controls on resources that aren't currently supported by RCPs.

Declarative policies

A declarative policy is a type of AWS Organizations management policy that helps you centrally declare and enforce your desired configuration for a given AWS service at scale across an organization. How those policies affect the OUs and accounts that inherit them depends on the type of declarative policy that you apply in AWS Organizations. For the latest supported services and attributes, see [Declarative policies](#) in the AWS Organizations documentation.

You can enforce the baseline configuration for an AWS service by making a few selections on the AWS Organizations and AWS Control Tower consoles or by using a few AWS Command Line Interface (AWS CLI) and AWS SDK commands. Declarative policies are enforced in the service's control plane, which means that the baseline configuration for an AWS service is always maintained, even when the service introduces new features or APIs, when new accounts are added to an organization, or when new principals and resources are created. Declarative policies can be applied to an entire organization or to specific OUs or accounts. The *effective policy* is the set of rules that are inherited from the organization root and OUs along with the policies that are directly attached to the account. If a declarative policy is [detached](#), the attribute state will roll back to its state before the declarative policy was attached.

You can use declarative policies to create custom error messages. For example, if an API operation fails because of a declarative policy, you can set the error message or provide a custom URL—such as a link to an internal wiki or a link to a message that describes the failure. This helps provide users with more information so they can troubleshoot the issue themselves. You can also audit the process of creating declarative policies, updating declarative policies, and deleting declarative policies by using AWS CloudTrail.

Declarative policies provide *account status reports*, which enable you to review the current status of all attributes that are supported by declarative policies for the accounts in scope. You can choose the accounts and OUs to include in the report scope or choose an entire

organization by selecting the root. This report helps you assess readiness by providing a breakdown by AWS Region and specifying whether the current state of an attribute is *uniform across accounts* (through the `numberOfMatchedAccounts` value) or *inconsistent across accounts* (through the `numberOfUnmatchedAccounts` value).

Design consideration:

- When you configure a service attribute by using a declarative policy, the policy might impact multiple APIs. Any noncompliant actions will fail. Account administrators will not be able to modify the value of the service attribute at the individual account level.

Centralized root access

All member accounts in AWS Organizations have their own root user, which is an identity that has complete access to all AWS services and resources in that member account. IAM provides centralized root access management to manage root access across all member accounts. This helps prevent member root user usage and helps provide recovery at scale. The centralized root access feature has two essential capabilities: root credentials management and root sessions.

- The root credentials management capability allows central management and helps secure root user across all management accounts. This capability includes the removal of long-term root credentials, prevention of root credential recovery by member accounts, and provisioning of new member accounts with no root credentials by default. It also provides an easy way to demonstrate compliance. When root user management is centralized, you can remove root user passwords, access keys, and signing certificates, and deactivate multi-factor authentication (MFA) from all member accounts.
- The root sessions capability enables you to perform privileged root user actions by using short-term credentials on member accounts from the Org Management account or from delegated administrator accounts. This capability helps you enable short-term root access that is scoped to specific actions, adhering to the principle of least privilege.

For centralized root credential management, you need to enable root credential management and root sessions capabilities at the organization level from the Org Management account or in a delegated administrator account. Following AWS SRA best practices, we delegate this capability to the Security Tooling account. For information about configuring and using centralized root user access, see the AWS Security blog post, [Centrally managing root access for customers using AWS Organizations](#).

IAM Identity Center

[AWS IAM Identity Center](#) is an identity federation service that helps you centrally manage SSO access to all your AWS accounts, principals, and cloud workloads. IAM Identity Center also helps you manage access and permissions to commonly used third-party software as a service (SaaS) applications. Identity providers integrate with IAM Identity Center by using SAML 2.0. Bulk and just-in-time provisioning can be done by using the System for Cross-Domain Identity Management (SCIM). IAM Identity Center can also integrate with on-premises or AWS-managed Microsoft Active Directory (AD) domains as an identity provider through the use of AWS Directory Service. IAM Identity Center includes a user portal where your end-users can find and access their assigned AWS accounts, IAM Identity Center, roles, cloud applications, and custom applications in one place.

IAM Identity Center natively integrates with AWS Organizations and runs in the Org Management account by default. However, to exercise least privilege and tightly control access to the management account, IAM Identity Center administration can be delegated to a specific member account. In the AWS SRA, the Shared Services account is the delegated administrator account for IAM Identity Center. Before you enable delegated administration for IAM Identity Center, review [these considerations](#). You will find more information about delegation in the [Shared Services account](#) section. Even after you enable delegation, IAM Identity Center still needs to run in the Org Management account to perform certain [IAM Identity Center-related tasks](#), which include managing permission sets that are provisioned in the Org Management account.

Within the IAM Identity Center console, accounts are displayed by their encapsulating OU. This enables you to quickly discover your AWS accounts, apply common sets of permissions, and manage access from a central location.

IAM Identity Center includes an identity store where specific user information must be stored. However, IAM Identity Center does not have to be the authoritative source for workforce information. In cases where your enterprise already has an authoritative source, IAM Identity Center supports the following types of identity providers (IdPs).

- **IAM Identity Center identity store** – Choose this option if the following two options are not available. Users are created, group assignments are made, and permissions are assigned in the identity store. Even if your authoritative source is external to IAM Identity Center, a copy of principal attributes will be stored with the identity store.
- **Microsoft Active Directory (AD)** – Choose this option if you want to continue managing users in either your directory in AWS Directory Service for Microsoft Active Directory or your self-managed directory in Active Directory.

- **External identity provider** – Choose this option if you prefer to manage users in an external third-party, SAML-based IdP.

You can rely on an existing IdP that is already in place within your enterprise. This makes it easier to manage access across multiple applications and services, because you are creating, managing, and revoking access from a single location. For example, if someone leaves your team, you can revoke their access to all applications and services (including AWS accounts) from one location. This reduces the need for multiple credentials and provides you with an opportunity to integrate with your human resources (HR) processes.

Design consideration:

- Use an external IdP if that option is available to your enterprise. If your IdP supports System for Cross-domain Identity Management (SCIM), take advantage of the SCIM capability in IAM Identity Center to automate user, group, and permission provisioning (synchronization). This allows AWS access to stay in sync with your corporate workflow for new hires, employees who are moving to another team, and employees who are leaving the company. At any given time, you can have only one directory or one SAML 2.0 identity provider connected to IAM Identity Center. However, you can switch to another identity provider.

IAM access advisor

IAM access advisor provides traceability data in the form of service last accessed information for your AWS accounts and OUs. Use this detective control to contribute to a [least privilege strategy](#). For IAM principals, you can view two types of last accessed information: allowed AWS service information and allowed action information. The information includes the date and time when the attempt was made.

IAM access within the Org Management account lets you view service last accessed data for the Org Management account, OU, member account, or IAM policy in your AWS organization. This information is available in the IAM console within the management account and can also be obtained programmatically by using IAM access advisor APIs in AWS CLI or a programmatic client. The information indicates which principals in an organization or account last attempted to access the service and when. Last accessed information provides insight for actual service usage (see [example scenarios](#)), so you can reduce IAM permissions to only those services that are actually used.

AWS Systems Manager

Quick Setup and Explorer, which are capabilities of [AWS Systems Manager](#), both support AWS Organizations and operate from the Org Management account.

[Quick Setup](#) is an automation feature of Systems Manager. It enables the Org Management account to easily define configurations for Systems Manager to engage on your behalf across accounts in your AWS organization. You can enable Quick Setup across your entire AWS organization or choose specific OUs. Quick Setup can schedule AWS Systems Manager Agent (SSM Agent) to run biweekly updates on your EC2 instances and can set up a daily scan of those instances to identify missing patches.

[Explorer](#) is a customizable operations dashboard that reports information about your AWS resources. Explorer displays an aggregated view of operations data for your AWS accounts and across AWS Regions. This includes data about your EC2 instances and patch compliance details. After you complete Integrated Setup (which also includes Systems Manager OpsCenter) within AWS Organizations, you can aggregate data in Explorer by OU or for an entire AWS organization. Systems Manager aggregates the data into the AWS Org Management account before displaying it in Explorer.

The [Workloads OU](#) section later in this guide discusses the use of the SSM Agent on the EC2 instances in the Application account.

AWS Control Tower

[AWS Control Tower](#) provides a straightforward way to set up and govern a secure, multi-account AWS environment, which is called a *landing zone*. AWS Control Tower creates your landing zone by using AWS Organizations, and provides ongoing account management and governance as well as implementation best practices. You can use AWS Control Tower to provision new accounts in a few steps while ensuring that the accounts conform to your organizational policies. You can even add existing accounts to a new AWS Control Tower environment.

AWS Control Tower has a broad and flexible set of features. A key feature is its ability to *orchestrate* the capabilities of several other [AWS services](#), including AWS Organizations, AWS Service Catalog, and IAM Identity Center, to build a landing zone. For example, by default, AWS Control Tower uses AWS CloudFormation to establish a baseline, AWS Organizations service control policies (SCPs) prevent configuration changes, and AWS Config rules continuously detect non-conformance. AWS Control Tower employs blueprints that help you quickly align your multi-account AWS environment

with [AWS Well-Architected security foundation design principles](#). Among governance features, AWS Control Tower offers guardrails that prevent deployment of resources that don't conform to selected policies.

You can get started implementing AWS SRA guidance with AWS Control Tower. For example, AWS Control Tower establishes an AWS organization with the recommended multi-account architecture. It provides blueprints to provide identity management, provide federated access to accounts, centralize logging, establish cross-account security audits, define a workflow for provisioning new accounts, and implement account baselines with network configurations.

In the AWS SRA, AWS Control Tower is within the Org Management account because AWS Control Tower uses this account to set up an AWS organization automatically and designates that account as the management account. This account is used for billing across your AWS organization. It's also used for Account Factory provisioning of accounts, to manage OUs, and to manage guardrails. If you are launching AWS Control Tower in an existing AWS organization, you can use the existing management account. AWS Control Tower will use that account as the designated management account.

Design consideration:

- If you want to do additional baselining of controls and configurations across your accounts, you can use [Customizations for AWS Control Tower \(CfCT\)](#). With CfCT, you can customize your AWS Control Tower landing zone by using a CloudFormation template and SCPs. You can deploy the custom template and policies to individual accounts and OUs within your organization. CfCT integrates with AWS Control Tower lifecycle events to ensure that resource deployments stay in sync with your landing zone.

AWS Artifact

[AWS Artifact](#) provides on-demand access to AWS security and compliance reports and select online agreements. Reports available in AWS Artifact include System and Organization Controls (SOC) reports, Payment Card Industry (PCI) reports, and certifications from accreditation bodies across geographies and compliance verticals that validate the implementation and operating effectiveness of AWS security controls. AWS Artifact helps you perform your due diligence of AWS with enhanced transparency into our security control environment. It also lets you continuously monitor the security and compliance of AWS with immediate access to new reports.

AWS Artifact Agreements enable you to review, accept, and track the status of AWS agreements such as the Business Associate Addendum (BAA) for an individual account and for the accounts that are part of your organization in AWS Organizations.

You can provide the AWS audit artifacts to your auditors or regulators as evidence of AWS security controls. You can also use the responsibility guidance provided by some of the AWS audit artifacts to design your cloud architecture. This guidance helps determine the additional security controls you can put in place to support the specific use cases of your system.

AWS Artifact is hosted in the Org Management account to provide a central location where you can review, accept, and manage agreements with AWS. This is because agreements that are accepted at the management account flow down to the member accounts.

Design consideration:

- Users within the Org Management account should be restricted to use only the Agreements feature of AWS Artifact and nothing else. To implement segregation of duties, AWS Artifact is also hosted in the Security Tooling account where you can delegate permissions to your compliance stakeholders and external auditors to access audit artifacts. You can implement this separation by defining fine-grained IAM permission policies. For examples, see [Example IAM policies](#) in the AWS documentation.

Distributed and centralized security service guardrails

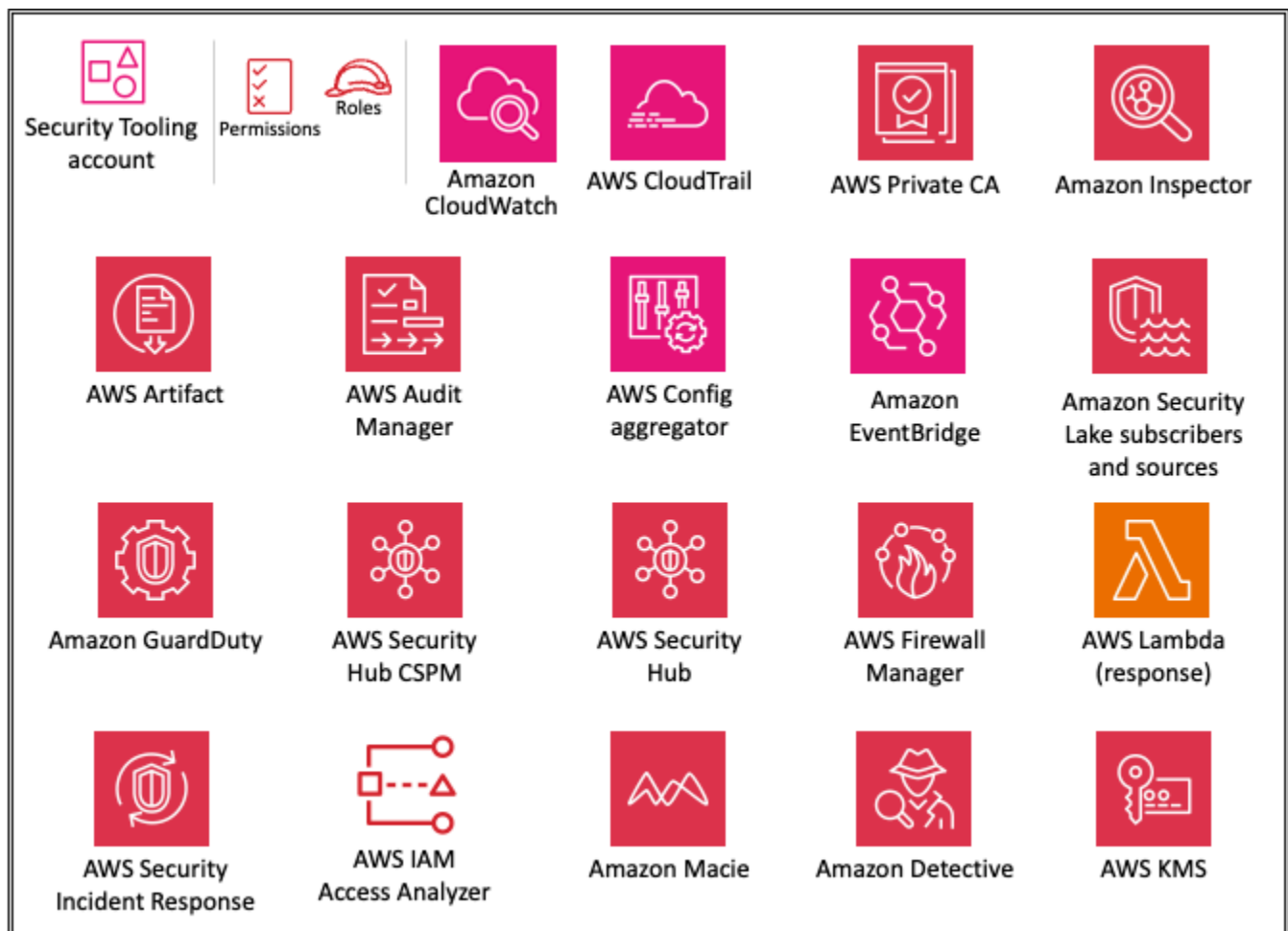
In the AWS SRA, AWS Security Hub CSPM, AWS Security Hub, Amazon GuardDuty, AWS Config, IAM Access Analyzer, AWS CloudTrail organization trails, and often Amazon Macie are deployed with appropriate delegated administration or aggregation to the Security Tooling account. This enables a consistent set of guardrails across accounts and also provides centralized monitoring, management, and governance across your AWS organization. You will find this group of services in every type of account represented in the AWS SRA. These should be part of the AWS services that must be provisioned as part of your account onboarding and baselining process. The [GitHub code repository](#) provides a sample implementation of AWS security-focused services across your accounts, including the AWS Org Management account.

In addition to these services, AWS SRA includes two security-focused services, Amazon Detective and AWS Audit Manager, which support the integration and delegated administrator functionality in AWS Organizations. However, those are not included as part of the recommended services for account baselining. We have seen that these services are best used in the following scenarios:

- You have a dedicated team or group of resources that perform those digital forensics and IT audit functions. Detective is best utilized by security analyst teams, and Audit Manager is helpful to your internal audit or compliance teams.
- You want to focus on a core set of tools such as AWS Config, Amazon GuardDuty, AWS Security Hub, and AWS Security Hub CSPM at the start of your project, and then build on these by using services that provide additional capabilities.

Security OU – Security Tooling account

The following diagram illustrates the AWS security services that are configured in the Security Tooling account.



The Security Tooling account is dedicated to operating security services, monitoring AWS accounts, and automating security alerting and response. The security objectives include the following:

- Provide a dedicated account with controlled access to manage access to the security guardrails, monitoring, and response.
- Maintain the appropriate centralized security infrastructure to monitor security operations data and maintain traceability. Detection, investigation, and response are essential parts of the security lifecycle and can be used to support a quality process, a legal or compliance obligation, and for threat identification and response efforts.
- Further support a defense-in-depth organization strategy by maintaining another layer of control over appropriate security configuration and operations such as encryption keys and security group settings. This is an account where security operators work. Read-only/audit roles to view AWS organization-wide information are typical, whereas write/modify roles are limited in number, tightly controlled, monitored, and logged.

Design considerations:

- AWS Control Tower names the account under the Security OU the *Audit Account* by default. You can rename the account during the AWS Control Tower setup.
- It might be appropriate to have more than one Security Tooling account. For example, monitoring and responding to security events are often assigned to a dedicated team. Network security might warrant its own account and roles in collaboration with the cloud infrastructure or network team. Such splits retain the objective of separating centralized security enclaves and further emphasize the separation of duties, least privilege, and potential simplicity of team assignments. If you are using AWS Control Tower, it restricts the creation of additional AWS accounts under the Security OU.

Delegated administrator for security services

The Security Tooling account serves as the administrator account for security services that are managed in an administrator/member structure throughout the AWS accounts. As mentioned earlier, this is handled through the AWS Organizations delegated administrator functionality. Services in the AWS SRA that [currently support delegated administrator](#) include IAM centralized management of root access, AWS Config, AWS Firewall Manager, Amazon GuardDuty, IAM Access Analyzer, Amazon Macie, AWS Security Hub, AWS Security Hub CSPM, Amazon Detective, AWS Audit Manager, Amazon Inspector, AWS CloudTrail, and AWS Systems Manager. Your security team manages the security features of these services and monitors any security-specific events or findings.

AWS IAM Identity Center supports delegated administration to a member account. AWS SRA uses the Shared Services account as the delegated administrator account for IAM Identity Center, as explained later in the [IAM Identity Center](#) section of the Shared Services account.

Centralized root access

The Security Tooling account is the delegated administrator account for IAM centralized management of root access capability. This capability has to be enabled at the organization level by enabling credential management and privileged root action in member accounts. Delegated administrators have to be provided `sts:AssumeRoot` permissions explicitly to be able to take privileged root actions on behalf of member accounts. This permission is available only after privileged root action in a member account is enabled in the Org Management or delegated administrator account. With this permission, users can perform privileged root user tasks on member accounts, centrally from the Security Tooling account. After you launch a privileged session, you can delete a misconfigured S3 bucket policy, delete a misconfigured SQS queue policy, delete the root user credentials for a member account, and reenale root user credentials for a member account. You can perform these actions from the console, by using the AWS Command Line Interface (AWS CLI) or through APIs.

AWS CloudTrail

[AWS CloudTrail](#) is a service that supports the governance, compliance, and auditing of activity in your AWS account. With CloudTrail, you can log, continuously monitor, and retain account activity related to actions across your AWS infrastructure. CloudTrail is integrated with AWS Organizations, and that integration can be used to create a single trail that logs all events for all accounts in the AWS organization. This is referred to as an *organization trail*. You can create and manage an organization trail only from within the management account for the organization or from a delegated administrator account. When you create an organization trail, a trail with the name that you specify is created in every AWS account that belongs to your AWS organization. The trail logs activity for all accounts, including the management account, in the AWS organization and stores the logs in a single S3 bucket. Because of the sensitivity of this S3 bucket, you should secure it by following the best practices outlined in the [Amazon S3 as central log store](#) section later in this guide. All accounts in the AWS organization can see the organization trail in their list of trails. However, member AWS accounts have view-only access to this trail. By default, when you create an organization trail in the CloudTrail console, the trail is a multi-Region trail. For additional security best practices, see the [CloudTrail documentation](#).

In the AWS SRA, the Security Tooling account is the delegated administrator account for managing CloudTrail. The corresponding S3 bucket to store the organization trail logs is created in the Log Archive account. This is to separate the management and usage of CloudTrail log privileges. For information about how to create or update an S3 bucket to store log files for an organization trail, see the [CloudTrail documentation](#). As a security best practice, add the `aws:SourceArn` condition key of the organization trail to the resource policy of the S3 bucket (and any other resources such as KMS keys or SNS topics). This ensures that the S3 bucket accepts only data that is associated with the specific trail. The trail is configured with [log file validation](#) for log file integrity validation. The log and digest files are encrypted by using SSE-KMS. The organization trail is also integrated with a log group in CloudWatch Logs to send events for long-term retention.

Note

You can create and manage organization trails from both management and delegated administrator accounts. However, as a best practice, you should limit access to the management account and use the delegated administrator functionality where it is available.

Design considerations:

- CloudTrail does not log [data events](#) by default because these are often high-volume activities. However, you should capture data events for specific critical AWS resources, such as S3 buckets, Lambda functions, log events from outside AWS that are either sent to Amazon S3 or forwarded using Amazon SQS and Amazon SNS topics. To do this, configure your organization trail to include data events from specific resources by specifying the Amazon Resource Name (ARN) of each resource.
- If a member account requires access to CloudTrail log files for its own account, you can [selectively share](#) the organization's CloudTrail log files from the central S3 bucket. However, if member accounts require local Amazon CloudWatch log groups for their account's CloudTrail logs or want to configure log management and data events (read-only, write-only, management events, data events) differently from the organization trail, they can create a local trail with the appropriate controls. Local account-specific trails incur [additional cost](#).

AWS Security Hub CSPM

[AWS Security Hub Cloud Security Posture Management](#) (AWS Security Hub CSPM), previously known as AWS Security Hub, provides you with a comprehensive view of your security posture in AWS and helps you check your environment against security industry standards and best practices. Security Hub CSPM collects security data from across AWS integrated services, supported third-party products, and other custom security products that you might use. It helps you continuously monitor and analyze your security trends and identify the highest priority security issues. In addition to the ingested sources, Security Hub CSPM generates its own findings, which are represented by security controls that map to one or more security standards. These standards include AWS Foundational Security Best Practices (FSBP), Center for Internet Security (CIS) AWS Foundations Benchmark (versions 5.0.0, 3.0.0, and 1.2.0), National Institute of Standards and Technology (NIST) SP 800-53 Rev. 5, Payment Card Industry Data Security Standard (PCI DSS), and [service-managed standards](#). For a list of current security standards and details on specific security controls, see the [Standards reference for Security Hub CSPM](#) in the Security Hub CSPM documentation.

Security Hub CSPM integrates with AWS Organizations to simplify security posture management across all your existing and future accounts in your AWS organization. You can use the Security Hub CSPM [central configuration feature](#) from the delegated administrator account (in this case, Security Tooling) to specify how the Security Hub CSPM service, security standards, and security controls are configured in your organization accounts and organizational units (OUs) across Regions. You can configure these settings in a few steps from one primary Region, which is referred to as the *home Region*. If you don't use central configuration, you must configure Security Hub CSPM separately in each account and Region. The delegated administrator can designate accounts and OUs as *self-managed*, where the member can configure settings separately in each Region, or as *centrally managed*, where the delegated administrator can configure the member account or OU across Regions. You can designate all accounts and OUs in your organization as centrally managed, all self-managed, or a combination of both. This simplifies the enforcement of a consistent configuration while providing the flexibility to modify it for each OU and account.

The Security Hub CSPM delegated administrator account can also view findings, view insights, and control details from all member accounts. You can additionally designate an aggregation Region within the delegated administrator account to centralize your findings across your accounts and your linked Regions. Your findings are continuously and bidirectionally synced between the aggregator Region and all other Regions.

Security Hub CSPM supports integrations with several AWS services. Amazon GuardDuty, AWS Config, Amazon Macie, IAM Access Analyzer, AWS Firewall Manager, Amazon Inspector, Amazon Route 53 Resolver DNS Firewall, and AWS Systems Manager Patch Manager can feed findings to Security Hub CSPM. Security Hub CSPM processes findings by using a standard format called the [AWS Security Finding Format \(ASFF\)](#). Security Hub CSPM correlates the findings across integrated products to prioritize the most important ones. You can enrich the metadata of Security Hub CSPM findings to help better contextualize, prioritize, and take action on the security findings. This enrichment adds resource tags, a new AWS application tag, and account name information to every finding that's ingested into Security Hub CSPM. This helps you fine-tune findings for automation rules, search or filter findings and insights, and assess security posture status by application. In addition, you can use [automation rules](#) to automatically update findings. As Security Hub CSPM ingests findings, it can apply a variety of rule actions, such as suppressing findings, changing their severity, and adding notes to findings. These rule actions take effect when findings match your specified criteria, such as the resource or account IDs the finding is associated with, or its title. You can use automation rules to update select finding fields in the ASFF. Rules apply to both new and updated findings.

During the investigation of a security event, you can navigate from Security Hub CSPM to Amazon Detective to investigate a GuardDuty finding. Security Hub CSPM recommends aligning the delegated administrator accounts for services such as Detective (where they exist) for smoother integration. For example, if you do not align administrator accounts between Detective and Security Hub CSPM, navigating from findings into Detective will not work. For a comprehensive list, see [Overview of AWS service integrations with Security Hub CSPM](#) in the Security Hub CSPM documentation.

You can use Security Hub CSPM with the [Network Access Analyzer](#) feature of Amazon VPC to help continuously monitor the compliance of your AWS network configuration. This will help you block unwanted network access and help prevent your critical resources from external access. For further architecture and implementation details, see the AWS blog post [Continuous verification of network compliance using Amazon VPC Network Access Analyzer and AWS Security Hub CSPM](#).

In addition to its monitoring features, Security Hub CSPM supports integration with Amazon EventBridge to automate the remediation of specific findings. You can define custom actions to take when a finding is received. For example, you can configure custom actions to send findings to a ticketing system or to an automated remediation system. For additional discussions and examples, see the AWS blog posts [Automated response and remediation with AWS Security Hub CSPM](#) and [How to deploy the AWS solution for Security Hub CSPM automated response and remediation](#).

Security Hub CSPM uses service-linked AWS Config Rules to perform most of its security checks for controls. To support these controls, [AWS Config must be enabled on all accounts](#)—including the administrator (or delegated administrator) account and member accounts—in each AWS Region where Security Hub CSPM is enabled.

Amazon CloudWatch supports ingesting AWS Security Hub CSPM findings. This helps you centrally analyze and monitor security findings directly in CloudWatch Logs. Security Hub CSPM findings are supported in ASFF and Open Cybersecurity Schema Framework (OCSF) format using CloudWatch Pipelines, providing standardized security data ingestion. You can use CloudWatch Logs Insights to query findings, create metric filters for monitoring, and you can use Amazon S3 Tables integration for advanced analytics. This helps security teams identify and respond to threats faster across your AWS environment. You should create an Amazon CloudWatch [telemetry enablement rule](#) to automatically send Security Hub findings to CloudWatch Logs for all production accounts, ensuring consistent visibility into security posture.

Design considerations:

- If a compliance standard, such as PCI-DSS, is already present in Security Hub CSPM, the fully managed Security Hub CSPM service is the easiest way to operationalize it. However, if you want to assemble your own compliance or security standard, which might include security, operational, or cost optimization checks, AWS Config conformance packs offer a simplified customization process. (For more information about AWS Config and conformance packs, see the [AWS Config](#) section.)
- Common use cases for Security Hub CSPM include the following:
 - As a dashboard that provides visibility for application owners into the security and compliance posture of their AWS resources
 - As a central view of security findings used by security operations, incident responders, and threat hunters to triage and take action on AWS security and compliance findings across AWS accounts and Regions
 - To aggregate and route security and compliance findings from across AWS accounts and Regions, to a centralized security information and event management (SIEM) or other security orchestration system

For additional guidance on these use cases, including how to set them up, see the blog post [Three recurring Security Hub CSPM usage patterns and how to deploy them](#).

Implementation example:

- The [AWS SRA code library](#) provides a sample implementation of [Security Hub CSPM](#). It includes automatic enablement of the service, delegated administration to a member account (Security Tooling), and configuration to enable Security Hub CSPM for all existing and future accounts in the AWS organization.

AWS Security Hub

[AWS Security Hub](#) is a unified cloud security solution that prioritizes your critical security threats and helps you respond at scale. Security Hub detects security issues in near real time by automatically correlating and enriching security signals from multiple sources, such as posture management (AWS Security Hub CSPM), vulnerability management (Amazon Inspector), sensitive data (Amazon Macie), and threat detection (Amazon GuardDuty). This enables security teams to prioritize active risks in their cloud environments through automated analyses and contextual insights. Security Hub provides a visual representation of the potential attack path that attackers can exploit to gain access to resources associated with an exposure finding. This transforms complex security signals into actionable insights, so you can make informed decisions about your security quickly.

Security Hub has been strategically redesigned to simplify the enablement of associated security service building blocks to arrive at a security outcome. By correlating security findings in a threat matrix across different security signals in near real time, you can prioritize the most critical risks first. The findings are correlated to detect exposure associated with AWS resources. Exposures represent broader weaknesses in security controls, misconfigurations, or other areas that could be exploited by active threats. For example, an exposure might be an EC2 instance that is reachable from the internet and has software vulnerabilities that have high likelihood of exploitation.

Security Hub and Security Hub CSPM are complementary services. [Security Hub CSPM](#) provides a comprehensive view of your security posture and helps you evaluate your cloud environment against security industry standards and best practices. Security Hub provides a unified experience that helps you prioritize and respond to critical security issues. Security Hub CSPM findings are routed to Security Hub automatically, where they're correlated with findings from other security services, such as Amazon Inspector, to generate exposures. This helps you identify the most critical risks in your environment.

Security Hub also provides a summary of resources in your AWS environment by type and associated findings. Resources are prioritized by exposures and attack sequences. When you choose a resource type, you can review all the resources associated with that resource type.

For the optimal experience, we [recommend](#) enabling Security Hub and Security Hub CSPM as well as enabling these other security services: [Amazon GuardDuty](#), [Amazon Inspector](#), and [Amazon Macie](#). You can gain visibility into whether these services and features are uniformly enabled across all your organization's member accounts by using Security Hub Coverage findings.

In the AWS SRA, the Security Tooling account acts as the delegated administrator for Security Hub, Security Hub CSPM, and other AWS security services. Within the Security Tooling account you can view all resources associated with member accounts. You can also view all the resources in your home AWS Region from linked AWS Regions.

Note

[Enabling Security Hub](#) requires three steps, including procedures that take into account whether you have previously enabled Security Hub CSPM. Security Hub is natively integrated with AWS Organizations, which simplifies the configuration and implementation process, and centralizes and aggregates all findings into a single location. In accordance with the AWS SRA best practice, use the [Security Tooling account](#) as the delegated administrator account to manage and configure Security Hub. Use Security Hub configuration settings to enable all Regions, OUs, and accounts automatically, including future Regions and accounts. You should also set up cross-Region aggregation to aggregate findings, resources, and trends from multiple AWS Regions into a single home Region. During configuration, you can also enable any native integrations such as Jira Cloud or ServiceNow.

Design considerations:

- Security Hub findings are formatted in the Open Cybersecurity Schema Framework (OCSF). Security Hub generates findings in OCSF and receives findings in OCSF from Security Hub CSPM and other AWS services. These OCSF findings can be sent over Amazon EventBridge for automations or stored in a central log aggregation account to perform security log analysis and retention.
- The AWS Org Management account cannot designate itself as the delegated administrator in Security Hub. This aligns with the AWS SRA best practice of designating the Security Tooling account as the delegated administrator. Also note:
 - The designated administrator account for Security Hub CSPM automatically becomes the designated administrator for Security Hub.

- Removing delegated administration through Security Hub also removes delegated administration for Security Hub CSPM. Likewise, removing delegated administration through Security Hub CSPM also removes it for Security Hub.
- Security Hub includes features that automatically modify and take action on findings based on your specifications, Security Hub supports the following types of automations:
 - Automation rules, which automatically update findings, suppress findings, and send findings to ticketing tools in near real time based on defined criteria.
 - Automated response and remediation, which create custom EventBridge rules that define automatic actions to take against specific findings and insights.
- Security Hub can configure Amazon Inspector across all member accounts and Regions through policies, and can configure GuardDuty and Security Hub CSPM through deployment. Policies generate AWS Organizations policies for accounts and Regions. Deployments are one-time actions that enable a security capability across selected accounts and Regions. Deployments do not apply to newly enabled accounts. As an alternative, you can auto-enable features for new member accounts in GuardDuty and Security Hub CSPM.

Amazon GuardDuty

[Amazon GuardDuty](#) is a threat detection service that continuously monitors for malicious activity and unauthorized behavior to protect your AWS accounts and workloads. You must always capture and store appropriate logs for monitoring and audit purposes, but GuardDuty pulls independent streams of data directly from AWS CloudTrail, Amazon VPC flow logs, and AWS DNS logs. You don't have to manage Amazon S3 bucket policies or modify the way you collect and store your logs. GuardDuty permissions are managed as service-linked roles that you can revoke at any time by disabling GuardDuty. This makes it easy to enable the service without complex configuration, and it eliminates the risk that an IAM permission modification or S3 bucket policy change will affect the operation of the service.

In addition to providing [foundational data sources](#), GuardDuty provides optional features to identify security findings. These include EKS Protection, RDS Protection, S3 Protection, Malware Protection, and Lambda Protection. For new detectors, you can configure [auto enable](#) for the entire AWS organization.

- With [GuardDuty S3 Protection](#), GuardDuty monitors Amazon S3 data events in CloudTrail in addition to the default CloudTrail management events. Monitoring data events enables

GuardDuty to monitor object-level API operations for potential security risks to data within your S3 buckets.

- [GuardDuty Malware Protection](#) detects the presence of malware on Amazon EC2 instances or container workloads by initiating agentless scans on attached Amazon Elastic Block Store (Amazon EBS) volumes. GuardDuty also detects potential malware in S3 buckets by scanning newly uploaded objects or new versions of existing objects.
- [GuardDuty RDS Protection](#) is designed to profile and monitor access activity to Amazon Aurora databases (Amazon Aurora MySQL-Compatible Edition and Aurora PostgreSQL-Compatible Edition) and [Amazon RDS for PostgreSQL](#) without impacting database performance.
- [GuardDuty EKS Protection](#) includes EKS Audit Log Monitoring and EKS Runtime Monitoring. With EKS Audit Log Monitoring, GuardDuty monitors [Kubernetes audit logs](#) from Amazon EKS clusters and analyzes them for potentially malicious and suspicious activity. EKS Runtime Monitoring uses the GuardDuty security agent (which is an Amazon EKS add-on) to provide runtime visibility into individual Amazon EKS workloads. The GuardDuty security agent helps identify specific containers within your Amazon EKS clusters that are potentially compromised. It can also detect attempts to escalate privileges from an individual container to the underlying Amazon EC2 host or to the broader AWS environment.

GuardDuty also provides a feature known as [Extended Threat Detection](#) that automatically detects multi-stage attacks that span data sources, multiple types of AWS resources, and time within an AWS account. GuardDuty correlates these events, which are called *signals*, to identify scenarios that present themselves as potential threats to your AWS environment, and then generates an attack sequence finding. This covers threat scenarios that involve compromise related to AWS credentials misuse, and data compromise attempts in your AWS accounts. GuardDuty considers all attack sequence finding types as **Critical**. This feature is enabled by default, and there is no additional cost associated with it.

In the AWS SRA, GuardDuty is enabled in all accounts through AWS Organizations, and all findings are viewable and actionable by appropriate security teams in the GuardDuty delegated administrator account (in this case, the Security Tooling account). GuardDuty active findings are exported to a central S3 bucket in the Log Archive account, so you can retain the findings beyond 90 days. The findings are exported from the delegated administrator account and also include all the findings from associated member accounts in the same Region. The findings in the bucket S3 are encrypted with an AWS KMS customer managed key. The S3 bucket policy and KMS key policy are configured to allow only GuardDuty to use the resources.

When AWS Security Hub CSPM is enabled, GuardDuty findings automatically flow to Security Hub CSPM and Security Hub. When Amazon Detective is enabled, GuardDuty findings are included in the Detective log ingest process. GuardDuty and Detective support cross-service user workflows, where GuardDuty provides links from the console that redirect you from a selected finding to a Detective page that contains a curated set of visualizations for investigating that finding. For example, you can also integrate GuardDuty with Amazon EventBridge to automate best practices for GuardDuty, such as [automating responses to new GuardDuty findings](#).

Implementation example:

- The [AWS SRA code library](#) provides a sample implementation of [GuardDuty](#). It includes encrypted S3 bucket configuration, delegated administration, and GuardDuty enablement for all existing and future accounts in the AWS organization.

AWS Config

[AWS Config](#) is a service that enables you to assess, audit, and evaluate the configurations of supported AWS resources in your AWS accounts. AWS Config continuously monitors and records AWS resource configurations, and automatically evaluates recorded configurations against desired configurations. You can also integrate AWS Config with other services to do the heavy lifting in automated audit and monitoring pipelines. For example, AWS Config can monitor for changes in individual secrets in AWS Secrets Manager.

You can evaluate the configuration settings of your AWS resources by using [AWS Config Rules](#). AWS Config provides a library of customizable, predefined rules called [managed rules](#), or you can write your own [custom rules](#). You can run AWS Config Rules in proactive mode (before resources have been deployed) or detective mode (after resources have been deployed). Resources can be evaluated when there are configuration changes, on a periodic schedule, or both.

A [conformance pack](#) is a collection of AWS Config rules and remediation actions that can be deployed as a single entity in an account and Region, or across an organization in AWS Organizations. Conformance packs are created by authoring a YAML template that contains the list of AWS Config managed or custom rules and remediation actions. To get started evaluating your AWS environment, use one of the [sample conformance pack templates](#).

AWS Config integrates with AWS Security Hub CSPM to send the results of AWS Config managed and custom rule evaluations as findings into Security Hub CSPM.

AWS Config Rules can be used in conjunction with AWS Systems Manager to effectively remediate noncompliant resources. You use Systems Manager Explorer to gather the compliance status of AWS Config rules in your AWS accounts across AWS Regions and then use [Systems Manager Automation documents \(runbooks\)](#) to resolve your noncompliant AWS Config rules. For implementation details, see the blog post [Remediate noncompliant AWS Config rules with AWS Systems Manager Automation runbooks](#).

The AWS Config aggregator collects configuration and compliance data across multiple accounts, Regions, and organizations in AWS Organizations. The aggregator dashboard displays the configuration data of aggregated resources. Inventory and compliance dashboards offer essential and current information about your AWS resource configurations and compliance status across AWS accounts, across AWS Regions, or within an AWS organization. They enable you to visualize and assess your AWS resource inventory without needing to write AWS Config advanced queries. You can get essential insights such as a summary of compliance by resources, the top 10 accounts that have noncompliant resources, a comparison of running and stopped EC2 instances by type, and EBS volumes by volume type and size.

If you use AWS Control Tower to manage your AWS organization, it will deploy [a set of AWS Config rules as detective guardrails](#) (categorized as mandatory, strongly recommended, or elective). These guardrails help you govern your resources and monitor compliance across accounts in your AWS organization. These AWS Config rules will automatically use an `aws-control-tower` tag that has a value of `managed-by-control-tower`.

AWS Config must be enabled for each member account in the AWS organization and AWS Region that contains the resources that you want to protect. You can centrally manage (for example, create, update, and delete) AWS Config rules across all accounts within your AWS organization. From the AWS Config delegated administrator account, you can deploy a common set of AWS Config rules across all accounts and specify accounts where AWS Config rules should not be created. The AWS Config delegated administrator account can also aggregate resource configuration and compliance data from all member accounts to provide a single view. Use the APIs from the delegated administrator account to enforce governance by ensuring that the underlying AWS Config rules cannot be modified by the member accounts in your AWS organization. AWS Config is natively integrated to send findings to AWS Security Hub CSPM, if Security Hub CSPM is enabled and at least one AWS Config managed or custom rule exists.

In the AWS SRA, the AWS Config delegated administrator account is the Security Tooling account. The AWS Config [delivery channel](#) is configured to deliver resource configuration snapshots in a

centralized S3 bucket in the Log Archive account. Because the Log Archive account is the central log repository store, it is used to store resource configuration.

Design considerations:

- AWS Config streams configuration and compliance change notifications to Amazon EventBridge. This means that you can use the native filtering capabilities in EventBridge to filter AWS Config events so that you can route specific types of notifications to specific targets. For example, you can send compliance notifications for specific rules or resource types to specific email addresses, or route configuration change notifications to an external IT service management (ITSM) or configuration management database (CMDB) tool. For more information, see the blog post [AWS Config best practices](#).
- In addition to using AWS Config proactive rule evaluation, you can use [AWS CloudFormation Guard](#), which is a policy-as-code evaluation tool that proactively checks for resource configuration compliance. The AWS CloudFormation Guard command line interface (CLI) provides you with a declarative, domain-specific language (DSL) that you can use to express policy as code. In addition, you can use AWS CLI commands to validate JSON-formatted or YAML-formatted structured data such as CloudFormation change sets, JSON-based Terraform configuration files, or Kubernetes configurations. You can run the evaluations locally by using the [AWS CloudFormation Guard CLI](#) as part of your authoring process or run it within your [deployment pipeline](#). If you have [AWS Cloud Development Kit \(AWS CDK\)](#) applications, you can use [cdk-nag](#) for proactive checking of best practices.

Implementation example:

- The [AWS SRA code library](#) provides a [sample implementation](#) that deploys AWS Config conformance packs to all AWS accounts and Regions within an AWS organization. The [AWS Config Aggregator](#) module helps you configure an AWS Config aggregator by delegating administration to a member account (Security Tooling) within the Org Management account and then configuring AWS Config Aggregator within the delegated administrator account for all existing and future accounts in the AWS organization. You can use the [AWS Config Control Tower Management Account](#) module to enable AWS Config within the Org Management account—it isn't enabled by AWS Control Tower.

Amazon Macie

[Amazon Macie](#) is a fully managed data security and data privacy service that uses machine learning and pattern matching to discover and help protect your sensitive data in AWS. You need to identify the type and classification of data your workload is processing to ensure that appropriate controls are enforced. You can use Macie to automate the discovery and reporting of sensitive data in two ways: by [performing automated sensitive data discovery](#) and by [creating and running sensitive data discovery jobs](#). With automated sensitive data discovery, Macie evaluates your S3 bucket inventory on a daily basis and uses sampling techniques to identify and select representative S3 objects from your buckets. Macie then retrieves and analyzes the selected objects, inspecting them for sensitive data. Sensitive data discovery jobs provide deeper and more targeted analysis. With this option, you define the breadth and depth of the analysis, including the S3 buckets to analyze, the sampling depth, and custom criteria that derive from the properties of S3 objects. If Macie detects a potential issue with the security or privacy of a bucket, it creates a [policy finding](#) for you. Automated data discovery is enabled by default for all new Macie customers, and existing Macie customers can enable it with one click.

Macie is enabled in all accounts through AWS Organizations. Principals who have the appropriate permissions in the delegated administrator account (in this case, the Security Tooling account) can enable or suspend Macie in any account, create sensitive data discovery jobs for buckets that are owned by member accounts, and view all policy findings for all member accounts. Sensitive data findings can be viewed only by the account that created the sensitive findings job. For more information, see [Managing multiple Macie accounts as an organization](#) in the Macie documentation.

Macie findings flow to AWS Security Hub CSPM for review and analysis. Macie also integrates with Amazon EventBridge to facilitate automated responses to findings such as alerts, feeds to security information and event management (SIEM) systems, and automated remediation.

Design considerations:

- If S3 objects are encrypted with an AWS Key Management Service (AWS KMS) key that you manage, you can add the Macie service-linked role as a key user to that KMS key to enable Macie to scan the data.
- Macie is optimized for scanning objects in Amazon S3. As a result, any Macie-supported object type that can be placed in Amazon S3 (permanently or temporarily) can be scanned for sensitive data. This means that data from other sources—for example, [periodic snapshot exports of Amazon Relational Database Service \(Amazon RDS\) or Amazon Aurora databases, exported](#)

[Amazon DynamoDB tables](#), or extracted text files from native or third-party applications—can be moved to Amazon S3 and evaluated by Macie.

Implementation example:

- The [AWS SRA code library](#) provides a sample implementation of [Amazon Macie](#). It includes delegating administration to a member account and configuring Macie within the delegated administrator account for all existing and future accounts in the AWS organization. Macie is also configured to send the findings to a central S3 bucket that is encrypted with a customer managed key in AWS KMS.

IAM Access Analyzer

As you accelerate your AWS Cloud adoption journey and continue to innovate, it's critical to maintain tight control over fine-grained access (permissions), contain access proliferation, and ensure that permissions are used effectively. Excessive and unused access presents security challenges and makes it harder for enterprises to enforce the [principle of least privilege](#). This principle is an important security architecture pillar that involves continually right-sizing IAM permissions to balance security requirements with operational and application development requirements. This effort involves multiple stakeholder personas, including central security and Cloud Center of Excellence (CCoE) teams as well as decentralized development teams.

[AWS Identity and Access Management Access Analyzer](#) provides tools to efficiently set fine-grained permissions, verify intended permissions, and refine permissions by removing unused access to help you meet your enterprise security standards. It gives you visibility into [external and internal access to AWS resources and unused access findings](#) through [dashboards](#) and AWS Security Hub CSPM. Additionally, it supports [Amazon EventBridge](#) for event-based custom notification and remediation workflows.

The IAM Access Analyzer external access analyzer findings feature helps you identify the resources in your AWS organization and accounts, such as [Amazon S3 buckets or IAM roles](#), that are shared with an external entity. The AWS organization or account you choose is known as the *zone of trust*. The analyzer uses [automated reasoning](#) to analyze all [supported resources](#) within the zone of trust, and generates findings for principals that can access the resources from outside the zone of trust. These findings help identify resources that are shared with an external entity and help you preview how your policy affects public and cross-account access to your resource before you deploy resource permissions. This is available at no additional cost.

Similarly, the IAM Access Analyzer internal access analyzer finding feature helps you identify the resources in your AWS organization and accounts that are shared with principals internally within your organization or account. This analysis supports the principle of least privilege by ensuring that your specified resources can be accessed only by the intended principals within your organization. This is a paid feature and requires explicit configuration of resources to inspect. Use this feature judiciously to monitor specific sensitive resources that, by design, need to be locked down even internally.

IAM Access Analyzer findings also help you identify unused access granted in your AWS organizations and accounts, including:

- **Unused IAM roles** – Roles that have no access activity within the specified usage window.
- **Unused IAM users, credentials, and access keys** – Credentials that belong to IAM users and are used to access AWS services and resources.
- **Unused IAM policies and permissions** – Service-level and action-level permissions that weren't used by a role within a specified usage window. IAM Access Analyzer uses identity-based policies that are attached to roles to determine the services and actions that those roles can access. The analyzer provides a review of unused permissions for all service-level permissions.

You can use the findings generated from IAM Access Analyzer to gain visibility into, and remediate, any unintended or unused access based on your organization's policies and security standards. After remediation, these findings are marked as [resolved](#) the next time the analyzer runs. If the finding is intentional, you can mark it as [archived](#) in IAM Access Analyzer and prioritize other findings that present a greater security risk. Additionally, you can set up [archive rules](#) to automatically archive specific findings. For example, you can create an archive rule to automatically archive any findings for a specific Amazon S3 bucket that you regularly grant access to.

As a builder, you can use IAM Access Analyzer to perform automated [IAM policy checks](#) earlier in your development and deployment (CI/CD) process to adhere to your corporate security standards. You can integrate IAM Access Analyzer custom policy checks and policy reviews with AWS CloudFormation to automate policy reviews as a part of your development team's CI/CD pipelines. This includes:

- **IAM policy validation** – IAM Access Analyzer validates your policies against [IAM policy grammar and AWS best practices](#). You can view findings for policy validation checks, including security warnings, errors, general warnings, and suggestions for your policy. Over 100 [policy](#)

[validation checks](#) are currently available and can be automated by using the AWS Command Line Interface (AWS CLI) and APIs.

- **IAM custom policy checks** – IAM Access Analyzer custom policy checks validate your policies against your specified security standards. Custom policy checks use automated reasoning to provide a higher level of assurance on meeting your corporate security standards. The types of custom policy checks include:
 - **Check against a reference policy:** When you edit a policy, you can compare it with a reference policy, such as an existing version of the policy, to check whether the update grants new access. The [CheckNoNewAccess](#) API compares two policies (an updated policy and a reference policy) to determine whether the updated policy introduces new access over the reference policy, and returns a pass or fail response.
 - **Check against a list of IAM actions:** You can use the [CheckAccessNotGranted](#) API to ensure that a policy doesn't grant access to a list of critical actions that are defined in your security standard. This API takes a policy and checks whether the policy allows at least one of the actions, and then it returns a pass or fail response.

Security teams and other IAM policy authors can use IAM Access Analyzer to author policies that comply with IAM policy grammar and security standards. Authoring right-sized policies manually can be error prone and time consuming. The IAM Access Analyzer [policy generation](#) feature assists in authoring IAM policies that are based on a principal's access activity. IAM Access Analyzer reviews AWS CloudTrail logs for [supported services](#) and generates a policy template that contains the permissions that were used by the principal in the specified date range. You can then use this template to create a policy with fine-grained permissions that grants only the necessary permissions.

- You must have a CloudTrail trail enabled for your account to generate a policy based on access activity.
- IAM Access Analyzer doesn't identify action-level activity for data events, such as Amazon S3 data events, in generated policies.
- The `iam:PassRole` action isn't tracked by CloudTrail and isn't included in generated policies.

IAM Access Analyzer is deployed in the Security Tooling account through the delegated administrator functionality in AWS Organizations. The delegated administrator has permissions to create and manage analyzers with the AWS organization as the zone of trust.

Design consideration:

- To get account-scoped findings (where the account serves as the trusted boundary), you create an account-scoped analyzer in each member account. This can be done as part of the account pipeline. Account-scoped findings flow into Security Hub CSPM at the member account level. From there, they flow to the Security Hub CSPM delegated administrator account (Security Tooling).

Implementation examples:

- The [AWS SRA code library](#) provides a sample implementation of [IAM Access Analyzer](#). It demonstrates how to configure an organization-level analyzer within a delegated administrator account and an account-level analyzer within each account.
- For information about how you can integrate custom policy checks into builder workflows, see the AWS blog post [Introducing IAM Access Analyzer custom policy checks](#).

Amazon CloudWatch

[Amazon CloudWatch](#) monitors your AWS resources and the applications you run on AWS in real time, and it offers tools to give you system-wide observability of your application performance, operational health, and resource utilization. [Some AWS services](#) automatically send basic metrics to CloudWatch at no charge. Additionally, CloudWatch provides additional monitoring capabilities for several key pieces of AWS infrastructure:

- [Database Insights](#) allows you to monitor database performance metrics in real time, analyze SQL query performance, and troubleshoot database load issues for AWS database services.
- [Lambda Insights](#) provides system-level metrics for AWS Lambda functions, including memory and CPU utilization tracking, and cold start detection and analysis.
- [Container Insights](#) allows you to collect and analyze metrics from containerized applications running on Amazon ECS clusters, Amazon EKS clusters, and self-managed Kubernetes clusters on Amazon EC2.

The AWS SRA recommends two options for centralized log collection and analytics across your AWS organization. [Amazon CloudWatch Unified Data Store](#) is the recommended primary option, deployed in Security Tooling account under the Security OU. Amazon Security Lake remains available as a secondary option for organizations with existing investments or specific subscriber-based access requirements.

The Security Tooling account serves as the centralized home for all observability, security, and compliance telemetry across your organization. Designate this account as the CloudWatch delegated administrator for the organization. This delegation grants the Monitoring account the ability to manage CloudWatch resources including Pipelines, centralization rules, cross-account observability links, and organization-wide metric and log collection—across all member accounts without requiring elevated permissions in the management account.

CloudWatch Unified Data Store provides unified data management and analytics capabilities that consolidate operational, security, and compliance data across your AWS environment and third-party sources into a single service. This eliminates the need for multiple separate data stores and complex ETL pipelines. Additionally, the data collected in CloudWatch can be made available as an Amazon S3 Table for cross-account fine-grained, column-level access control.

To protect the availability of the logs and the log management process, configure strict IAM policies and service control policies (SCPs) on the Monitoring account to provide only necessary permissions to manage CloudWatch. Use detective controls, such as those in AWS Config, to monitor, alert, and remediate this collection of permissions for unexpected changes.

The CloudWatch administrator can enable organization-wide log collection using centralization rules. [Pipelines](#) can be used to collect AWS vended logs (CloudTrail management events, CloudTrail data events for Amazon S3 and Lambda, Amazon VPC Flow Logs, AWS WAF logs, Amazon Route 53 resolver logs, and Amazon EKS audit logs) across all member accounts and AWS Regions. Pipelines can be configured to transform logs into a standardized open-source schema called *Open Cybersecurity Schema Framework (OCSF)* by using the built-in OCSF processor. With OCSF support, CloudWatch efficiently normalizes and consolidates security data from AWS and other enterprise security sources to create a unified and reliable repository of security-related information.

CloudWatch Pipelines also supports third-party connectors (such as CrowdStrike, SentinelOne, Okta, Entra ID, Wiz, Zscaler, Palo Alto Networks, ServiceNow CMDB) to ingest external security telemetry into the same unified data store.

AWS Security Hub CSPM findings can be ingested into CloudWatch through Pipelines, providing an overview of your compliance posture and whether you're following security recommendations for AWS and AWS Partner solutions.

To gain visibility and actionable insights from logs and events, you can query the data by using CloudWatch Logs Insights (with [Facets](#)-based exploration, natural language queries, and Log Insights SQL/OpenSearch PPL/OpenSearch SQL support), Amazon Athena, Amazon OpenSearch Service, Amazon Redshift, Amazon SageMaker AI, Amazon Quick, and third-party solutions. Users

who require access to the log data shouldn't access the Monitoring account directly. They should access data from the Security Tooling account by using cross-account IAM roles scoped to read-only CloudWatch Logs Insights queries or by querying Amazon S3 Tables (Apache Iceberg format) in the Log Archive account through AWS Lake Formation cross-account grants. This enables fine-grained, column-level access control through Athena, OpenSearch Service, Quick, or third-party SIEM tools. Other AWS accounts and on-premises locations access data through the same Lake Formation governed Amazon S3 Tables or through analytics tools that consume from the Log Archive account.

For long-term immutable storage, configure CloudWatch to send log data to S3 buckets in the Log Archive account. Amazon S3 Object Lock and Glacier policies ensure immutability for regulatory compliance. The Log Archive account serves as a storage sink only and does not run CloudWatch analytics workloads.

As a best practice, we recommend that you restrict the configuration of CloudWatch through development pipelines and prevent configuration changes through the AWS Management Console or the AWS Command Line Interface (AWS CLI). You can configure notifications to detect any unauthorized access to log groups or S3 buckets.

Amazon Security Lake

[Amazon Security Lake](#) is a fully managed security data lake service. You can use Security Lake to automatically centralize security data from AWS environments, software as a service (SaaS) providers, on premises, and [third-party sources](#). Security Lake helps you build a normalized data source that simplifies the usage of analytics tools over security data, so you can get a more complete understanding of your security posture across the entire organization. The data lake is backed by Amazon Simple Storage Service (Amazon S3) buckets, and you retain ownership over your data. Security Lake automatically collects logs for AWS services, including AWS CloudTrail, Amazon VPC, Amazon Route 53, Amazon S3, AWS Lambda, Amazon EKS audit logs, AWS Security Hub CSPM findings, and AWS WAF logs.

AWS SRA recommends that you use the Log Archive account as the delegated administrator account for Security Lake. For more information about setting up the delegated administrator account, see [Amazon Security Lake](#) in the *Security OU – Log Archive account* section. Security teams that want to access Security Lake data or need the ability to write non-native logs to the Security Lake buckets by using custom extract, transform, and load (ETL) functions should operate within the Security Tooling account.

Security Lake can collect logs from different cloud providers, logs from third-party solutions, or other custom logs. We recommend that you use the Security Tooling account to perform the ETL functions to convert the logs to Open Cybersecurity Schema Framework (OCSF) format and output a file in Apache Parquet format. Security Lake creates the cross-account role with the proper permissions for the Security Tooling account and the custom source backed by Lambda functions or AWS Glue crawlers, to write data to the S3 buckets for Security Lake.

The Security Lake administrator should configure security teams that use the Security Tooling account and require access to the logs that Security Lake collects as [subscribers](#). Security Lake supports two types of subscriber access:

- **Data access** – Subscribers can directly access the Amazon S3 objects for Security Lake. Security Lake manages the infrastructure and permissions. When you configure the Security Tooling account as a Security Lake data access subscriber, the account is notified of new objects in the Security Lake buckets through Amazon Simple Queue Service (Amazon SQS), and Security Lake creates the permissions to access those new objects.
- **Query access** – Subscribers can query source data from AWS Lake Formation tables in your S3 bucket by using services such as Amazon Athena. Cross-account access is automatically set up for query access by using Lake Formation. When you configure the Security Tooling account as a Security Lake query access subscriber, the account is given read-only access to the logs in the Security Lake account. When you use this subscriber type, the Athena and AWS Glue tables are shared from the Security Lake Log Archive account with the Security Tooling account through AWS Resource Access Manager (AWS RAM). To enable this capability, you have to update the cross-account data sharing settings to version 3.

For more information about creating subscribers, see [Subscriber management](#) in the Security Lake documentation.

For best practices for ingesting custom sources, see [Collecting data from custom sources](#) in the Security Lake documentation.

You can use [Amazon QuickSight](#), [Amazon OpenSearch Service](#), and [Amazon SageMaker](#) to set up analytics against the security data that you store in Security Lake.

Design consideration:

- If an application team needs query access to Security Lake data to meet a business requirement, the Security Lake administrator should configure that Application account as a subscriber.

AWS Firewall Manager

[AWS Firewall Manager](#) helps protect your network by simplifying your administration and maintenance tasks for AWS WAF, AWS Shield Advanced, Amazon VPC security groups, AWS Network Firewall, and Amazon Route 53 Resolver DNS Firewall across multiple accounts and resources. With Firewall Manager, you set up your AWS WAF firewall rules, Shield Advanced protections, Amazon VPC security groups, Network Firewall firewalls, and DNS Firewall rule group associations only once. The service automatically applies the rules and protections across your accounts and resources, even as you add new resources.

Firewall Manager is particularly useful when you want to protect your entire AWS organization instead of a small number of specific accounts and resources, or if you frequently add new resources that you want to protect. Firewall Manager uses security policies to let you define a set of configurations, including relevant rules, protections, and actions that must be deployed and the accounts and resources (indicated by tags) to include or exclude. You can create granular and flexible configurations while still being able to scale control out to large numbers of accounts and VPCs. These policies automatically and consistently enforce the rules you configure even when new accounts and resources are created. Firewall Manager is enabled in all accounts through AWS Organizations, and configuration and management are performed by the appropriate security teams in the Firewall Manager delegated administrator account (in this case, the Security Tooling account).

You must enable AWS Config for each AWS Region that contains the resources that you want to protect. If you don't want to enable AWS Config for all resources, you must enable it for resources that are associated with [the type of Firewall Manager policies that you use](#). When you use both AWS Security Hub CSPM and Firewall Manager, Firewall Manager automatically sends your findings to Security Hub CSPM. Firewall Manager creates findings for resources that are out of compliance and for attacks that it detects, and sends the findings to Security Hub CSPM. When you set up a Firewall Manager policy for AWS WAF, you can centrally enable logging on web access control lists (web ACLs) for all in-scope accounts and centralize the logs under a single account.

With Firewall Manager you can have one or multiple administrators who can manage the firewall resources of your organization. When you assign multiple administrators, you can apply restrictive administrative scope conditions to define the resources (accounts, OUs, Regions, policy types) that each administrator can manage. This gives you the flexibility to have different administrator roles within your organization, and helps you maintain the principal of least privileged access. The AWS SRA uses one administrator with full administrative scope delegated to the Security Tooling account.

Design consideration:

- Account managers of individual member accounts in the AWS organization can configure additional controls (such as AWS WAF rules and Amazon VPC security groups) in the Firewall Manager managed services according to their particular needs.

Implementation example:

- The [AWS SRA code library](#) provides a sample implementation of [Firewall Manager](#). It demonstrates delegated administration (Security Tooling), deploys a maximum allowed security group, configures a security group policy, and configures multiple AWS WAF policies.

Amazon EventBridge

[Amazon EventBridge](#) is a serverless event bus service that makes it straightforward to connect your applications with data from a variety of sources. It is frequently used in security automation. You can set up routing rules to determine where to send your data to build application architectures that react in real time to all your data sources. You can create a custom event bus to receive events from your custom applications, in addition to using the default event bus in each account. You can create an event bus in the Security Tooling account that can receive security-specific events from other accounts in the AWS organization. For example, by linking AWS Config Rules, Amazon GuardDuty, and AWS Security Hub CSPM with EventBridge, you create a flexible, automated pipeline for routing security data, raising alerts, and managing actions to resolve issues.

Design considerations:

- EventBridge is capable of routing events to a number of different targets. One valuable pattern for automating security actions is to connect particular events to individual AWS Lambda responders, which take appropriate actions. For example, in certain circumstances you might want to use EventBridge to route a public S3 bucket finding to a Lambda responder that corrects the bucket policy and removes the public permissions. These responders can be integrated into your investigative playbooks and runbooks to coordinate response activities.
- A best practice for a successful security operations team is to integrate the flow of security events and findings into a notification and workflow system such as a ticketing system, a bug/issue system, or another security information and event management (SIEM) system. This takes the workflow out of email and static reports, and helps you route, escalate, and manage

events or findings. The flexible routing abilities in EventBridge are a powerful enabler for this integration.

Amazon Detective

[Amazon Detective](#) supports your responsive security control strategy by making it straightforward to analyze, investigate, and quickly identify the root cause of security findings or suspicious activities for your security analysts. Detective automatically extracts time-based events such as login attempts, API calls, and network traffic from AWS CloudTrail logs and Amazon VPC flow logs. Detective consumes these events by using independent streams of CloudTrail logs and Amazon VPC flow logs. You can use Detective to access up to a year of historical event data. Detective uses machine learning and visualization to create a unified, interactive view of the behavior of your resources and the interactions among them over time—this is called a *behavior graph*. You can explore the behavior graph to examine disparate actions such as failed logon attempts or suspicious API calls.

Detective integrates with Amazon Security Lake to enable security analysts to query and retrieve logs that are stored in Security Lake. You can use this integration to get additional information from CloudTrail logs and Amazon VPC flow logs that are stored in Security Lake while conducting security investigations in Detective.

Detective also ingests findings that are detected by Amazon GuardDuty, including threats that are detected by [GuardDuty Runtime Monitoring](#). When an account enables Detective, it becomes the administrator account for the behavior graph.

Additional optional data sources for Detective include [Amazon EKS audit logs](#) and AWS Security Hub CSPM. The Amazon EKS audit log data source enhances the information provided about the following entity types: Amazon EKS clusters, Kubernetes pods, container images, and Kubernetes subjects. The Security Hub CSPM data source is part of [AWS security findings](#), where it correlates findings across products into Security Hub CSPM and ingests them into Detective.

Detective automatically groups multiple findings that are related to a single security compromise event into [finding groups](#). Threat actors typically perform a sequence of actions that lead to multiple security findings spread across time and resources. Therefore, finding groups should be the starting point for investigations that involve multiple entities and findings. Detective also provides finding group summaries by using generative AI that automatically analyzes finding groups and provides insights in natural language to help you accelerate security investigations.

Detective integrates with AWS Organizations. The Org Management account delegates a member account as the Detective administrator account. In the AWS SRA, this is the Security Tooling account. The Detective administrator account has the ability to automatically enable all current member accounts in the organization as Detective member accounts, and also add new member accounts as they get added to the AWS organization. Detective administrator accounts also have the ability to invite member accounts that currently do not reside in the AWS organization, but are within the same Region, to contribute their data to the primary account's behavior graph. When a member account accepts the invitation and is enabled, Detective begins to ingest and extract the member account's data into that behavior graph.

Design consideration:

- You can navigate to Detective finding profiles from the GuardDuty and AWS Security Hub CSPM consoles. These links can help streamline the investigation process. Your account must be the administrative account for both Detective and the service you are pivoting from (GuardDuty or Security Hub CSPM). If the primary accounts are the same for the services, the integration links work seamlessly.

AWS Audit Manager

Note

AWS Audit Manager is no longer open to new customers. Existing customers can continue to use the service as normal. For more information, see [AWS Audit Manager availability change](#).

[AWS Audit Manager](#) helps you continually audit your AWS usage to simplify how you manage audits and compliance with regulations and industry standards. It enables you to move from manually collecting, reviewing, and managing evidence to a solution that automates evidence collection, provides a simple way to track the source of audit evidence, enables teamwork collaboration, and helps to manage evidence security and integrity. When it's time for an audit, Audit Manager helps you manage stakeholder reviews of your controls.

With Audit Manager you can audit against [prebuilt frameworks](#) such as the Center for Internet Security (CIS) benchmark, the CIS AWS Foundations Benchmark, System and Organization Controls 2 (SOC 2), and the Payment Card Industry Data Security Standard (PCI DSS). It also gives you the

ability to create your own frameworks with standard or custom controls based on your specific requirements for internal audits.

Audit Manager collects four types of evidence. Three types of evidence are automated: compliance check evidence from AWS Config and AWS Security Hub CSPM, management events evidence from AWS CloudTrail, and configuration evidence from AWS service-to-service API calls. For evidence that cannot be automated, Audit Manager lets you upload manual evidence.

By default, your data in Audit Manager is encrypted by using AWS managed keys. The AWS SRA uses a customer managed key for encryption to provide greater control over logical access. You should also configure an S3 bucket in the AWS Region where Audit Manager publishes the assessment report. This buckets should be encrypted with a customer managed key and have a bucket policy that's configured to allow only Audit Manager to publish reports.

Note

Audit Manager assists in collecting evidence that's relevant for verifying compliance with specific compliance standards and regulations. However, it doesn't assess your compliance. Therefore, the evidence that's collected through Audit Manager might not include details of your operational processes that are needed for audits. Audit Manager isn't a substitute for legal counsel or compliance experts. We recommend that you engage the services of a third-party assessor who is certified for the compliance framework(s) that you are evaluated against.

Audit Manager assessments can run over multiple accounts in your AWS organizations. Audit Manager collects and consolidates evidence into a delegated administrator account in AWS Organizations. This audit functionality is primarily used by compliance and internal audit teams, and requires only read access to your AWS accounts.

Design considerations:

- Audit Manager complements other AWS security services such as Security Hub CSPM, Security Hub, and AWS Config to help implement a risk management framework. Audit Manager provides independent risk assurance functionality, whereas Security Hub CSPM helps you oversee your risk and AWS Config conformance packs assist in managing your risks. Audit professionals who are familiar with the [Three Lines Model](#) developed by the [Institute of Internal Auditors \(IIA\)](#) should note that this combination of AWS services helps you cover the three lines of defense. For more information, see the two part [blog series](#) on the AWS Cloud Operations & Migrations blog.

- In order for Audit Manager to collect Security Hub CSPM evidence, the delegated administrator account for both services has to be the same AWS account. For this reason, in the AWS SRA, the Security Tooling account is the delegated administrator for Audit Manager.

AWS Artifact

[AWS Artifact](#) is hosted within the Security Tooling account to separate the compliance artifact management functionality from the AWS Org Management account. This separation of duty is important because we recommend that you avoid using the AWS Org Management account for deployments unless absolutely necessary. Instead, pass on deployments to member accounts. Because audit artifact management can be done from a member account and the function closely aligns with the security and compliance team, the Security Tooling account is designated as the administrator account for AWS Artifact. You can use AWS Artifact reports to download AWS security and compliance documents, such as AWS ISO certifications, Payment Card Industry (PCI), and System and Organization Controls (SOC) reports.

AWS Artifact doesn't support the delegated administration feature. Instead, you can restrict this capability to only IAM roles in the Security Tooling account that pertain to your audit and compliance teams, so they can download, review, and provide those reports to external auditors as needed. You can additionally restrict specific IAM roles to have access to only specific AWS Artifact reports through IAM policies. For sample IAM policies, see the [AWS Artifact documentation](#).

Design consideration:

- If you choose to have a dedicated AWS account for audit and compliance teams, you can host AWS Artifact in a security audit account, which is separate from the Security Tooling account. AWS Artifact reports provide evidence that demonstrates that an organization is following a documented process or meeting a specific requirement. Audit artifacts are gathered and archived throughout the system development lifecycle and can be used as evidence in internal or external audits and assessments.

AWS KMS

[AWS Key Management Service](#) (AWS KMS) helps you create and manage cryptographic keys and control their use across a wide range of AWS services and in your applications. AWS KMS is a secure and resilient service that uses hardware security modules to protect cryptographic keys. It follows industry standard lifecycle processes for key material, such as storage, rotation, and access control

of keys. AWS KMS can help protect your data with encryption and signing keys, and can be used for both server-side encryption and client-side encryption through the [AWS Encryption SDK](#). For protection and flexibility, AWS KMS supports three types of keys: customer managed keys, AWS managed keys, and AWS owned keys. Customer managed keys are AWS KMS keys in your AWS account that you create, own, and manage. AWS managed keys are AWS KMS keys in your account that are created, managed, and used on your behalf by an AWS service that is integrated with AWS KMS. AWS owned keys are a collection of AWS KMS keys that an AWS service owns and manages for use in multiple AWS accounts. For more information about using AWS KMS keys, see the [AWS KMS documentation](#) and [AWS KMS cryptographic details](#).

One deployment option is to centralize the responsibility of AWS KMS key management to a single account while delegating the ability to use keys in the Application account by application resources by using a combination of key and IAM policies. This approach is secure and straightforward to manage, but you can encounter hurdles due to AWS KMS throttling limits, account service limits, and the security team being inundated with operational key management tasks. Another deployment option is to have a decentralized model in which you allow AWS KMS to reside in multiple accounts, and you allow those responsible for the infrastructure and workloads in a specific account to manage their own keys. This model gives your workload teams more control, flexibility, and agility over the use of encryption keys. It also helps avoid API limits, limits the scope of impact to one AWS account only, and simplifies reporting, auditing, and other compliance-related tasks. In a decentralized model it is important to deploy and enforce guardrails so that the decentralized keys are managed in the same way and usage of AWS KMS keys is audited according to established best practices and policies. For more information, see the whitepaper [AWS Key Management Service Best Practices](#). AWS SRA recommends a distributed key management model in which the AWS KMS keys reside locally within the account where they are used. We recommend that you avoid using a single key in one account for all cryptographic functions. Keys can be created based on function and data protection requirements, and to enforce the principle of least privilege. In some cases, encryption permissions would be kept separate from decryption permissions, and administrators would manage lifecycle functions but would not be able to encrypt or decrypt data with the keys that they manage.

In the Security Tooling account, AWS KMS is used to manage the encryption of centralized security services such as the AWS CloudTrail organization trail that is managed by the AWS organization.

AWS Private CA

[AWS Private Certificate Authority](#) (AWS Private CA) is a managed private CA service that helps you securely manage the lifecycle of your private end-entity TLS certificates for EC2 instances,

containers, IoT devices, and on-premises resources. It allows encrypted TLS communications to running applications. With AWS Private CA, you can create your own CA hierarchy (a root CA, through subordinate CAs, to end-entity certificates) and issue certificates with it to authenticate internal users, computers, applications, services, servers, and other devices, and to sign computer code. Certificates issued by a private CA are trusted only within your AWS organization, not on the internet.

A public key infrastructure (PKI) or security team can be responsible for managing all PKI infrastructure. This includes the management and creation of the private CA. However, there must be a provision that allows workload teams to self-serve their certificate requirements. The AWS SRA depicts a centralized CA hierarchy in which the root CA is hosted within the Security Tooling account. This enables security teams to enforce stringent security control, because the root CA is the foundation of the entire PKI. However, creation of private certificates from the private CA is delegated to application development teams by sharing out the CA to an Application account by using AWS Resource Access Manager (AWS RAM). AWS RAM manages the permissions required for cross-account sharing. This removes the need for a private CA in every account and provides a more cost-effective way of deployment. For more information about the workflow and implementation, see the blog post [How to use AWS RAM to share your AWS Private CA cross-account](#).

Note

AWS Certificate Manager (ACM) also helps you provision, manage, and deploy public TLS certificates for use with AWS services. To support this functionality, ACM has to reside in the AWS account that would use the public certificate. This is discussed later in this guide, in the [Application account](#) section.

Design considerations:

- With AWS Private CA, you can create a hierarchy of certificate authorities with up to five levels. You can also create multiple hierarchies, each with its own root. The AWS Private CA hierarchy should adhere to your organization's PKI design. However, keep in mind that increasing the CA hierarchy increases the number of certificates in the certification path, which, in turn, increases the validation time of an end-entity certificate. A well-defined CA hierarchy provides benefits that include granular security control appropriate to each CA, delegation of subordinate CA to a different application, which leads to division of administrative tasks, use of CA with limited revocable trust, the ability to define different validity periods, and the ability to enforce path limits. Ideally, your root and subordinate CAs are in separate AWS accounts. For more

information about planning a CA hierarchy by using AWS Private CA, see the [AWS Private CA documentation](#) and the blog post [How to secure an enterprise scale AWS Private CA hierarchy for automotive and manufacturing](#).

- AWS Private CA can integrate with your existing CA hierarchy, which allows you to use the automation and native AWS integration capability of ACM in conjunction with the existing root of trust that you use today. You can create a subordinate CA in AWS Private CA backed by a parent CA on premises. For more information about implementation, see [Installing a subordinate CA certificate signed by an external parent CA](#) in the AWS Private CA documentation.

Amazon Inspector

[Amazon Inspector](#) is an automated vulnerability management service that automatically discovers and scans Amazon EC2 instances, container images in Amazon Elastic Container Registry (Amazon ECR), AWS Lambda functions, and code repositories within your source code managers for known software vulnerabilities and unintended network exposure.

Amazon Inspector continuously assesses your environment throughout the lifecycle of your resources by automatically scanning resources whenever you make changes to them. Events that initiate rescanning a resource include installing a new package on an EC2 instance, installing a patch, and the publication of a new common vulnerabilities and exposures (CVE) report that affects the resource. Amazon Inspector supports Center of Internet Security (CIS) Benchmark assessments for operating systems in EC2 instances.

Amazon Inspector integrates with developer tools such as Jenkins and TeamCity for container image assessments. You can assess your container images for software vulnerabilities within your continuous integration and continuous delivery (CI/CD) tools, and push security to an earlier point in the software development lifecycle. Assessment findings are available in the CI/CD tool's dashboard, so you can perform automated actions in response to critical security issues such as blocked builds or image pushes to container registries. If you have an active AWS account, you can install the Amazon Inspector plugin from your CI/CD tool marketplace and add an Amazon Inspector scan in your build pipeline without needing to activate the Amazon Inspector service. This feature works with CI/CD tools hosted anywhere—on AWS, on premises, or in hybrid clouds—so you can consistently use a single solution across all your development pipelines. When Amazon Inspector is activated, it automatically discovers all your EC2 instances, container images in Amazon ECR and CI/CD tools, and Lambda functions at scale, and continuously monitors them for known vulnerabilities.

The network reachability findings of Amazon Inspector assess the accessibility of your EC2 instances to or from VPC edges such as internet gateways, VPC peering connections, or virtual private networks (VPNs) through a virtual gateway. These rules help automate the monitoring of your AWS networks and identify where network access to your EC2 instances might be misconfigured through mismanaged security groups, access control lists (ACLs), internet gateways, and so on. For more information, see the [Amazon Inspector documentation](#).

When Amazon Inspector identifies vulnerabilities or open network paths, it produces a finding that you can investigate. The finding includes comprehensive details about the vulnerability, including a risk score, the affected resource, and remediation recommendations. The risk score is specifically tailored to your environment and is calculated by correlating up-to-date CVE information with temporal and environmental factors such as network accessibility and exploitability information to provide a contextual finding.

[Amazon Inspector Code Security](#) scans first-party application source code, third-party application dependencies, and infrastructure as code (IaC) for vulnerabilities. After you activate Code Security, you can create and apply a scan configuration to your code repository to determine frequency, scan type, and repositories to be scanned. Code Security supports static application security testing (SAST), software composition analysis (SCA), and IaC scanning. To configure frequency, you can define scans on demand, at code changes, or periodically. Code scanning captures snippets of code to highlight detected vulnerabilities. The code snippets are stored encrypted with KMS keys. The delegated administrator for an organization cannot view code snippets that belong to member accounts. After you [integrate](#) your source code managers (SCMs) with Code Security, all code repositories are listed as projects in the Amazon Inspector console. Code Security monitors only the default branch of each repository. Amazon Inspector streamlines security remediation by providing specific code fix recommendations directly where developers work. The two-way integration with your SCM automatically suggests fixes as comments within pull requests (PRs) and merge requests (MRs) for critical and high findings, and alerts developers to the most important vulnerabilities to address without disrupting their workflow.

In order to scan for vulnerabilities, EC2 instances must be [managed](#) in AWS Systems Manager by using AWS Systems Manager Agent (SSMAgent). No agents are required for network reachability of EC2 instances or vulnerability scanning of container images in Amazon ECR or Lambda functions.

Amazon Inspector is integrated with AWS Organizations and supports delegated administration. In the AWS SRA, the Security Tooling account is made the delegated administrator account for Amazon Inspector. The Amazon Inspector delegated administrator account can manage findings

data and certain settings for members of the AWS organization. This includes viewing the details of aggregated findings for all member accounts, enabling or disabling scans for member accounts, and reviewing scanned resources within the AWS organization.

Design considerations:

- Amazon Inspector integrates with AWS Security Hub CSPM and Security Hub automatically when both services are enabled. You can use this integration to send all findings from Amazon Inspector to Security Hub CSPM, which will then include those findings in its analysis of your security posture.
- Amazon Inspector automatically exports events for findings, resource coverage changes, and initial scans of individual resources to Amazon EventBridge, and, optionally, to an Amazon Simple Storage Service (Amazon S3) bucket. To export active findings to an S3 bucket, you need an AWS KMS key that Amazon Inspector can use to encrypt findings, and an S3 bucket with permissions that allow Amazon Inspector to upload objects. EventBridge integration enables you to monitor and process findings in near real time as part of your existing security and compliance workflows. EventBridge events are published to the Amazon Inspector delegated administrator account in addition to the member account from which they originated.
- Amazon Inspector Code Security integrations with GitHub SaaS, GitHub Enterprise Cloud, and GitHub Enterprise Server require public internet access.

Implementation example:

- The [AWS SRA code library](#) provides a sample implementation of [Amazon Inspector](#). It demonstrates delegated administration (Security Tooling) and configures Amazon Inspector for all existing and future accounts in the AWS organization.

AWS Security Incident Response

[AWS Security Incident Response](#) is a service that helps you prepare for, and respond to, security incidents in your AWS environment. It triages findings, escalates security events, and manages cases that require your immediate attention. Additionally, it gives you access to the AWS Customer Incident Response Team (CIRT), which investigates impacted resources. AWS Security Incident Response also provides automated response and remediation capabilities through AWS Systems Manager documents (SSM documents), which help security teams respond to, and recover from, security incidents more efficiently. AWS Security Incident Response [integrates with Amazon](#)

[GuardDuty and AWS Security Hub CSPM](#) to receive security findings and orchestrate automated responses.

AWS Security Incident Response provides an [AI-powered investigative agent](#) that automates evidence gathering and analysis for AWS supported cases. When a security event case is created, the investigative agent activates in parallel with Security Incident Response engineers, automatically collecting relevant information from CloudTrail, IAM, Amazon EC2, and AWS Cost Explorer. The agent correlates this data to generate comprehensive investigation summaries typically within minutes.

In the AWS SRA, AWS Security Incident Response is deployed in the Security Tooling account as a delegated administrator account. The Security Tooling account is selected because it aligns with the account's purpose of operating security services and automating security alerting and responses. The Security Tooling account also acts as the delegated administrator account for Security Hub CSPM and GuardDuty, which, along with AWS Security Incident Response, help simplify workflow management. AWS Security Incident Response is configured to work with AWS Organizations, so you can manage incident responses across your organization's accounts from the Security Tooling account.

AWS Security Incident Response helps you implement the following phases of the incident response lifecycle:

- Preparation: Create and maintain response plans and SSM documents for containment actions.
- Detection and analysis: Automatically analyze security findings and determine incident severity.
- Detection and analysis: Open a service-supported case and engage with the AWS CIRT for additional assistance. CIRT is a group of individuals who provide support during active security events.
- Containment and eradication: Run automated containment actions through SSM documents.
- Post-incident activity: Document incident details and conduct post-incident analysis.

You can also use AWS Security Incident Response to create self-managed cases. AWS Security Incident Response can create an outbound notification or case when you need to be aware of, or act on, something that might impact your account or resources. This feature is available only when you enable the proactive response and alert triaging workflows as part of your subscription.

Design considerations:

- When you implement AWS Security Incident Response, carefully review and test automated response actions before you enable them in production. Automation can speed up incident response, but improperly configured automated actions could impact legitimate workloads.
- Consider using SSM documents in AWS Security Incident Response to implement organization-specific containment procedures while maintaining the service's built-in best practices for common incident types.
- If you plan to use AWS Security Incident Response in a VPC, make sure that you have the appropriate VPC endpoints configured for Systems Manager and other integrated services to enable containment actions in private subnets.

Deploying common security services within all AWS accounts

The [Apply security services across your AWS organization](#) section earlier in this reference highlighted security services that protect an AWS account, and noted that many of these services can also be configured and managed within AWS Organizations. Some of these services should be deployed in all accounts, and you will see them in the AWS SRA. This enables a consistent set of guardrails and provides centralized monitoring, management, and governance across your AWS organization.

Security Hub CSPM, GuardDuty, AWS Config, IAM Access Analyzer, and CloudTrail organization trails appear in all accounts. The first three support the delegated administrator feature discussed previously in the section [The management account, trusted access, and delegated administrators](#). CloudTrail currently uses a different aggregation mechanism.

The AWS SRA [GitHub code repository](#) provides a sample implementation of enabling Security Hub CSPM, GuardDuty, AWS Config, AWS Firewall Manager, and CloudTrail organization trails across all your accounts, including the AWS Org Management account.

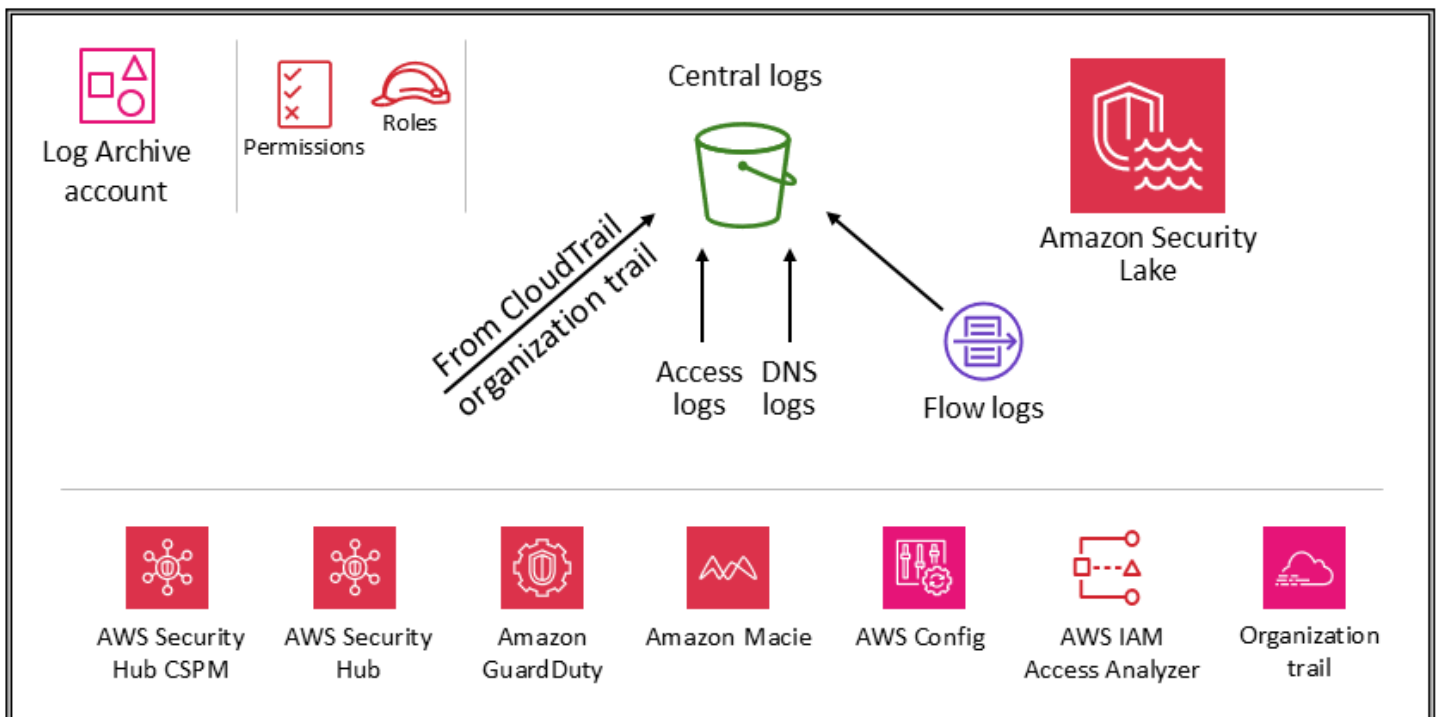
Design considerations:

- Specific account configurations might necessitate additional security services. For example, accounts that manage S3 buckets (the Application and Log Archive accounts) should also include Amazon Macie, and consider turning on CloudTrail S3 data event logging in these common security services. (Macie supports delegated administration with centralized configuration and monitoring.) Another example is Amazon Inspector, which is applicable only for accounts that host either EC2 instances or Amazon ECR images.

- In addition to the services described previously in this section, the AWS SRA includes two security-focused services, Amazon Detective and AWS Audit Manager, which support AWS Organizations integration and the delegated administrator functionality. However, those are not included as part of the recommended services for account baselining, because we have seen that these services are best used in the following scenarios:
 - You have a dedicated team or group of resources that perform these functions. Detective is best utilized by security analyst teams and Audit Manager is helpful to your internal audit or compliance teams.
 - You want to focus on a core set of tools such as GuardDuty and Security Hub CSPM at the start of your project, and then build on these by using services that provide additional capabilities.

Security OU – Log Archive account

The following diagram illustrates the AWS security services that are configured in the Log Archive account.



The Log Archive account is dedicated to ingesting and archiving all security-related logs and backups. With centralized logs in place, you can monitor, audit, and alert on Amazon S3 object access, unauthorized activity by identities, IAM policy changes, and other critical activities

performed on sensitive resources. The security objectives are straightforward: This should be immutable storage, accessed only by controlled, automated, and monitored mechanisms, and built for durability (for example, by using the appropriate replication and archival processes). Controls can be implemented at depth to protect the integrity and availability of the logs and log management process. In addition to preventive controls, such as assigning least privilege roles to be used for access and encrypting logs with a controlled AWS KMS key, use detective controls such as AWS Config to monitor (and alert and remediate) this collection of permissions for unexpected changes.

Design consideration:

- Operational log data used by your infrastructure, operations, and workload teams often overlaps with the log data used by security, audit, and compliance teams. We recommend that you consolidate your operational log data into the Log Archive account. Based on your specific security and governance requirements, you might need to filter operational log data saved to this account. You might also need to specify who has access to the operational log data in the Log Archive account.

Types of logs

The primary logs shown in the AWS SRA include AWS CloudTrail (organization trail), Amazon VPC flow logs, access logs from Amazon CloudFront and AWS WAF, and DNS logs from Amazon Route 53. These logs provide an audit of actions taken (or attempted) by a user, role, AWS service, or network entity (identified, for example, by an IP address). Other log types (for example, application logs or database logs) can be captured and archived as well. For more information about log sources and logging best practices, see the [security documentation for each service](#).

Amazon S3 as central log store

Many AWS services log information in Amazon S3—either by default or exclusively. AWS CloudTrail, Amazon VPC Flow Logs, Elastic Load Balancing, Amazon GuardDuty, AWS Config, and AWS WAF are some examples of services that log information in Amazon S3. This means that log integrity is achieved through S3 object integrity; log confidentiality is achieved through S3 object access controls; and log availability is achieved through S3 Object Lock, S3 object versions, and S3 Lifecycle rules. By logging information in a dedicated and centralized S3 bucket that resides in a dedicated account, you can manage these logs in just a few buckets and enforce strict security controls, access, and separation of duties.

In the AWS SRA, the primary logs stored in Amazon S3 come from CloudTrail, so this section describes how to protect those objects. This guidance also applies to any other S3 objects created either by your own applications or by other AWS services. Apply these patterns whenever you have data in Amazon S3 that needs high integrity, strong access control, and automated retention or destruction.

All new objects (including CloudTrail logs) that are uploaded to S3 buckets are [encrypted by default](#) by using Amazon server-side encryption with Amazon S3-managed encryption keys (SSE-S3). This helps protect the data at rest, but access control is controlled exclusively by IAM policies. To provide an additional managed security layer, you can use server-side encryption with AWS KMS keys that you manage (SSE-KMS) on all security S3 buckets. This adds a second level of access control. To read log files, a user must have both Amazon S3 read permissions for the S3 object and an IAM policy or role applied that allows them permissions to decrypt by the associated key policy.

Two options help you protect or verify the integrity of CloudTrail log objects that are stored in Amazon S3. CloudTrail provides [log file integrity validation](#) to determine whether a log file was modified or deleted after CloudTrail delivered it. The other option is [S3 Object Lock](#).

In addition to protecting the S3 bucket itself, you can adhere to the principle of least privilege for the logging services (for example, CloudTrail) and the Log Archive account. For example, users with permissions granted by the AWS managed IAM policy `AWSCloudTrail_FullAccess` can disable or reconfigure the most sensitive and important auditing functions in their AWS accounts. Limit the application of this IAM policy to as few individuals as possible.

Use detective controls, such as those delivered by AWS Config and IAM Access Analyzer, to monitor (and alert and remediate) this broader collective of preventive controls for unexpected changes.

For a deeper discussion of security best practices for S3 buckets, see the [Amazon S3 documentation](#), [online tech talks](#), and the blog post [Top 10 security best practices for securing data in Amazon S3](#).

Implementation example:

- The [AWS SRA code library](#) provides a sample implementation of [Amazon S3 block account public access](#). This module blocks Amazon S3 public access for all existing and future accounts in the AWS organization.

Amazon Security Lake

Organizations with existing [Amazon Security Lake](#) deployments or specific requirements for subscriber-based data access patterns, Security Lake remains a supported option.

The AWS SRA recommends that you use the Log Archive account as the delegated administrator account for Security Lake. When you do this, Security Lake collects supported logs in dedicated S3 buckets in the same account as other SRA-recommended security logs.

To protect the availability of the logs and the log management process, the S3 buckets for Security Lake should be accessed only by the Security Lake service or by IAM roles that are managed by Security Lake for sources or subscribers. In addition to using preventive controls—such as assigning least-privilege roles for access, and encrypting logs with a controlled AWS Key Management Service (AWS KMS) key—use detective controls such as AWS Config to monitor, alert, and remediate this collection of permissions for unexpected changes.

The Security Lake administrator can enable log collection across your AWS organization. These logs are stored in regional S3 buckets in the Log Archive account. Additionally, to centralize logs and facilitate easier storage and analysis, the Security Lake administrator can choose one or more rollup Regions where logs from all the regional S3 buckets are consolidated and stored. Logs from supported AWS services are automatically converted into OCSF and saved in Apache Parquet format in Security Lake S3 buckets. With OCSF support, Security Lake efficiently normalizes and consolidates security data from AWS and other enterprise security sources to create a unified and reliable repository of security-related information.

Security Lake can collect logs that are associated with AWS CloudTrail management events and CloudTrail data events for Amazon S3 and AWS Lambda. To collect CloudTrail management events in Security Lake, you must have at least one CloudTrail multi-Region organization trail that collects read and write CloudTrail management events. Logging must be enabled for the trail. A multi-Region trail delivers log files from multiple Regions to a single S3 bucket for a single AWS account. If the Regions are in different countries, consider data export requirements to determine whether multi-Region trails can be enabled.

AWS Security Hub CSPM is a supported native data source in Security Lake, and you should add Security Hub CSPM findings to Security Lake. Security Hub CSPM generates findings from many different AWS services and third-party integrations. These findings help you get an overview of your compliance posture and whether you're following security recommendations for AWS and AWS Partner solutions.

To gain visibility and actionable insights from logs and events, you can query the data by using tools such as Amazon Athena, Amazon OpenSearch Service, Amazon Quick, and third-party solutions. Users who require access to the Security Lake log data shouldn't access the Log Archive account directly. They should access data only from the Security Tooling account. Or they can use other AWS accounts or on-premises locations that provide analytics tools such as OpenSearch Service, Quick, or third-party tools such as security information and event management (SIEM) tools. To provide access to the data, the administrator should configure Security Lake subscribers in the Log Archive account and configure the account that needs access to the data as a query access subscriber. For more information, see [Amazon Security Lake](#) in the *Security OU – Security Tooling* account section of this guide.

Security Lake provides an AWS managed policy to help you manage administrator access to the service. As a best practice, we recommend that you restrict the configuration of Security Lake through development pipelines and prevent configuration changes through the AWS Management Console or the AWS Command Line Interface (AWS CLI). Additionally, you should set up strict IAM policies and service control policies (SCPs) to provide only necessary permissions to manage Security Lake. You can configure notifications to detect any direct access to these Amazon S3 buckets.

Centralized log collection

The AWS SRA recommends two options for centralized log collection and analytics across your AWS organization. Amazon CloudWatch Unified Data Experience is the recommended primary option, deployed in a dedicated Monitoring account within the Security OU. Amazon Security Lake remains available as a secondary option for organizations with existing investments or specific subscriber-based access requirements.

Amazon CloudWatch Unified Data Experience

The AWS SRA recommends that you deploy Amazon CloudWatch in a dedicated Monitoring account within the Security OU. This account serves as the centralized home for all observability, security, and compliance telemetry across your organization. Designate this account as the CloudWatch delegated administrator for the organization.

[CloudWatch Unified Data Experience](#) provides unified data management and analytics capabilities that consolidate operational, security, and compliance data across your AWS environment and third-party sources into a single service. This eliminates the need for multiple separate data stores and complex ETL pipelines. To protect the availability of the logs and the log management process,

configure strict IAM policies and service control policies (SCPs) on the Monitoring account to provide only necessary permissions to manage CloudWatch. Use detective controls such as AWS Config to monitor, alert, and remediate this collection of permissions for unexpected changes.

The CloudWatch administrator can enable organization-wide log collection using [CloudWatch Pipelines](#) and centralization rules. Pipelines automatically collect AWS vended logs (CloudTrail management events, CloudTrail data events for Amazon S3 and AWS Lambda, Amazon VPC Flow Logs, AWS WAF logs, Amazon Route 53 resolver logs, EKS audit logs) across all member accounts and regions. Logs from supported AWS services are automatically converted into a standardized open-source schema called Open Cybersecurity Schema Framework (OCSF) using the built-in OCSF processor. With OCSF support, CloudWatch efficiently normalizes and consolidates security data from AWS and other enterprise security sources to create a unified and reliable repository of security-related information. CloudWatch Pipelines also support third-party connectors to ingest external security telemetry into the same unified data store.

AWS Security Hub CSPM findings can be ingested into CloudWatch through Pipelines, providing an overview of your compliance posture and whether you're following security recommendations for AWS and AWS Partner solutions.

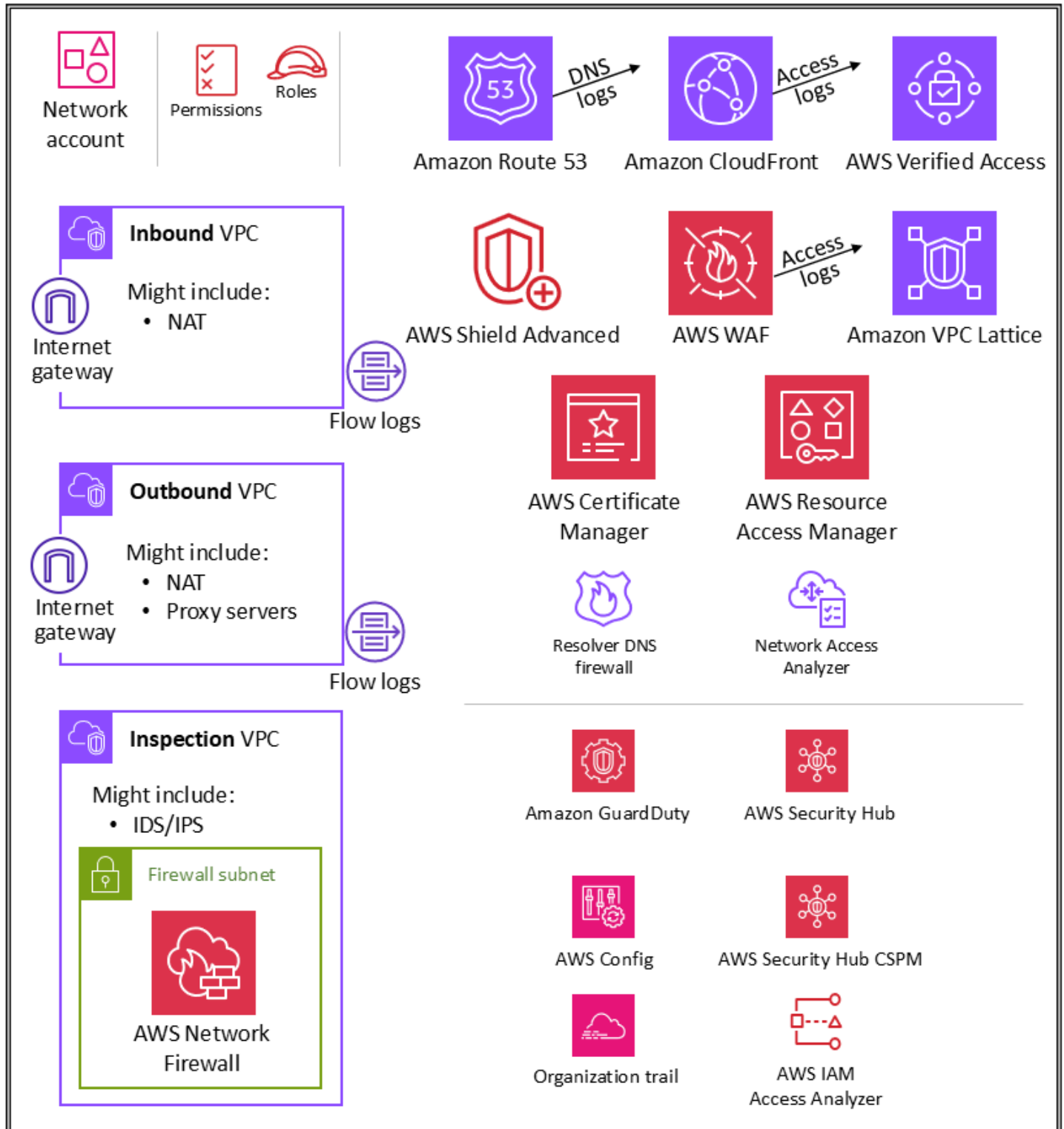
To gain visibility and actionable insights from logs and events, you can query the data by using CloudWatch Logs Insights (with Facets-based exploration, natural language queries, and LogsQL/PPL/SQL support), Amazon Athena, Amazon OpenSearch Service, Amazon Redshift, Amazon SageMaker AI, Amazon Quick, and third-party solutions. Users who require access to the log data shouldn't access the Monitoring account directly. They should access data from the Security Tooling account using CloudWatch cross-account observability, or from other AWS accounts and on-premises locations that provide analytics tools such as OpenSearch Service, Quick, or third-party tools such as security information and event management (SIEM) tools.

For long-term immutable storage, CloudWatch routes log data to S3 buckets in the Log Archive account via Amazon S3 Tables integration (Apache Iceberg format). Amazon S3 Object Lock and Glacier policies ensure immutability for regulatory compliance. The Log Archive account serves as a storage sink only and does not run CloudWatch analytics workloads.

As a best practice, we recommend that you restrict the configuration of CloudWatch through development pipelines and prevent configuration changes through the AWS Management Console or the AWS Command Line Interface (AWS CLI). You can configure notifications to detect any unauthorized access to log groups or Amazon S3 buckets.

Infrastructure OU – Network account

The following diagram illustrates the AWS security services that are configured in the Network account.



The Network account manages the gateway between your application and the broader internet. It is important to protect that two-way interface. The Network account isolates the networking services, configuration, and operation from the individual application workloads, security, and other infrastructure. This arrangement not only limits connectivity, permissions, and data flow, but also supports separation of duties and least privilege for the teams that need to operate in these accounts. By splitting network flow into separate inbound and outbound virtual private clouds (VPCs), you can protect sensitive infrastructure and traffic from undesired access. The inbound network is generally considered higher risk and deserves appropriate routing, monitoring, and potential issue mitigations. These infrastructure accounts will inherit permission guardrails from the Org Management account and the Infrastructure OU. Networking (and security) teams manage the majority of the infrastructure in this account.

Network architecture

Although network design and specifics are beyond the scope of this document, we recommend these three options for network connectivity between the various accounts: VPC peering, AWS PrivateLink, and AWS Transit Gateway. Important considerations in choosing among these are operational norms, budgets, and specific bandwidth needs.

- [VPC peering](#) – The simplest way to connect two VPCs is to use VPC peering. A connection enables full bidirectional connectivity between the VPCs. VPCs that are in separate accounts and AWS Regions can also be peered together. At scale, when you have tens to hundreds of VPCs, interconnecting them with peering results in a mesh of hundreds to thousands of peering connections, which can be challenging to manage and scale. VPC peering is best used when resources in one VPC must communicate with resources in another VPC, the environment of both VPCs is controlled and secured, and the number of VPCs to be connected is fewer than 10 (to allow for the individual management of each connection).
- [AWS PrivateLink](#) – PrivateLink provides private connectivity between VPCs, services, and applications. You can create your own application in your VPC and configure it as a PrivateLink-powered service (referred to as an *endpoint service*). Other AWS principals can create a connection from their VPC to your endpoint service by using an [interface VPC endpoint](#) or a [Gateway Load Balancer endpoint](#), depending on the type of service. When you use PrivateLink, service traffic doesn't pass across a publicly routable network. Use PrivateLink when you have a client-server setup where you want to give one or more consumer VPCs unidirectional access to a specific service or set of instances in the service provider VPC. This is also a good option when clients and servers in the two VPCs have overlapping IP addresses, because PrivateLink uses

elastic network interfaces within the client VPC so that there are no IP conflicts with the service provider.

- [AWS Transit Gateway](#) – Transit Gateway provides a hub-and-spoke design for connecting VPCs and on-premises networks as a fully managed service without requiring you to provision virtual appliances. AWS manages high availability and scalability. A transit gateway is a regional resource and can connect thousands of VPCs within the same AWS Region. You can attach your hybrid connectivity (VPN and AWS Direct Connect connections) to a single transit gateway, thereby consolidating and controlling your AWS organization's entire routing configuration in one place. A transit gateway solves the complexity involved with creating and managing multiple VPC peering connections at scale. It is the default for most network architectures, but specific needs around cost, bandwidth, and latency might make VPC peering a better fit for your needs.

Inbound (ingress) VPC

The inbound VPC is intended to accept, inspect, and route network connections initiated from outside the application. Depending on the specifics of the application, you can expect to see some network address translation (NAT) in this VPC. Flow logs from this VPC are captured and stored in the Log Archive account.

Outbound (egress) VPC

The outbound VPC is intended to handle network connections initiated from within the application. Depending on the specifics of the application, you can expect to see traffic NAT, AWS service-specific VPC endpoints, and hosting of external API endpoints in this VPC. Flow logs from this VPC are captured and stored in the Log Archive account.

Inspection VPC

A dedicated inspection VPC provides a simplified and central approach for managing inspections between VPCs (in the same or in different AWS Regions), the internet, and on-premises networks. For the AWS SRA, ensure that all traffic between VPCs passes through the inspection VPC, and avoid using the inspection VPC for any other workload.

AWS Network Firewall

[AWS Network Firewall](#) is a highly available, managed network firewall service for your VPC. It enables you to effortlessly deploy and manage stateful inspection, intrusion prevention and detection, and web filtering to help protect your virtual networks on AWS. You can use Network

Firewall to decrypt TLS sessions and inspect inbound and outbound traffic. For more information about configuring Network Firewall, see the [AWS Network Firewall – New Managed Firewall Service in VPC](#) blog post.

You use a firewall on a per-Availability Zone basis in your VPC. For each Availability Zone, you choose a subnet to host the firewall endpoint that filters your traffic. The firewall endpoint in an Availability Zone can protect all the subnets inside the zone except for the subnet where it's located. Depending on the use case and deployment model, the firewall subnet could be either public or private. The firewall is completely transparent to the traffic flow and does not perform network address translation (NAT). It preserves the source and destination address. In this reference architecture, the firewall endpoints are hosted in an inspection VPC. All traffic from the inbound VPC and to the outbound VPC is routed through this firewall subnet for inspection.

Network Firewall provides *managed rule groups*, a collection of pre-defined, ready-to-use rules that AWS writes and maintains for you. You can select one or more of the following rule groups to use in your Network Firewall policies:

- [Active threat defense managed rule groups](#) help protect against active threats tracked by AWS threat intelligence.
- [Domain and IP managed rule groups](#) help protect against domains known or suspected to be associated with malware or bots.
- [Threat signature managed rule groups](#) inspect for and defend against signatures that represent a variety of known threat categories.

Each set of managed rule groups counts as a single rule group toward the maximum number of stateful rule groups per firewall policy.

Network Firewall makes firewall activity visible in real time through Amazon CloudWatch metrics, and offers increased visibility of network traffic by sending logs to Amazon Simple Storage Service (Amazon S3), CloudWatch, and Amazon Data Firehose. Network Firewall is interoperable with your existing security approach, including technologies from [AWS Partners](#). You can also import existing [Suricata](#) rulesets, which might have been written internally or sourced externally from third-party vendors or open-source platforms.

In the AWS SRA, Network Firewall is used within the network account because the network control-focused functionality of the service aligns with the intent of the account.

Design considerations:

- AWS Firewall Manager supports Network Firewall, so you can centrally configure and deploy Network Firewall rules across your organization. (For details, see [Using AWS Network Firewall policies in Firewall Manager](#) in the AWS documentation.) When you configure Firewall Manager, it automatically creates a firewall with sets of rules in the accounts and VPCs that you specify. It also deploys an endpoint in a dedicated subnet for every Availability Zone that contains public subnets. At the same time, any changes to the centrally configured set of rules are automatically updated downstream on the deployed Network Firewall firewalls.
- There are [multiple deployment models](#) available with Network Firewall. The right model depends on your use case and requirements. Examples include the following:
 - A distributed deployment model where Network Firewall is deployed into individual VPCs.
 - A centralized deployment model where Network Firewall is deployed into a centralized VPC for east-west (VPC-to-VPC) or north-south (internet egress and ingress, on-premises) traffic.
 - A combined deployment model where Network Firewall is deployed into a centralized VPC for east-west and a subset of north-south traffic.
- As a best practice, do not use the Network Firewall subnet to deploy any other services. This is because Network Firewall cannot inspect traffic from sources or destinations within the firewall subnet.

Network Access Analyzer

[Network Access Analyzer](#) is a feature of Amazon VPC that identifies unintended network access to your resources. You can use Network Access Analyzer to validate network segmentation, identify resources that are accessible from the internet or accessible only from trusted IP address ranges, and validate that you have appropriate network controls on all network paths.

Network Access Analyzer uses automated reasoning algorithms to analyze the network paths that a packet can take between resources in an AWS network, and produces findings for paths that match your defined [Network Access Scope](#). Network Access Analyzer performs a static analysis of a network configuration, meaning that no packets are transmitted in the network as part of this analysis.

The Amazon Inspector Network Reachability rules provide a related feature. The findings generated by these rules are used in the Application account. Both Network Access Analyzer and Network Reachability use the latest technology from the [AWS provable security initiative](#), and they apply this technology with different areas of focus. The Network Reachability package focuses specifically on EC2 instances and their internet accessibility.

The Network account defines the critical network infrastructure that controls the traffic in and out of your AWS environment. This traffic needs to be tightly monitored. In the AWS SRA, Network Access Analyzer is used within the Network account to help identify unintended network access, identify internet-accessible resources through internet gateways, and verify that appropriate network controls such as network firewalls and NAT gateways are present on all network paths between resources and internet gateways.

Design consideration:

- Network Access Analyzer is a feature of Amazon VPC, and it can be used in any AWS account that has a VPC. Network administrators can get tightly scoped, cross-account IAM roles to validate that approved network paths are enforced within each AWS account.

AWS RAM

[AWS Resource Access Manager](#) (AWS RAM) helps you securely share the AWS resources that you create in one AWS account with other AWS accounts. AWS RAM provides a central place to manage the sharing of resources and to standardize this experience across accounts. This makes it simpler to manage resources while taking advantage of the administrative and billing isolation, and reduce the scope of impact containment benefits provided by a multi-account strategy. If your account is managed by AWS Organizations, AWS RAM lets you share resources with all accounts in the organization, or only with the accounts within one or more specified organizational units (OUs). You can also share with specific AWS accounts by account ID, regardless of whether the account is part of an organization. You can also share [some supported resource types](#) with specified IAM roles and users.

AWS RAM enables you to share resources that do not support IAM resource-based policies, such as VPC subnets and Route 53 rules. Furthermore, with AWS RAM, the owners of a resource can see which principals have access to individual resources that they have shared. IAM principals can retrieve the list of resources shared with them directly, which they can't do with resources shared by IAM resource policies. If AWS RAM is used to share resources outside your AWS organization, an invitation process is initiated. The recipient must accept the invitation before access to the resources is granted. This provides additional checks and balances.

AWS RAM is invoked and managed by the resource owner, in the account where the shared resource is deployed. One common use case for AWS RAM illustrated in the AWS SRA is for network administrators to share VPC subnets and transit gateways with the entire AWS organization. This provides the ability to decouple AWS account and network management functions and helps

achieve separation of duties. For more information about VPC sharing, see the AWS blog post [VPC sharing: A new approach to multiple accounts and VPC management](#) and the [AWS network infrastructure](#) whitepaper.

Design consideration:

- Although AWS RAM as a service is deployed only within the Network account in the AWS SRA, it would typically be deployed in more than one account. For example, you can centralize your data lake management to a single data lake account, and then share the AWS Lake Formation data catalog resources (databases and tables) with other accounts in your AWS organization. For more information, see the [AWS Lake Formation documentation](#) and the AWS blog post [Securely share your data across AWS accounts using AWS Lake Formation](#). Additionally, security administrators can use AWS RAM to follow best practices when they build an AWS Private Certificate Authority hierarchy. CAs can be shared with external third parties, who can issue certificates without having access to the CA hierarchy. This allows origination organizations to limit and revoke third-party access.

AWS Verified Access

[AWS Verified Access](#) provides secure access to corporate applications and resources without a VPN. It improves security posture and helps apply zero trust access by evaluating each access request in real time against predefined requirements. You can define a unique access policy for each application with conditions based on [identity data](#) and [device posture](#). Verified Access provides secure access to HTTP(S) applications, such as browser-based applications, and non-HTTP(S) applications over TCP, SSH, and RDP protocols for applications such as Git repositories, databases, and groups of EC2 instances. These can be accessed by using a command-line terminal or from a desktop application. Verified Access also simplifies security operations by helping administrators efficiently set and monitor access policies. This frees up time to update policies, respond to security and connectivity incidents, and audit for compliance standards. Verified Access also supports integration with AWS WAF to help you filter out common threats such as SQL injection and cross-site scripting (XSS). Verified Access is seamlessly integrated with AWS IAM Identity Center, which allows users to authenticate with SAML-based third-party identity providers (IdPs). If you already have a custom IdP solution that is compatible with OpenID Connect (OIDC), Verified Access can also authenticate users by directly connecting with your IdP. Verified Access logs every access attempt so that you can quickly respond to security incidents and audit requests. Verified Access supports delivery of these logs to Amazon Simple Storage Service (Amazon S3), Amazon CloudWatch Logs, and Amazon Data Firehose.

Verified Access supports two common corporate application patterns: internal and internet-facing. Verified Access integrates with applications by using Application Load Balancers or elastic network interfaces. If you're using an Application Load Balancer, Verified Access requires an internal load balancer. Because Verified Access supports AWS WAF at the instance level, an existing application that has AWS WAF integration with an Application Load Balancer can move policies from the load balancer to the Verified Access instance. A corporate application is represented as a Verified Access endpoint. Each endpoint is associated with a Verified Access group and inherits the access policy for the group. A Verified Access group is a collection of Verified Access endpoints and a group-level Verified Access policy. Groups simplify policy management and enable IT administrators to set up baseline criteria. Application owners can further define granular policies depending on the sensitivity of the application.

In the AWS SRA, Verified Access is hosted within the Network account. The central IT team sets up centrally managed configurations. For example, they might connect trust providers such as identity providers (for example, Okta) and device trust providers (for example, Jamf), create groups, and determine the group-level policy. These configurations can then be shared with tens, hundreds, or thousands of workload accounts by using AWS RAM. This enables application teams to manage the underlying endpoints that manage their applications without overhead from other teams. AWS RAM provides a scalable way to leverage Verified Access for corporate applications that are hosted in different workload accounts.

Design consideration:

- You can group endpoints for applications that have similar security requirements to simplify policy administration, and then share the group with application accounts. All applications in the group share the group policy. If an application in the group requires a specific policy because of an edge case, you can apply application-level policy for that application.

Amazon VPC Lattice

[Amazon VPC Lattice](#) is an application networking service that connects, monitors, and secures service-to-service communications. A [service](#), often called a *microservice*, is an independently deployable unit of software that delivers a specific task. VPC Lattice automatically manages network connectivity and application-layer routing between services across VPCs and AWS accounts without requiring you to manage the underlying network connectivity, frontend load balancers, or sidecar proxies. It provides a fully managed application-layer proxy that provides application-level routing based on request characteristics such as paths and headers. VPC Lattice is built into the VPC infrastructure, so it provides a consistent approach across a wide range of

compute types such as Amazon Elastic Compute Cloud (Amazon EC2), Amazon Elastic Kubernetes Service (Amazon EKS), and AWS Lambda. VPC Lattice also supports weighted routing for blue/green and canary-style deployments. You can use VPC Lattice to create a [service network](#) with a logical boundary that automatically implements service discovery and connectivity. VPC Lattice integrates with IAM for service-to-service authentication and authorization using [auth policies](#).

VPC Lattice integrates with AWS RAM to enable sharing of services and service networks. AWS SRA depicts a distributed architecture where developers or service owners create VPC Lattice services in their Application account. Service owners define the listeners, routing rules, and target groups along with auth policies. They then share the services with other accounts, and associate the services with VPC Lattice service networks. These networks are created by network administrators in the Network account and shared with the Application account. Network administrators configure service network-level auth policies and monitoring. Administrators associate VPCs and VPC Lattice services with one or more service networks. For a detailed walkthrough of this distributed architecture, see the AWS blog post [Build secure multi-account multi-VPC connectivity for your applications with Amazon VPC Lattice](#).

Design considerations:

- Depending on your organization's operating model of service or service network visibility, network administrators can share their service networks and can give service owners the control to associate their services and VPCs with these service networks. Or, service owners can share their services, and network administrators can associate the services with service networks.
- All clients and services in VPCs associated with the service network can communicate with other services within the same service network. Traffic that traverses VPC peering or AWS Transit Gateway can also access resources and services over a VPC endpoint.

Edge security

Edge security generally entails three types of protections: secure content delivery, network and application-layer protection, and distributed denial of service (DDoS) mitigation. Content such as data, videos, applications, and APIs have to be delivered quickly and securely, using the recommended version of TLS to encrypt communications between endpoints. The content should also have access restrictions through signed URLs, signed cookies, and token authentication. Application-level security should be designed to control bot traffic, block common attack patterns such as SQL injection or cross-site scripting (XSS), and provide web traffic visibility. At the edge, DDoS mitigation provides an important defense layer that ensures continued availability of

mission-critical business operations and services. Applications and APIs should be protected from SYN floods, UDP floods, or other reflection attacks, and have inline mitigation to stop basic network-layer attacks.

AWS offers several services to help provide a secure environment, from the core cloud to the edge of the AWS network. Amazon CloudFront, AWS Certificate Manager (ACM), AWS Shield, AWS WAF, and Amazon Route 53 work together to help create a flexible, layered security perimeter. With CloudFront, content, APIs, or applications can be delivered over HTTPS by using TLSv1.3 to encrypt and secure communication between viewer clients and CloudFront. You can use ACM to create a [custom SSL certificate](#) and deploy it to a CloudFront distribution for free. ACM automatically handles certificate renewal. Shield is a managed DDoS protection service that helps safeguard applications that run on AWS. It provides dynamic detection and automatic inline mitigations that minimize application downtime and latency. AWS WAF lets you create rules to filter web traffic based on specific conditions (IP addresses, HTTP headers and body, or custom URIs), common web attacks, and pervasive bots. Route 53 is a highly available and scalable DNS web service. Route 53 connects user requests to internet applications that run on AWS or on premises. The AWS SRA adopts a centralized network ingress architecture by using AWS Transit Gateway, hosted within the Network account, so the edge security infrastructure is also centralized in this account.

Amazon CloudFront

[Amazon CloudFront](#) is a secure content delivery network (CDN) that provides inherent protection against common network layer and transport DDoS attempts. You can deliver your content, APIs, or applications by using TLS certificates, and advanced TLS features are enabled automatically. You can use AWS Certificate Manager (ACM) to create a custom TLS certificate and enforce HTTPS communications between viewers and CloudFront, as described later in the [ACM section](#). You can additionally require that the communications between CloudFront and your custom origin implement end-to-end encryption in transit. For this scenario, you must install a TLS certificate on your origin server. If your origin is an elastic load balancer, you can use a certificate that is generated by ACM or a certificate that is validated by a third-party certificate authority (CA) and imported into ACM. If S3 bucket website endpoints serve as the origin for CloudFront, you can't configure CloudFront to use HTTPS with your origin, because Amazon S3 doesn't support HTTPS for website endpoints. (However, you can still require HTTPS between viewers and CloudFront.) For all other origins that support installing HTTPS certificates, you must use a certificate that is signed by a trusted third-party CA.

CloudFront provides multiple options to secure and restrict access to your content. For example, it can restrict access to your Amazon S3 origin by using signed URLs and signed cookies. For

more information, see [Configure secure access and restrict access to content](#) in the CloudFront documentation.

The AWS SRA illustrates centralized CloudFront distributions in the Network account because they align with the centralized network pattern that's implemented by using AWS Transit Gateway. By deploying and managing CloudFront distributions in the Network account, you gain the benefits of centralized controls. You can manage all CloudFront distributions in a single place, which makes it easier to control access, configure settings, and monitor usage across all accounts. Additionally, you can manage the ACM certificates, DNS records, and CloudFront logging from one centralized account.

The CloudFront security dashboard provides AWS WAF visibility and controls directly in your CloudFront distribution. You get visibility into your application's top security trends, allowed and blocked traffic, and bot activity. You can use investigative tools such as visual log analyzers and built-in blocking controls to isolate traffic patterns and block traffic without querying logs or writing security rules.

Design considerations:

- Alternatively, you can deploy CloudFront as part of the application in the Application account. In this scenario, the application team makes decisions such as how the CloudFront distributions are deployed, determines the appropriate cache policies, and takes responsibility for governance, auditing, and monitoring of the CloudFront distributions. By spreading CloudFront distributions across multiple accounts, you can benefit from additional service quotas. As another benefit, you can use CloudFront's inherent and automated [origin access identity \(OAI\) and origin access control \(OAC\)](#) configuration to restrict access to Amazon S3 origins.
- When you deliver web content through a CDN such as CloudFront, you have to prevent viewers from bypassing the CDN and accessing your origin content directly. To achieve this origin access restriction, you can use CloudFront and AWS WAF to add custom headers and verify the headers before you forward requests to your custom origin. For a detailed explanation of this solution, see the AWS security blog post [How to enhance Amazon CloudFront origin security with AWS WAF and AWS Secrets Manager](#). An alternate method is to limit only the CloudFront prefix list in the security group that's associated with the Application Load Balancer. This will help ensure that only a CloudFront distribution can access the load balancer.

AWS WAF

[AWS WAF](#) is a web application firewall that helps protect your web applications from web exploits such as common vulnerabilities and bots that could affect application availability, compromise security, or consume excessive resources. It can be integrated with an Amazon CloudFront distribution, an Amazon API Gateway REST API, an Application Load Balancer, an AWS AppSync GraphQL API, an Amazon Cognito user pool, and the AWS App Runner service.

AWS WAF uses [web access control lists](#) (ACLs) to protect a set of AWS resources. A web ACL is a set of [rules](#) that defines the inspection criteria, and an associated action to take (block, allow, count, or run bot control) if a web request meets the criteria. AWS WAF provides a set of [managed rules](#) that provides protection against common application vulnerabilities. These rules are curated and managed by AWS and AWS Partners. AWS WAF also offers a powerful rule language for authoring custom rules. You can use custom rules to write inspection criteria that fit your particular needs. Examples include IP restrictions, geographical restrictions, and customized versions of managed rules that better fit your specific application behavior.

AWS WAF provides a set of intelligent tier-managed rules for common and targeted bots and account takeover protection (ATP). You are charged a subscription fee and a traffic inspection fee when you use the bot control and ATP rule groups. Therefore, we recommend that you monitor your traffic first and then decide what to use. You can use the bot management and account takeover dashboards that are available for free on the AWS WAF console to monitor these activities and then decide whether you need an intelligent tier AWS WAF rule group.

In the AWS SRA, AWS WAF is integrated with CloudFront in the Network account. In this configuration, AWS WAF rule processing happens at the edge locations instead of within the VPC. This enables filtering of malicious traffic closer to the end user who requested the content, and helps restrict malicious traffic from entering your core network.

You can send full AWS WAF logs to an S3 bucket in the Log Archive account by configuring cross-account access to the S3 bucket. For more information, see the [AWS re:Post article](#) on this topic.

Design considerations:

- As an alternative to deploying AWS WAF centrally in the Network account, some use cases are better met by deploying AWS WAF in the Application account. For example, you might choose this option when you deploy your CloudFront distributions in your Application account or have public-facing Application Load Balancers, or if you're using API Gateway in front of your web applications. If you decide to deploy AWS WAF in each Application account, use AWS Firewall

Manager to manage the AWS WAF rules in these accounts from the centralized Security Tooling account.

- You can also add general AWS WAF rules at the CloudFront layer and additional application-specific AWS WAF rules at a Regional resource such as the Application Load Balancer or the API gateway.

AWS Shield

[AWS Shield](#) is a managed DDoS protection service that safeguards applications that run on AWS. There are two tiers of Shield: Shield Standard and Shield Advanced. Shield Standard provides all AWS customers with protection against the most common infrastructure (layers 3 and 4) events at no additional charge. Shield Advanced provides more sophisticated automatic mitigations for unauthorized events that target applications on protected Amazon EC2, Elastic Load Balancing (Elastic Load Balancing), CloudFront, AWS Global Accelerator, and Route 53 hosted zones. If you own high-visibility websites or are prone to frequent DDoS attacks, you can consider the additional features that Shield Advanced provides.

You can use the [Shield Advanced automatic application layer DDoS mitigation feature](#) to configure Shield Advanced to respond automatically to mitigate application layer (layer 7) attacks against your protected CloudFront distributions, Elastic Load Balancing (Elastic Load Balancing) load balancers (Application, Network, and Classic), Amazon Route 53 hosted zones, Amazon EC2 Elastic IP addresses, and AWS Global Accelerator standard accelerators. When you enable this feature, Shield Advanced automatically generates custom AWS WAF rules to mitigate DDoS attacks. Shield Advanced also gives you access to the [AWS Shield Response Team](#) (SRT). You can contact SRT at any time to create and manage custom mitigations for your application or during an active DDoS attack. If you want SRT to proactively monitor your protected resources and contact you during a DDoS attempt, consider enabling the [proactive engagement](#) feature.

Design considerations:

- If you have any workloads that are fronted by internet-facing resources in the Application account, such as CloudFront, an Application Load Balancer, or a Network Load Balancer, configure Shield Advanced in the Application account and add those resources to Shield protection. You can use AWS Firewall Manager to configure these options at scale.
- If you have multiple resources in the data flow, such as a CloudFront distribution in front of an Application Load Balancer, use only the entry-point resource as the protected resource. This will ensure that you are not paying [Shield Data Transfer Out \(DTO\) fees](#) twice for two resources.

- Shield Advanced records metrics that you can monitor in Amazon CloudWatch. (For more information, see [Monitoring with Amazon CloudWatch](#) in the AWS documentation.) Set up CloudWatch alarms to receive SNS notifications to your security center when a DDoS event is detected. In a suspected DDoS event, contact the [AWS Enterprise Support](#) team by filing a support ticket and assigning it the highest priority. The Enterprise Support team will include the Shield Response Team (SRT) when handling the event. In addition, you can preconfigure the AWS Shield engagement Lambda function to create a support ticket and send an email to the SRT team.

AWS Certificate Manager (ACM)

[AWS Certificate Manager](#) (ACM) lets you provision, manage, and deploy public and private TLS certificates for use with AWS services and your internal connected resources. With ACM, you can quickly request a certificate, deploy it on ACM-integrated AWS resources, such as Elastic Load Balancing load balancers, CloudFront distributions, and APIs on Amazon API Gateway, and let ACM handle certificate renewals. When you request ACM public certificates, there is no need to generate a key pair or a certificate signing request (CSR), submit a CSR to a certificate authority (CA), or upload and install the certificate when it is received. ACM also provides the option to import TLS certificates issued by third-party CAs and deploy them with ACM integrated services. When you use ACM to manage certificates, certificate private keys are securely protected and stored by using strong encryption and key management best practices. With ACM there is no additional charge for provisioning public certificates, and ACM manages the renewal process.

ACM is used in the Network account to generate a public TLS certificate, which, in turn, is used by CloudFront distributions to establish the HTTPS connection between viewers and CloudFront. For more information, see the [CloudFront documentation](#).

Design consideration:

- For externally facing certificates, ACM must reside in the same account as the resources for which it provisions certificates. Certificates cannot be shared across accounts.

Amazon Route 53

[Amazon Route 53](#) is a highly available and scalable DNS web service. You can use Route 53 to perform three main functions: domain registration, DNS routing, and health checking.

You can use Route 53 as a DNS service to map domain names to your EC2 instances, S3 buckets, CloudFront distributions, and other AWS resources. The distributed nature of the AWS DNS servers helps ensure that your end users are routed to your application consistently. Features such as Route 53 traffic flow and routing control help you improve reliability. If your primary application endpoint becomes unavailable, you can configure your failover to reroute your users to an alternate location. Route 53 Resolver provides recursive DNS for your VPC and on-premises networks over AWS Direct Connect or AWS managed VPN.

By using the IAM service with Route 53, you get fine-grained control over who can update your DNS data. You can enable DNS Security Extensions (DNSSEC) signing to let DNS resolvers validate that a DNS response came from Route 53 and has not been tampered with.

[Route 53 Resolver DNS Firewall](#) provides protection for outbound DNS requests from your VPCs. These requests go through Route 53 Resolver for domain name resolution. A primary use of DNS Firewall protections is to help prevent DNS exfiltration of your data. With DNS Firewall, you can monitor and control the domains that your applications can query. You can deny access to the domains that you know are bad, and allow all other queries to pass through. Alternately, you can deny access to all domains except for the ones that you explicitly trust. You can also use DNS Firewall to block resolution requests to resources in private hosted zones (shared or local), including VPC endpoint names. It can also block requests for public or private EC2 instance names.

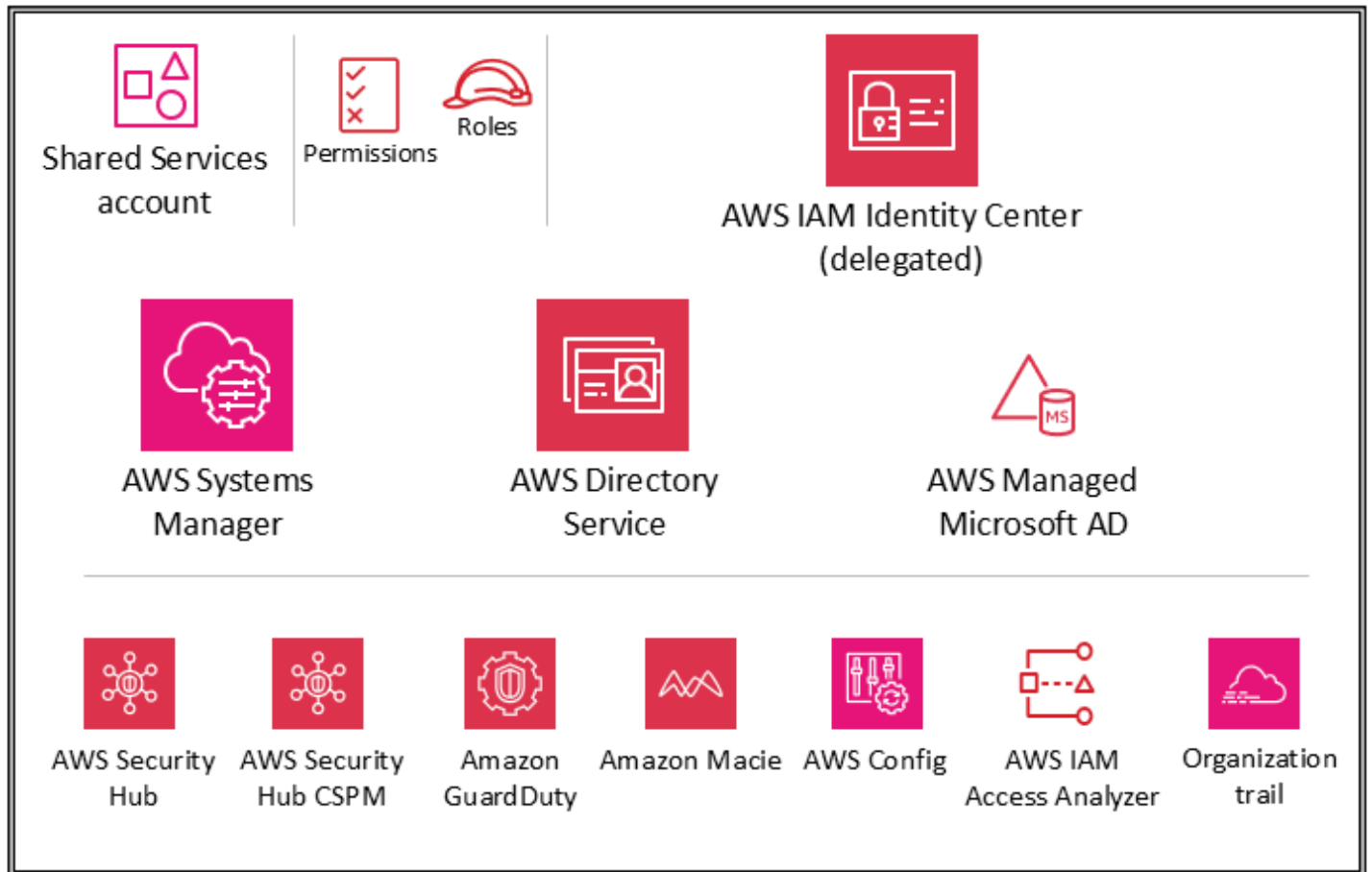
Route 53 resolvers are created by default as part of every VPC. In the AWS SRA, Route 53 is used in the Network account primarily for the DNS Firewall capability.

Design consideration:

- DNS Firewall and AWS Network Firewall both offer domain name filtering, but for different types of traffic. You can use DNS Firewall and Network Firewall together to configure domain-based filtering for application-layer traffic over two different network paths:
 - DNS Firewall provides filtering for outbound DNS queries that pass through the Route 53 Resolver from applications within your VPCs. You can also configure DNS Firewall to send custom responses for queries to blocked domain names.
 - Network Firewall provides filtering for both network-layer and application-layer traffic, but does not have visibility into queries made by Route 53 Resolver.

Infrastructure OU – Shared Services account

The following diagram illustrates the AWS security services that are configured in the Shared Services account.



The Shared Services account is part of the Infrastructure OU, and its purpose is to support the services that multiple applications and teams use to deliver their outcomes. For example, directory services (Active Directory), messaging services, and metadata services are in this category. The AWS SRA highlights the shared services that support security controls. Although the Network accounts are also part of the Infrastructure OU, they are removed from the Shared Services account to support the separation of duties. The teams that will manage these services don't need permissions or access to the Network accounts.

AWS Systems Manager

[AWS Systems Manager](#) (which is also included in the Org Management account and in the Application account) provides a collection of capabilities that enable visibility and control of your AWS resources. One of these capabilities, Systems Manager Explorer, is a customizable operations dashboard that reports information about your AWS resources. You can synchronize operations data across all accounts in your AWS organization by using AWS Organizations and Systems Manager Explorer. Systems Manager is deployed in the Shared Services account through the delegated administrator functionality in AWS Organizations.

Systems Manager helps you work to maintain security and compliance by scanning your managed instances and reporting (or taking corrective action) on any policy violations it detects. By pairing Systems Manager with appropriate deployments in individual member AWS accounts (for example, the Application account), you can coordinate instance inventory data collection and centralize automation such as patching and security updates.

AWS Managed Microsoft AD

[AWS Directory Service for Microsoft Active Directory](#), also known as AWS Managed Microsoft AD, enables your directory-aware workloads and AWS resources to use managed Active Directory on AWS. You can use AWS Managed Microsoft AD to join [Amazon EC2 for Windows Server](#), [Amazon EC2 for Linux](#), and [Amazon RDS for SQL Server](#) instances to your domain, and use [AWS end user computing \(EUC\)](#) services, such as [Amazon WorkSpaces](#), with Active Directory users and groups.

AWS Managed Microsoft AD helps you extend your existing Active Directory to AWS and use your existing on-premises user credentials to access cloud resources. You can also administer your on-premises users, groups, applications, and systems without the complexity of running and maintaining an on-premises, highly available Active Directory. You can join your existing computers, laptops, and printers to an AWS Managed Microsoft AD domain.

AWS Managed Microsoft AD is built on Microsoft Active Directory and doesn't require you to synchronize or replicate data from your existing Active Directory to the cloud. You can use familiar Active Directory administration tools and features, such as Group Policy Objects (GPOs), domain trusts, fine-grained password policies, group Managed Service Accounts (gMSAs), schema extensions, and Kerberos-based single sign-on. You can also delegate administrative tasks and authorize access using Active Directory security groups.

Multi-Region replication enables you to deploy and use a single AWS Managed Microsoft AD directory across multiple AWS Regions. This makes it easier and more cost-effective for you to

deploy and manage your Microsoft Windows and Linux workloads globally. When you use the automated multi-Region replication capability, you get higher resiliency while your applications use a local directory for optimal performance.

AWS Managed Microsoft AD supports Lightweight Directory Access Protocol (LDAP) over SSL/TLS, also known as LDAPS, in both client and server roles. When acting as a server, AWS Managed Microsoft AD supports LDAPS over ports 636 (SSL) and 389 (TLS). You enable server-side LDAPS communications by installing a certificate on your AWS Managed Microsoft AD domain controllers from an AWS-based Active Directory Certificate Services (AD CS) certificate authority (CA). When acting as a client, AWS Managed Microsoft AD supports LDAPS over ports 636 (SSL). You can enable client-side LDAPS communications by registering CA certificates from your server certificate issuers into AWS, and then enable LDAPS on your directory.

In the AWS SRA, Directory Service is used within the Shared Services account to provide domain services for Microsoft-aware workloads across multiple AWS member accounts.

Design considerations:

- You can grant your on-premises Active Directory users access to sign in to the AWS Management Console and AWS Command Line Interface (AWS CLI) with their existing Active Directory credentials by using IAM Identity Center and selecting AWS Managed Microsoft AD as the identity source. This enables your users to assume one of their assigned roles at sign-in, and to access and take action on the resources according to the permissions defined for the role. An alternative option is to use AWS Managed Microsoft AD to enable your users to assume an IAM role.
- You can configure AWS Managed Microsoft AD security settings to align with Defense Information Systems Agency (DISA) Security Technical Implementation Guides (STIG) for [Windows Server](#) and [Active Directory](#). You can configure through a self-service interface, both programmatically and through the AWS Management Console. You can now ensure consistent configuration across multiple managed directories by declaring their desired configuration and letting AWS implement and persist these configurations. When expanding to additional regions or scaling out with additional domain controllers, AWS Managed Microsoft AD automatically applies these settings to all new instances.

IAM Identity Center

The AWS SRA uses the delegated administrator feature supported by AWS IAM Identity Center to delegate most of the administration of IAM Identity Center to the Shared Services account.

This helps restrict the number of users who require access to the Org Management account. IAM Identity Center still needs to be enabled in the Org Management account to perform certain tasks, including the management of permission sets that are provisioned within the Org Management account.

The primary reason for using the Shared Services account as the delegated administrator for IAM Identity Center is the Active Directory location. If you plan to use Active Directory as your IAM Identity Center identity source, you will need to locate the directory in the member account that you have designated as your IAM Identity Center delegated administrator account. In the AWS SRA, the Shared Services account hosts AWS Managed Microsoft AD, so that account is made the delegated administrator for IAM Identity Center.

IAM Identity Center supports the registration of a single member account as a delegated administrator at one time. You can register a member account only when you sign in with credentials from the management account. To enable delegation, you have to consider the prerequisites listed in the [IAM Identity Center documentation](#). The delegated administrator account can perform most IAM Identity Center management tasks, but with some restrictions, which are listed in the [IAM Identity Center documentation](#). Access to the delegated administrator account for IAM Identity Center should be tightly controlled.

Design considerations:

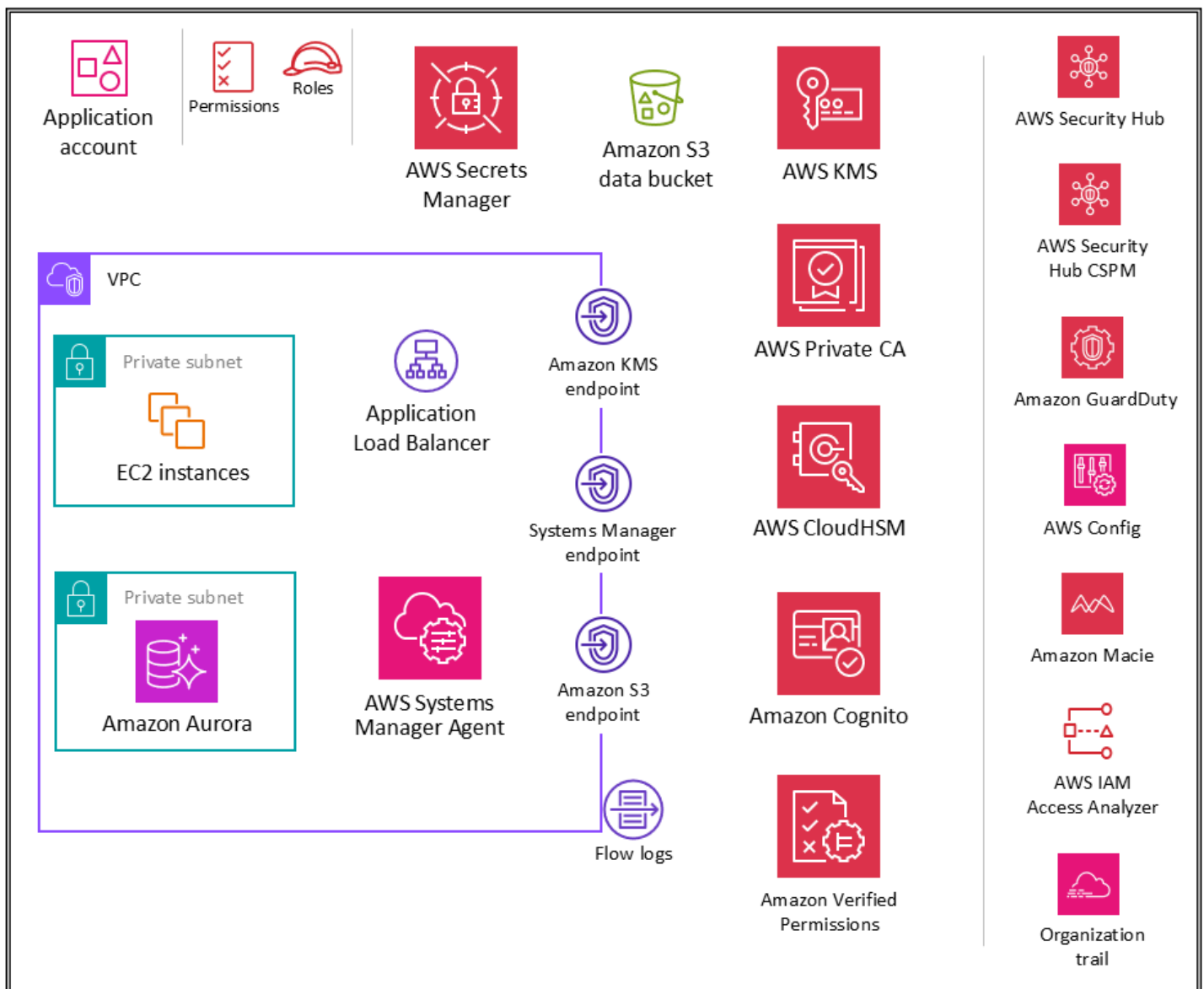
- If you decide to change the IAM Identity Center identity source from any other source to Active Directory, or change it from Active Directory to any other source, the directory must reside in (be owned by) the IAM Identity Center delegated administrator member account, if one exists; otherwise, it must be in the management account.
- You can host your AWS Managed Microsoft AD within a dedicated VPC in a different account and then use [AWS Resource Access Manager \(AWS RAM\)](#) to share subnets from this other account to the delegated administrator account. That way, the AWS Managed Microsoft AD instance is controlled in the delegated administrator account, but from the network perspective it acts as if it is deployed in the VPC of another account. This is helpful when you have multiple AWS Managed Microsoft AD instances and you want to deploy them locally to where your workload is running but manage them centrally through one account.
- If you have a dedicated identity team that performs regular identity and access management activities or have strict security requirements to separate identity management functions from other shared services functions, you can host a dedicated AWS account for identity management. In this scenario, you designate this account as your delegated administrator for IAM Identity Center, and it also hosts your AWS Managed Microsoft AD directory. You can achieve the same

level of logical isolation between your identity management workloads and other shared services workloads by using fine-grained IAM permissions within a single shared service account.

- IAM Identity Center currently doesn't support the use of different identity sources for different set of accounts or let you delegate permissions management to different parts of your organization (that is, multiple delegated administrators) or to different groups of administrators. If you require these features, you can use [IAM federation](#) to manage your user identities within an identity provider (IdP) outside of AWS and give these external user identities permission to use AWS resources in your account. IAM supports IdPs that are compatible with [OpenID Connect \(OIDC\)](#) or SAML 2.0. As a best practice, use SAML 2.0 federation with third-party identity providers such as Active Directory Federation Service (AD FS), Okta, Azure Active Directory (Azure AD), or Ping Identity to provide single sign-on capability for users to log into the AWS Management Console or to call AWS API operations. For more information about IAM federation and identity providers, see [About SAML 2.0-based federation](#) in the IAM documentation.

Workloads OU – Application account

The following diagram illustrates the AWS security services that are configured in the Application account (along with the application itself).



The Application account hosts the primary infrastructure and services to run and maintain an enterprise application. The Application account and Workloads OU serve a few primary security objectives. First, you create a separate account for each application to provide boundaries and controls between workloads so that you can avoid issues of comingling roles, permissions, data, and encryption keys. You want to provide a separate account container where the application team can be given broad rights to manage their own infrastructure without affecting others. Next, you add a layer of protection by providing a mechanism for the security operations team to monitor and collect security data. Employ an organization trail and local deployments of account security services (Amazon GuardDuty, AWS Config, AWS Security Hub CSPM, Amazon EventBridge, IAM

Access Analyzer), which are configured and monitored by the security team. Finally, you enable your enterprise to set controls centrally. You align the application account to the broader security structure by making it a member of the Workloads OU through which it inherits appropriate service permissions, constraints, and guardrails.

Design consideration:

- In your organization you are likely to have more than one business application. The Workloads OU is intended to house most of your business-specific workloads, including both production and non-production environments. These workloads can be a mix of commercial off-the-shelf (COTS) applications and your own internally developed custom applications and data services. There are few patterns for organizing different business applications along with their development environments. One pattern is to have multiple child OUs based on your development environment, such as production, staging, test, and development, and to use separate child AWS accounts under those OUs that pertain to different applications. Another common pattern is to have separate child OUs per application and then use separate child AWS accounts for individual development environments. The exact OU and account structure depends on your application design and the teams that manage those applications. Consider the security controls that you want to enforce, whether they are environment-specific or application-specific, because it is easier to implement those controls as SCPs on OUs. For further considerations on organizing workload-oriented OUs, see the [Application OUs](#) section of the AWS whitepaper *Organizing your AWS environment using multiple accounts*.

Application VPC

The virtual private cloud (VPC) in the Application account needs both inbound access (for the simple web services that you are modeling) and outbound access (for application needs or AWS service needs). By default, resources inside a VPC are routable to one another. There are two private subnets: one to host the EC2 instances (application layer) and the other for Amazon Aurora (database layer). Network segmentation between different tiers, such as the application tier and database tier, is accomplished through VPC security groups, which restrict traffic at the instance level. For resiliency, the workload spans two or more Availability Zones and utilizes two subnets per zone.

Design consideration:

- You can use [Traffic Mirroring](#) to copy network traffic from an elastic network interface of EC2 instances. You can then send the traffic to out-of-band security and monitoring appliances for

content inspection, threat monitoring, or troubleshooting. For example, you might want to monitor the traffic that is leaving your VPC or the traffic whose source is outside your VPC. In this case, you will mirror all traffic except for the traffic passing within your VPC and send it to a single monitoring appliance. Amazon VPC flow logs do not capture mirrored traffic; they generally capture information from packet headers only. Traffic Mirroring provides deeper insight into the network traffic by allowing you to analyze actual traffic content, including payload. Enable Traffic Mirroring only for the elastic network interface of EC2 instances that might be operating as part of sensitive workloads or for which you expect to need detailed diagnostics in the event of an issue.

VPC endpoints

[VPC endpoints](#) provide another layer of security control as well as scalability and reliability. Use these to connect your application VPC to other AWS services. (In the Application account, the AWS SRA employs VPC endpoints for AWS KMS, AWS Systems Manager, and Amazon S3.) Endpoints are virtual devices. They are horizontally scaled, redundant, and highly available VPC components. They allow communication between instances in your VPC and services without imposing availability risks or bandwidth constraints on your network traffic. You can use a VPC endpoint to privately connect your VPC to supported AWS services and VPC endpoint services powered by AWS PrivateLink without requiring an internet gateway, NAT device, VPN connection, or AWS Direct Connect connection. Instances in your VPC do not require public IP addresses to communicate with other AWS services. Traffic between your VPC and the other AWS service does not leave the Amazon network.

Another benefit of using VPC endpoints is to enable the configuration of endpoint policies. A VPC endpoint policy is an IAM resource policy that you attach to an endpoint when you create or modify the endpoint. If you do not attach an IAM policy when you create an endpoint, AWS attaches a default IAM policy for you that allows full access to the service. An endpoint policy does not override or replace IAM user policies or service-specific policies (such as S3 bucket policies). It is a separate IAM policy for controlling access from the endpoint to the specified service. In this way, it adds another layer of control over which AWS principals can communicate with resources or services.

Amazon EC2

The [Amazon EC2](#) instances that compose our application make use of version 2 of the Instance Metadata Service (IMDSv2). IMDSv2 adds protections for four types of vulnerabilities that could

be used to try to access the IMDS: website application firewalls, open reverse proxies, server-side request forgery (SSRF) vulnerabilities, open layer 3 firewalls, and NATs. For more information, see the blog post [Add defense in depth against open firewalls, reverse proxies, and SSRF vulnerabilities with enhancements to the EC2 Instance Metadata Service](#).

Use separate VPCs (as subset of account boundaries) to isolate infrastructure by workload segments. Use subnets to isolate the tiers of your application (for example, web, application, and database) within a single VPC. Use private subnets for your instances if they should not be accessed directly from the internet. To call the Amazon EC2 API from your private subnet without using an internet gateway, use AWS PrivateLink. Restrict access to your instances by using [security groups](#). Use [VPC Flow Logs](#) to monitor the traffic that reaches your instances. Use [Session Manager](#), a capability of AWS Systems Manager, to access your instances remotely instead of opening inbound SSH ports and managing SSH keys. Use separate Amazon Elastic Block Store (Amazon EBS) volumes for the operating system and your data. You can [configure your AWS account](#) to enforce the encryption of the new EBS volumes and snapshot copies that you create.

Implementation example:

- The [AWS SRA code library](#) provides a sample implementation of [default Amazon EBS encryption in Amazon EC2](#). It demonstrates how you can enable the account-level default Amazon EBS encryption within each AWS account and AWS Region in the AWS organization.

AWS Nitro Enclaves

[AWS Nitro Enclaves](#) is an Amazon EC2 feature that allows you to create isolated execution environments, called *enclaves*, from EC2 instances. Enclaves are separate, hardened, and highly constrained virtual machines. The CPU and memory of a single parent EC2 instance is partitioned into isolated enclaves. Each enclave runs an independent kernel. Enclaves provide only secure local socket connectivity with their parent instance. They have no persistent storage, interactive access, or external networking. Users cannot SSH into an enclave, and the data and applications inside the enclave cannot be accessed by the processes, applications, or users (root or administrator) of the parent instance. You can secure your most sensitive data, such as personally identifiable information (PII), healthcare, financial, and intellectual property data, within EC2 instances. Nitro Enclaves enables you to focus on your application instead of worrying about integration with external services. Nitro Enclaves includes cryptographic attestation for your software so that you can be sure that only authorized code is running, and integration with the AWS KMS so that only your enclaves can access sensitive material. This helps reduce the attack surface area for your most sensitive data processing applications. There is no additional cost of using Nitro Enclaves.

[Cryptographic attestation](#) is a process used to prove the identity of an enclave. The attestation process is accomplished through the Nitro Hypervisor, which produces a signed attestation document for the enclave to prove its identity to another third party or service. Attestation documents contain key details of the enclave such as the enclave's public key, hashes of the enclave image and applications, and more.

With AWS Certificate Manager (ACM) for Nitro Enclaves, you can use public and private SSL/TLS certificates with your web applications and web servers running on EC2 instances with Nitro Enclaves. SSL/TLS certificates are used to secure network communications and to establish the identity of websites over the internet and resources on private networks. ACM for Nitro Enclaves removes the time-consuming and error-prone manual process of purchasing, uploading, and renewing SSL/TLS certificates. ACM for Nitro Enclaves creates secure private keys, distributes the certificate and its private key to your enclave, and manages certificate renewals. With ACM for Nitro Enclaves, the certificate's private key remains isolated in the enclave, which prevents the instance and its users from accessing it. For more information, see [AWS Certificate Manager for Nitro Enclaves](#) in the Nitro Enclaves documentation.

Application Load Balancers

[Application Load Balancers](#) distribute incoming application traffic across multiple targets, such as EC2 instances, in multiple Availability Zones. In the AWS SRA, the target group for the load balancer are the application EC2 instances. The AWS SRA uses HTTPS listeners to ensure that the communication channel is encrypted. The Application Load Balancer uses a server certificate to terminate the front-end connection, and then to decrypt requests from clients before sending them to the targets.

AWS Certificate Manager (ACM) natively integrates with Application Load Balancers, and the AWS SRA uses ACM to generate and manage the necessary X.509 (TLS server) public certificates. You can enforce TLS 1.2 and strong ciphers for front-end connections through the Application Load Balancer security policy. For more information, see the [Elastic Load Balancing documentation](#).

Design considerations:

- For common scenarios such as strictly internal applications that require a private TLS certificate on the Application Load Balancer, you can use ACM within this account to generate a private certificate from AWS Private CA. In the AWS SRA, the ACM root private CA is hosted in the Security Tooling account and can be shared with the whole AWS organization or with specific AWS accounts to issue end-entity certificates, as described earlier in the [Security Tooling account](#) section.

- For public certificates, you can use ACM to generate those certificates and manage them, including automated rotation. Alternatively, you can generate your own certificates by using SSL/TLS tools to create a certificate signing request (CSR), get the CSR signed by a certificate authority (CA) to produce a certificate, and then import the certificate into ACM or upload the certificate to IAM for use with the Application Load Balancer. If you import a certificate into ACM, you must monitor the expiration date of the certificate and renew it before it expires.
- For additional layers of defense, you can deploy AWS WAF policies to protect the Application Load Balancer. Having edge policies, application policies, and even private or internal policy enforcement layers adds to the visibility of communication requests and provides unified policy enforcement. For more information, see the blog post [Deploying defense in depth using AWS Managed Rules for AWS WAF](#).

AWS Private CA

[AWS Private Certificate Authority](#) (AWS Private CA) is used in the Application account to generate private certificates to be used with an Application Load Balancer. It is a common scenario for Application Load Balancers to serve secure content over TLS. This requires TLS certificates to be installed on the Application Load Balancer. For applications that are strictly internal, private TLS certificates can provide the secure channel.

In the AWS SRA, AWS Private CA is hosted in the Security Tooling account and is shared out to the Application account by using AWS RAM. This allows developers in an Application account to request a certificate from a shared private CA. Sharing CAs across your organization or across AWS accounts helps reduce the cost and complexity of creating and managing duplicate CAs in all your AWS accounts. When you use ACM to issue private certificates from a shared CA, the certificate is generated locally in the requesting account, and ACM provides full lifecycle management and renewal.

Amazon Inspector

The AWS SRA uses [Amazon Inspector](#) to automatically discover and scan EC2 instances and container images that reside in the Amazon Elastic Container Registry (Amazon ECR) for software vulnerabilities and unintended network exposure.

Amazon Inspector is placed in the Application account, because it provides vulnerability management services to EC2 instances in this account. Additionally, Amazon Inspector reports on [unwanted network paths](#) to and from EC2 instances.

Amazon Inspector in member accounts is centrally managed by the delegated administrator account. In the AWS SRA, the Security Tooling account is the delegated administrator account. The delegated administrator account can manage findings data and certain settings for members of the organization. This includes viewing aggregated findings details for all member accounts, enabling or disabling scans for member accounts, and reviewing scanned resources within the AWS organization.

Design consideration:

- You can use [Patch Manager](#), a capability of AWS Systems Manager, to trigger on-demand patching to remediate Amazon Inspector zero-day or other critical security vulnerabilities. Patch Manager helps you patch those vulnerabilities without having to wait for your normal patching schedule. The remediation is carried out by using the Systems Manager Automation runbook. For more information, see the two-part blog series [Automate vulnerability management and remediation in AWS using Amazon Inspector and AWS Systems Manager](#).

AWS Systems Manager

[AWS Systems Manager](#) is an AWS service that you can use to view operational data from multiple AWS services and automate operational tasks across your AWS resources. With automated approval workflows and runbooks, you can work to reduce human error and simplify maintenance and deployment tasks on AWS resources.

In addition to these general automation capabilities, Systems Manager supports a number of preventive, detective, and responsive security features. [AWS Systems Manager Agent](#) (SSM Agent) is Amazon software that can be installed and configured on an EC2 instance, an on-premises server, or a virtual machine (VM). SSM Agent makes it possible for Systems Manager to update, manage, and configure these resources. Systems Manager helps you maintain security and compliance by scanning these managed instances and reporting (or taking corrective action) on any violations it detects in your patch, configuration, and custom policies.

The AWS SRA uses [Session Manager](#), a capability of Systems Manager, to provide an interactive, browser-based shell and CLI experience. This provides secure and auditable instance management without the need to open inbound ports, maintain bastion hosts, or manage SSH keys. The AWS SRA uses [Patch Manager](#), a capability of Systems Manager, to apply patches to EC2 instances for both operating systems and applications.

The AWS SRA also uses [Automation](#), a capability of Systems Manager, to simplify common maintenance and deployment tasks of Amazon EC2 instances and other AWS resources.

Automation can simplify common IT tasks such as changing the state of one or more nodes (using an approval automation) and managing node states according to a schedule. Systems Manager includes features that help you target large groups of instances by using tags, and velocity controls that help you roll out changes according to the limits you define. Automation offers one-click automations for simplifying complex tasks such as creating golden Amazon Machine Images (AMIs) and recovering unreachable EC2 instances. Additionally, you can enhance operational security by giving IAM roles access to specific runbooks to perform certain functions, without directly giving permissions to those roles. For example, if you want an IAM role to have permissions to restart specific EC2 instances after patch updates, but you don't want to grant the permission directly to that role, you can instead create an Automation runbook and give the role permissions to only run the runbook.

Design considerations:

- Systems Manager relies on EC2 instance metadata to function correctly. Systems Manager can access instance metadata by using either version 1 or version 2 of the Instance Metadata Service (IMDSv1 and IMDSv2).
- SSM Agent has to communicate with different AWS services and resources such as Amazon EC2 messages, Systems Manager, and Amazon S3. For this communication to happen, the subnet requires either outbound internet connectivity or provisioning of appropriate VPC endpoints. The AWS SRA uses VPC endpoints for the SSM Agent to establish private network paths to various AWS services.
- Using Automation, you can share best practices with the rest of your organization. You can create best practices for resource management in runbooks and share the runbooks across AWS Regions and groups. You can also constrain the allowed values for runbook parameters. For these use cases, you might have to create Automation runbooks in a central account such as Security Tooling or Shared Services and share them with the rest of the AWS organization. Common use cases include the capability to centrally implement patching and security updates, remediate drift on VPC configurations or S3 bucket policies, and manage EC2 instances at scale. For implementation details, see the [Systems Manager documentation](#).

Amazon Aurora

In the AWS SRA, [Amazon Aurora](#) and [Amazon S3](#) make up the logical data tier. Aurora is a fully managed relational database engine that's compatible with MySQL and PostgreSQL. An application

that is running on the EC2 instances communicates with Aurora and Amazon S3 as needed. Aurora is configured with a database cluster inside a DB subnet group.

Design consideration:

- As in many database services, security for Aurora is managed at three levels. To control who can perform Amazon Relational Database Service (Amazon RDS) management actions on Aurora DB clusters and DB instances, you use IAM. To control which devices and EC2 instances can open connections to the cluster endpoint and port of the DB instance for Aurora DB clusters in a VPC, you use a VPC security group. To authenticate logins and permissions for an Aurora DB cluster, you can take the same approach as with a stand-alone DB instance of MySQL or PostgreSQL, or you can use IAM database authentication for Aurora MySQL-Compatible Edition. With this latter approach, you authenticate to your Aurora MySQL-Compatible DB cluster by using an IAM role and an authentication token.

Amazon S3

[Amazon S3](#) is an object storage service that offers industry-leading scalability, data availability, security, and performance. It is the data backbone of many applications built on AWS, and appropriate permissions and security controls are critical for protecting sensitive data. For recommended security best practices for Amazon S3, see the [documentation](#), [online tech talks](#), and deeper dives in [blog posts](#). The most important best practice is to block overly permissive access (especially public access) to S3 buckets.

AWS KMS

The AWS SRA illustrates the recommended distribution model for key management, where the AWS KMS key resides within the same AWS account as the resource to be encrypted. For this reason, AWS KMS is used in the Application account in addition to being included in the Security Tooling account. In the Application account, AWS KMS is used to manage keys that are specific to the application resources. You can implement a separation of duties by using [key policies](#) to grant key usage permissions to local application roles and to restrict management and monitoring permissions to your key custodians.

Design consideration:

- In a distributed model, the AWS KMS key management responsibility resides with the application team. However, your central security team can be responsible for the governance and [monitoring](#) of important cryptographic events such as the following:
 - The imported key material in a KMS key is nearing its expiration date.
 - The key material in a KMS key was automatically rotated.
 - A KMS key was deleted.
 - There is a high rate of decryption failure.

AWS CloudHSM

[AWS CloudHSM](#) provides managed hardware security modules (HSMs) in the AWS Cloud. It enables you to generate and use your own encryption keys on AWS by using FIPS 140-3 level 3 validated HSMs that you control access to. You can use AWS CloudHSM to offload SSL/TLS processing for your web servers. This reduces the burden on the web server and provides extra security by storing the web server's private key in AWS CloudHSM. You could similarly deploy an HSM from AWS CloudHSM in the inbound VPC in the Network account to store your private keys and sign certificate requests if you need to act as an issuing certificate authority.

Design consideration:

- If you have a hard requirement for FIPS 140-3 level 3, you can also choose to configure AWS KMS to use the AWS CloudHSM cluster as a custom key store rather than using the native KMS key store. By doing this, you benefit from the integration between AWS KMS and AWS services that encrypt your data, while being responsible for the HSMs that protect your KMS keys. This combines single-tenant HSMs under your control with the ease of use and integration of AWS KMS. To manage your AWS CloudHSM infrastructure, you have to employ a public key infrastructure (PKI) and have a team that has experience managing HSMs.

AWS Secrets Manager

[AWS Secrets Manager](#) helps you protect the credentials (*secrets*) that you need to access your applications, services, and IT resources. The service enables you to efficiently rotate, manage, and retrieve database credentials, API keys, and other secrets throughout their lifecycle. You can replace hardcoded credentials in your code with an API call to Secrets Manager to retrieve the secret programmatically. This helps ensure that the secret can't be compromised by someone who is examining your code, because the secret no longer exists in the code. Additionally, Secrets

Manager helps you move your applications between environments (development, pre-production, production). Instead of changing the code, you can ensure that an appropriately named and referenced secret is available in the environment. This promotes the consistency and reusability of application code across different environments, while requiring fewer changes and human interactions after the code has been tested.

With Secrets Manager, you can manage access to secrets by using fine-grained IAM policies and resource-based policies. You can help secure secrets by encrypting them with encryption keys that you manage by using AWS KMS. Secrets Manager also integrates with AWS logging and monitoring services for centralized auditing.

Secrets Manager uses [envelope encryption](#) with AWS KMS keys and data keys to protect each secret value. When you create a secret, you can choose any symmetric customer managed key in the AWS account and Region, or you can use the AWS managed key for Secrets Manager.

As a best practice, you can monitor your secrets to log any changes to them. This helps you ensure that any unexpected usage or change can be investigated. Unwanted changes can be rolled back. Secrets Manager currently supports two AWS services that enable you to monitor your organization and activity: AWS CloudTrail and AWS Config. CloudTrail captures all API calls for Secrets Manager as events, including calls from the Secrets Manager console and from code calls to the Secrets Manager APIs. In addition, CloudTrail captures other related (non-API) events that might have a security or compliance impact on your AWS account or might help you troubleshoot operational problems. These include certain secrets rotation events and deletion of secret versions. AWS Config can provide detective controls by tracking and monitoring changes to secrets in Secrets Manager. These changes include a secret's description, rotation configuration, tags, and relationship to other AWS sources such as the AWS KMS encryption key or the AWS Lambda functions used for secret rotation. You can also configure Amazon EventBridge, which receives configuration and compliance change notifications from AWS Config, to route particular secrets events for notification or remediation actions.

In the AWS SRA, Secrets Manager is located in the Application account to support local application use cases and to manage secrets close to their usage. Here, an instance profile is attached to the EC2 instances in the Application account. Separate secrets can then be configured in Secrets Manager to allow that instance profile to retrieve secrets—for example, to join the appropriate Active Directory or LDAP domain and to access the Aurora database. Secrets Manager [integrates with Amazon RDS](#) to manage user credentials when you create, modify, or restore an Amazon RDS DB instance or a Multi-AZ DB cluster. This helps you manage the creation and rotation of keys and replaces the hardcoded credentials in your code with programmatic API calls to Secrets Manager.

Design considerations:

- In general, configure and manage Secrets Manager in the account that is closest to where the secrets will be used. This approach takes advantage of the local knowledge of the use case and provides speed and flexibility to application development teams. For tightly controlled information where an additional layer of control might be appropriate, secrets can be centrally managed by Secrets Manager in the Security Tooling account.
- Secrets Manager supports hybrid post-quantum TLS using Module-Lattice-Based Key-Encapsulation Mechanism (ML-KEM) to protect secrets against harvest now, decrypt later (HNDL) attacks. You can use this TLS option when you connect to Secrets Manager API endpoints. This feature is automatically enabled in Secrets Manager Agent (version 2.0.0 or later), AWS Lambda extension (version 19 or later), and Secrets Manager CSI Driver (version 2.0.0 or later). However, because the performance characteristics and bandwidth requirements of hybrid cipher suites are different from those of classic key exchange mechanisms, we recommend that you test them on your API calls.

Amazon Cognito

[Amazon Cognito](#) lets you add user sign-up, sign-in, and access control to your web and mobile apps quickly and efficiently. Amazon Cognito scales to millions of users and supports sign-in with social identity providers, such as Apple, Facebook, Google, and Amazon, and enterprise identity providers through SAML 2.0 and OpenID Connect. The two main components of Amazon Cognito are [user pools](#) and [identity pools](#). User pools are user directories that provide sign-up and sign-in options for your application users. Identity pools enable you to grant your users access to other AWS services. You can use identity pools and user pools separately or together. For common usage scenarios, see the [Amazon Cognito documentation](#).

Amazon Cognito provides a built-in and customizable UI for user sign-up and sign-in. You can use Android, iOS, and JavaScript SDKs for Amazon Cognito to add user sign-up and sign-in pages to your apps. [AWS AppSync](#) is an AWS service and client library that enables cross-device syncing of application-related user data.

Amazon Cognito supports multi-factor authentication and encryption of data at rest and data in transit. Amazon Cognito user pools provide [advanced security features](#) to help protect access to user accounts in your application. These advanced security features provide risk-based adaptive authentication and protection from the use of compromised credentials.

Design considerations:

- You can create an AWS Lambda function and then trigger that function during user pool operations such as user sign-up, confirmation, and sign-in (authentication) with a Lambda trigger. You can add authentication challenges, migrate users, and customize verification messages. For common operations and user flow, see the [Amazon Cognito documentation](#). Amazon Cognito calls Lambda functions synchronously.
- You can use Amazon Cognito user pools to secure small, multi-tenant applications. A common use case of multi-tenant design is to run workloads to support testing multiple versions of an application. Multi-tenant design is also useful for testing a single application with different datasets, which allows full use of your cluster resources. However, make sure that the number of tenants and expected volume align with the related Amazon Cognito [service quotas](#). These quotas are shared across all tenants in your application.

Amazon Verified Permissions

[Amazon Verified Permissions](#) is a scalable permissions management and fine-grained authorization service for the applications that you build. Developers and administrators can use [Cedar](#), a purpose-built and security-first open-source policy language, with roles and attributes to define more granular, context-aware, policy-based access controls. Developers can build more secure applications faster by externalizing authorization and centralizing policy management and administration. Verified Permissions includes schema definitions, policy statement grammar, and [automated reasoning](#) that scale across millions of permissions, so you can enforce the principles of default deny and least privilege. The service also includes an evaluation simulator tool to help you test your authorization decisions and author policies. These features facilitate the deployment of an in-depth, fine-grained authorization model to support your [zero-trust](#) objectives. Verified Permissions centralizes permissions in a policy store and helps developers use those permissions to authorize user actions within their applications.

You can connect your application to the service through the API to authorize user access requests. For each authorization request, the service retrieves the relevant policies and evaluates those policies to determine whether a user is permitted to take an action on a resource, based on context inputs such as users, roles, group membership, and attributes. You can configure and connect Verified Permissions to send your policy management and authorization logs to AWS CloudTrail. If you use Amazon Cognito as your identity store, you can integrate with Verified Permissions and use the ID and access tokens that Amazon Cognito returns in the authorization decisions in your applications. You provide Amazon Cognito tokens to Verified Permissions, which uses the attributes that the tokens contain to represent the principal and identify the principal's entitlements.

For more information about this integration, see the AWS blog post [Simplifying fine-grained authorization with Amazon Verified Permissions and Amazon Cognito](#).

Verified Permissions helps you define policy-based access control (PBAC). PBAC is an access control model that uses permissions that are expressed as policies to determine who can access which resources in an application. PBAC brings together role-based access control (RBAC) and attribute-based access control (ABAC), resulting in a more powerful and flexible access control model. To learn more about PBAC and how you can design an authorization model by using Verified Permissions, see the AWS blog post [Policy-based access control in application development with Amazon Verified Permissions](#).

In the AWS SRA, Verified Permissions is located in the Application account to support permission management for applications through its integration with Amazon Cognito.

Layered defense

The Application account provides an opportunity to illustrate layered defense principals that AWS enables. Consider the security of the EC2 instances that make up the core of a simple example application represented in the AWS SRA and you can see the way AWS services work together in a layered defense. This approach aligns to the structural view of AWS security services, as described in the section [Apply security services across your AWS organization](#) earlier in this guide.

- The innermost layer is the EC2 instances. As mentioned earlier, EC2 instances include many native security features either by default or as options. Examples include [IMDSv2](#), the [Nitro system](#), and [Amazon EBS storage encryption](#).
- The second layer of protection focuses on the operating system and software running on the EC2 instances. Services such as [Amazon Inspector](#) and [AWS Systems Manager](#) enable you to monitor, report, and take corrective action on these configurations. Amazon Inspector [monitors your software for vulnerabilities](#) and Systems Manager helps you work to maintain security and compliance by scanning managed instances for their [patch](#) and [configuration status](#), and then reporting and taking any [corrective actions](#) you specify.
- The instances, and the software running on these instances, sit with your AWS networking infrastructure. In addition to using the [security features of Amazon VPC](#) the AWS SRA also makes use of VPC endpoints to provide private connectivity between the VPC and supported AWS services, and to provide a mechanism to place access policies at the network boundary.
- The activity and configuration of the EC2 instances, software, network, and IAM roles and resources are further monitored by AWS account-focused services such as AWS Security Hub

CSPM, AWS Security Hub, Amazon GuardDuty, AWS CloudTrail, AWS Config, IAM Access Analyzer, and Amazon Macie.

- Finally, beyond the Application account, AWS RAM helps control which resources are shared with other accounts, and IAM service control policies help you enforce consistent permissions across the AWS organization.

Multi-Region Architecture

Organizations are increasingly adopting AWS multi-Region security architectures to address critical business, regulatory, and operational requirements. Across the available AWS Regions and Availability Zones, customers in [human capital management \(HCM\)](#) sector (active-active high availability), [payment processing](#) (cross-Region failover for critical payment services to reduce RTO), [financial trading and market data](#) (cross-Region access to real-time global market data while meeting regional compliance), and [banking](#) (multi-country data platform managing 8.4 PB across geographic boundaries) demonstrate the breadth of multi-Region adoption drivers — from resilience and data sovereignty to global performance.

This chapter helps you determine whether an AWS multi-Region approach is necessary for your AWS Security Reference Architecture (AWS SRA) deployment and provides prescriptive recommendations for implementing it.

Important

Not every workload requires multi-Region. A well-architected multi-AZ deployment within a single Region already provides high availability for most scenarios. The drivers below describe the specific circumstances where extending to multiple AWS Regions becomes necessary.

Key drivers

Regulatory and compliance requirements

Data sovereignty and controlled replication

Data sovereignty refers to the legal requirement that data must be stored and processed within specific geographic boundaries. Regulations such as [General Data Protection Regulation](#) (GDPR) in the EU, the [UK Data Protection Act 2018](#) (UK GDPR post-Brexit), and Germany's [Bundesdatenschutzgesetz](#) (BDSG) impose constraints on where data can reside and how it can be replicated.

A common question arises: *Why does data sovereignty require multi-Region rather than simply operating in the single Region where data is captured?*

The answer lies in the intersection of sovereignty requirements and data resilience mandates. Many regulatory frameworks require not only that data stays within approved jurisdictions, but also that it is replicated for resilience, and that replication must itself remain within approved geographic boundaries. For example:

- A UK-based financial institution may be required to keep data within the UK and Ireland (eu-west-1 and eu-west-2), but not replicate it to Frankfurt or other EU regions. This creates a multi-Region requirement within a constrained geography.
- AWS has created [opt-in Regions](#) specifically to address data sovereignty. With opt-in Regions, customers must actively opt into a Region to make it possible for their data to be present there, making customer intent explicit. This ensures that customer data only gets replicated to the Regions they specify, with safeguards against unexpected replication to other Regions.
- For customers requiring stronger sovereignty guarantees, AWS supports client-side encryption as a prerequisite for cross-Region data replication. Even if data were inadvertently replicated to an unintended Region, the cryptographic materials would not exist in that Region, rendering the data undecryptable.

These constraints apply across regulated industries:

- **Healthcare and life sciences** – Healthcare providers and pharmaceutical companies must comply with regional data privacy regulations (such as the [Health Insurance Portability and Accountability ACT](#) (HIPAA) in the US and GDPR in the EU) that dictate where patient records and clinical data can reside. Electronic health record (EHR) platforms are typically deployed across multiple Availability Zones and multiple Regions within approved jurisdictions.
- **Financial services** – Financial regulators require institutions to maintain infrastructure across geographically separated locations within approved jurisdictions. This creates a multi-Region requirement where both primary and DR environments must remain within regulatory boundaries.
- **Automotive** – Connected vehicle platforms must comply with local data storage, sovereignty, and privacy requirements across multiple countries, using geo-location routing to connect millions of vehicles to the closest compliant cloud infrastructure.

Audit, compliance, and cross-jurisdictional data protection

Organizations operating across multiple jurisdictions must demonstrate to auditors and regulators that they can maintain operations and protect data without violating cross-border data transfer

restrictions. This is particularly relevant for European organizations subject to GDPR, where data from EU/EEA citizens must not flow to jurisdictions without adequate data protection frameworks unless specific legal mechanisms are in place.

Multi-Region deployment supports audit and compliance requirements in several ways:

- **Controlled data boundaries** – By deploying in specific Regions within approved jurisdictions, organizations can demonstrate to auditors that data never leaves the approved geography. AWS services like AWS Config, AWS CloudTrail, and AWS Security Hub provide continuous monitoring and audit trails across Regions.
- **Cross-border transfer controls** – Organizations prioritize digital sovereignty to ensure data is stored, processed, and managed in specific geographic regions in compliance with local laws. This includes requirements around data residency, control over encryption keys, and ensuring that sensitive information does not leave the designated jurisdiction. AWS helps meet these needs through Region-specific services and customer-managed KMS keys.
- **Multi-region governance** – Organizations require the flexibility to operate in multiple regions while maintaining consistent security, monitoring, and governance controls across environments. This includes clear auditability, transparency into data handling practices, and access to compliance documentation and certifications.

Business continuity (BC) and disaster recovery (DR)

The fundamental question arises: *If a single AWS Region already provides multiple Availability Zones with physical separation, why would I need multi-Region for DR?*

The [AWS Disaster Recovery whitepaper](#) states: "Remember that Availability Zones within an AWS Region are already designed with meaningful distance between them, and careful planning of location, such that most common disasters should only impact one zone and not the others. Therefore, a multi-AZ architecture within an AWS Region may already meet much of your risk mitigation needs."

However, multi-Region becomes necessary when:

- **Your disaster definition extends beyond a single data center or AZ** – For highly critical workloads, deploying infrastructure across multiple Regions with data replication and continuous backups minimizes business impact.
- **You need a bounded, predictable recovery time** – An [AWS Architecture blog post](#) states: "While a single Region supports highly available and resilient applications, distributing workloads

across multiple Regions enables a bounded recovery time in the rare event of a disruption to the application." Furthermore, "Each Region has strict logical and physical separation from other Regions. This purposeful design helps avoid service and infrastructure disruptions in one Region affecting another Region. This unique property of Regions can be used to build multi-Region applications with predictable fault domains."

- **Your RTO/RPO requirements demand it** – The four DR strategies offer different recovery profiles:

Strategy	RPO or RTO	Cost	Use case
Backup and restore	Hours	\$	Lower priority workloads
Pilot light	Tens of minutes	\$	Core services
Warm standby	Minutes	\$\$	Business critical services
Multi-site active/active	Near real time	\$\$	Mission critical, zero downtime

Fault isolation and event containment

AWS provides isolation at multiple levels:

- *Account-level isolation* provides resource and security boundaries between workloads. AWS recommends separating workloads using accounts to provide strong isolation boundaries for security, billing, and access.
- *Availability Zone isolation* helps protect against failures in other Availability Zones within the same Region, protecting against localized disasters, such as power outages or floods.
- *Region-level isolation* helps protect against failures in other Regions. Each AWS Region is physically and logically separated from other Regions. The physical and logical separation of AWS Regions provides a well-defined fault isolation boundary that you can use to create predictable fault boundaries for your own applications.

Account-level isolation protects against incidents spreading to other accounts within a Region. For example, a misconfiguration in one account does not affect another. However, a Regional disruption affects all accounts operating in that Region. Only Region-level isolation, achieved through multi-Region deployment, protects against disruptions that affect an entire region.

Performance and user experience

Reduced latency

Latency, the time it takes for data to travel between a user and the application, is fundamentally constrained by the speed of light across physical distance. A user in Tokyo accessing an application hosted exclusively in us-east-1 (Virginia) experiences significantly higher latency than one accessing the same application from a Region in Asia Pacific. Multi-Region deployment addresses this by placing compute, storage, and application logic closer to end users.

A single Region, even with multiple Availability Zones, serves users from one geographic location. For applications with a geographically distributed user base, this creates an inherent latency penalty for distant users that cannot be solved within a single Region. Multi-Region deployment, combined with intelligent routing, ensures that each user is served from the nearest infrastructure.

Enhanced availability

Enhanced availability in a multi-Region context means that users continue to experience uninterrupted service even when an entire AWS Region experiences an impairment. This goes beyond the high availability provided by multi-AZ deployments within a single Region.

A multi-AZ deployment within a single Region protects against the failure of individual Availability Zones. However, if the entire Region experiences a service disruption, all users served by that Region are affected. Multi-Region architectures provide an additional layer of availability by ensuring that if one region is impaired, traffic is automatically redirected to a healthy Region.

Global scale

For organizations serving customers across multiple continents, multi-Region deployment is not just about resilience. It's about delivering a consistent, high-quality experience regardless of where users are located. A single-Region deployment forces a trade-off. Users near the Region experience excellent performance, while users far away experience degraded performance. Multi-Region deployment eliminates this trade-off.

Global scale requires more than just handling high traffic volumes (which can be achieved within a single Region through horizontal scaling). It requires geographic distribution of the application stack so that users in different parts of the world receive comparable response times. This is particularly critical for:

- Global SaaS platforms where customers expect equivalent service levels across Regions
- Real-time applications (such as gaming, video conferencing, and financial trading) where even small latency differences create unfair or degraded experiences
- Connected devices and Internet of Things (IoT) (such as connected vehicles and industrial IoT), where millions of devices across geographies need low-latency access to cloud services

Decision framework for multi-Region deployment

To help you decide whether you need multi-Region, consider the following decision framework.

Question	If yes	If no
Do regulations require data replication within approved geographic boundaries?	Multi-Region within approved jurisdictions	Single Region may suffice
Does your industry regulator mandate geographically separated DR?	Multi-Region required	Multi-AZ may suffice
Must you demonstrate to auditors that data never leaves specific jurisdictions while maintaining DR?	Multi-Region within boundaries	Single Region with multi-AZ
Is your RTO requirement under 30 minutes for critical workloads?	Consider warm standby or active/active multi-Region	Pilot light or backup and restore may suffice
Does your disaster definition include full regional disruption?	Multi-Region required	Multi-AZ within single Region

Do you need protection against correlated regional failures (not just AZ failures)?	Multi-Region required	Multi-AZ provides sufficient isolation
Do you serve users across multiple continents with latency-sensitive applications?	Multi-Region active-active recommended	CloudFront edge caching with a single Region may suffice
Do you need consistent performance for real-time applications globally?	Full multi-Region active-active	Centralized backend with intelligent routing

Important

For most workloads, a well-architected multi-AZ deployment within a single Region provides sufficient resilience. Each Region's Availability Zones are physically separated and designed so that most common disasters impact only one zone. Multi-Region introduces additional infrastructure management, data synchronization, and application design, along with higher costs from cross-Region data transfer and duplicate infrastructure. Organizations should treat multi-Region as a deliberate decision driven by specific drivers, not as a default starting point. If none of the conditions in this decision framework apply, start with multi-AZ and revisit as requirements evolve.

Multi-Region deployment approach

This section of AWS Security Reference Architecture (AWS SRA) provides holistic guidelines for deploying AWS security services in a multi-account, multi-Region environment. This guidance helps you:

- Design security service deployments across multiple Regions
- Understand deployment ordering and dependencies
- Navigate Regional availability constraints
- Implement proper delegation models
- Maintain visibility and protection across your distributed environment

Foundational prerequisites

Before expanding to additional Regions, the following must be in place:

Prerequisite	Detail (common)	Detail (AWS Control Tower)	Detail (AWS Organizations only)
Landing zone or organization home Region established	The home region cannot be changed after initial setup. Additional Regions must be explicitly enabled and governed.	Selected during landing zone setup. Additional Regions are added through <code>enableRegions</code> and enrolled in AWS Control Tower.	Selected during creation of your organization. Additional Regions are governed by enabling them in account settings and deploying SCPs/RCPs to target OUs.
Region deny SCPs deployed	Attach at OU level to restrict unauthorized Regions. Define allowed Regions, exempt global services, and exempt break-glass roles. Test in a sandbox OU first.	Apply managed control <code>CT.MULTISERVICE.PV.1</code> . Configure <code>AllowedRegions</code> , <code>ExemptedPrincipalARNs</code> , and <code>ExemptedActions</code> parameters.	Create a custom SCP with explicit deny by using the <code>aws:RequestedRegion</code> condition key. Define allowed Regions in the condition block.
Global service exemptions in SCPs	Ensure Region deny SCPs exempt: IAM, AWS Organizations, CloudFront, Route 53, Shield, AWS STS, AWS Support, AWS Budgets, and Cost Explorer.	—	—
AWS KMS multi-Region keys replicated	Multi-Region KMS keys must be	—	—

replicated to every governed Region before enrolling Regions. IAM Identity Center multi-Region replication requires a multi-Region customer-managed KMS key.

AWS Config enabled everywhere

AWS Config recorder must be active in every account and every activated Region, including the management account.

Requires separate sra-config-management-account solution for the management account.

Deploy via CloudFormation StackSets from the management account or a delegated administrator. Include the management account using a separate stack or self-managed stack set.

Region deny resource control policies (RCPs)

Deploy RCPs at the OU level to complement SCPs with resource-level Region restrictions. RCPs control what resources can do, not just what principals can do.

Not natively managed by AWS Control Tower. Deploy through Organizations directly or through Customizations for Control Tower (CfCT).

Manage directly in the Organizations console, AWS CLI, or through IaC tools such as CloudFormation

SCP management model	Use a deny-list model with FullAWSAccess as the default allow.	Do not manually edit CT-managed SCPs. Use CfCT or AFC for custom policies. CT-managed SCPs have a 2,048-character limit per SCP.	Manage SCPs directly in Organizations console, AWS CLI, or through IaC. Up to 5 SCPs per OU attachment, and 5,120 characters per SCP.
Governance automation	Automate SCP/RCP deployment across OUs and Regions. Implement drift detection.	Use CfCT or Landing Zone Accelerator (LZA). AWS Control Tower provides built-in drift detection for managed controls.	Use CloudFormation StackSets, Terraform, or Organizations APIs. Implement custom drift detection via AWS Config rules or AWS Lambda.

Operational recommendations

- **Deploy one Region at a time, validate before proceeding** – Reduces impact scope and simplifies troubleshooting. Complete validation of all phases in one Region before starting the next.
- **Verify service quotas match across all target Regions** – Quotas are per-Region and do not automatically replicate.
- **Test Region deny SCPs in a sandbox OU** – Misconfigured deny policies can lock out access to existing resources. Always validate in a sandbox OU first.
- **Automate through CloudFormation StackSets** – Ensures consistent deployment across accounts and Regions by using AWS SRA code library templates.
- **Implement AWS Config conformance packs per Region** – Provides automated compliance validation in each Region independently.
- **Establish a runbook for adding new Regions** – Consider dependencies between services
- **Protect critical configurations via SCPs** – Deny deletion or modification of CloudTrail, AWS Config, IAM Access Analyzer, and KMS keys.

- **Account for GovCloud gaps** – AWS Security Incident Response and Amazon Macie are absent in GovCloud. Use AWS Systems Manager Incident Manager and manual classification as alternatives.

Amazon GuardDuty

[Amazon GuardDuty](#) is a fully managed, continuous security threat detection service for your AWS environment. It utilizes machine learning, anomaly detection, and integrated threat intelligence to automatically analyze AWS logs and data to identify unauthorized activity, malicious behavior, and data compromises. For architectural best practices, refer to the [Amazon GuardDuty](#) section in this guide.

Multi-Region considerations

When working with Amazon GuardDuty you must consider that it is a regional service. This means that for every Region in which you deploy the GuardDuty detector, you must do the following actions:

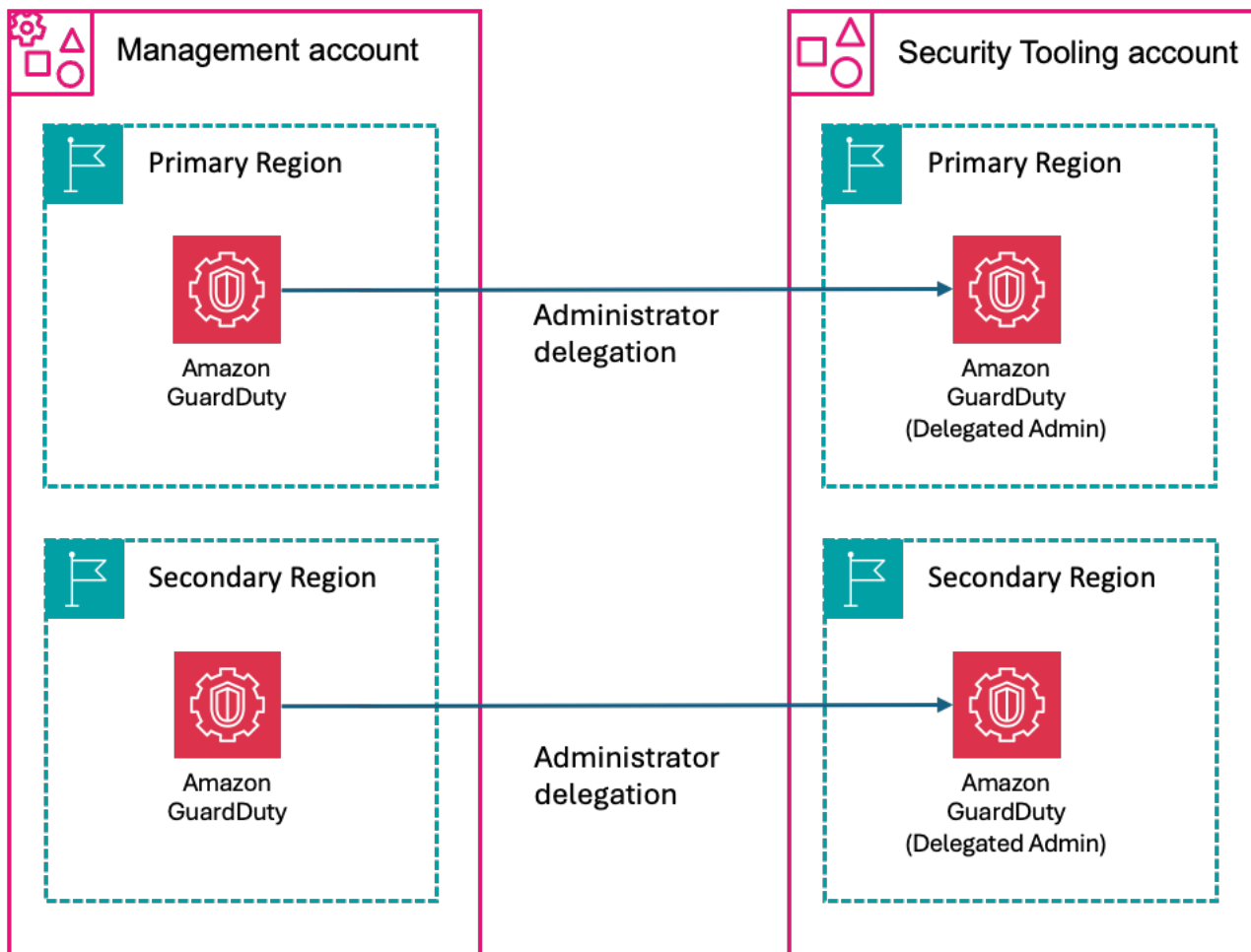
1. Enable GuardDuty in each Region in the management account.
2. Designate the delegate admin to the Security Tooling account (in the Security OU).
3. Ensure that the GuardDuty detector is enabled for all member accounts, foundational data sources are enabled, and protection plans are in place.

When working in multi-Regional deployment in GuardDuty you must aggregate all findings in a centralized bucket following AWS best practices. This bucket is deployed in the Log Archive account in the Region selected as primary. To centralize GuardDuty findings, you must set the centralized bucket in each of the detectors of the delegated admin account as the target for the findings.

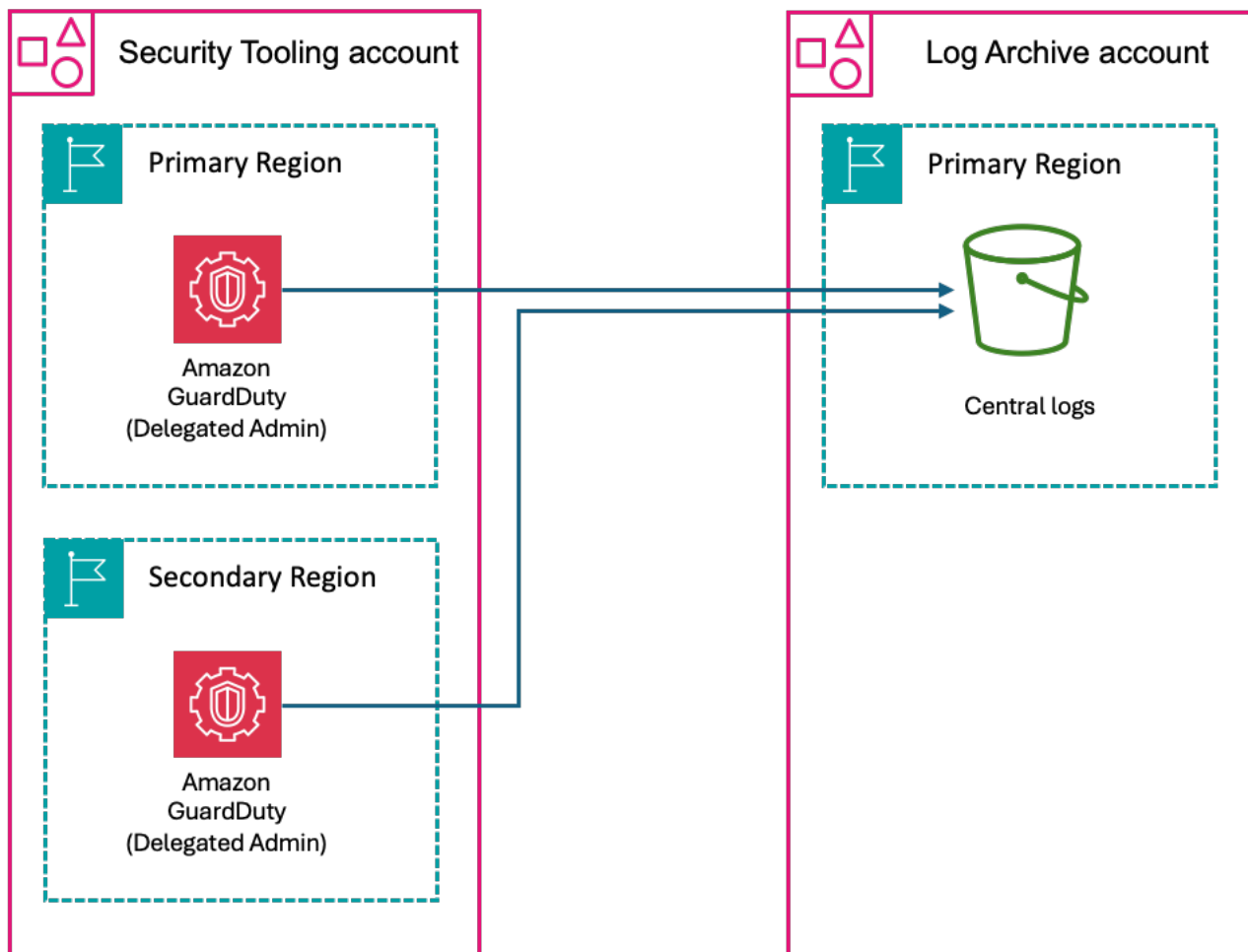
Architecture

The following diagrams show the configuration needed for the multi-Region delegated administration set up and the configuration for finding centralization in the primary Region.

The following image shows a Multi-Region delegated architecture.



The following image shows a finding aggregation architecture.



Amazon Inspector

[Amazon Inspector](#) is a fully managed, automated vulnerability management service. It continuously scans AWS workloads for software vulnerabilities (CVEs), unintended network exposures, and insecure configurations. For architectural best practices, refer to the [Amazon Inspector](#) section in this guide.

Multi-Region considerations

When working with Amazon Inspector, you must consider that it is a Regional service. This means that for every Region in which you deploy workloads, you should perform the following actions:

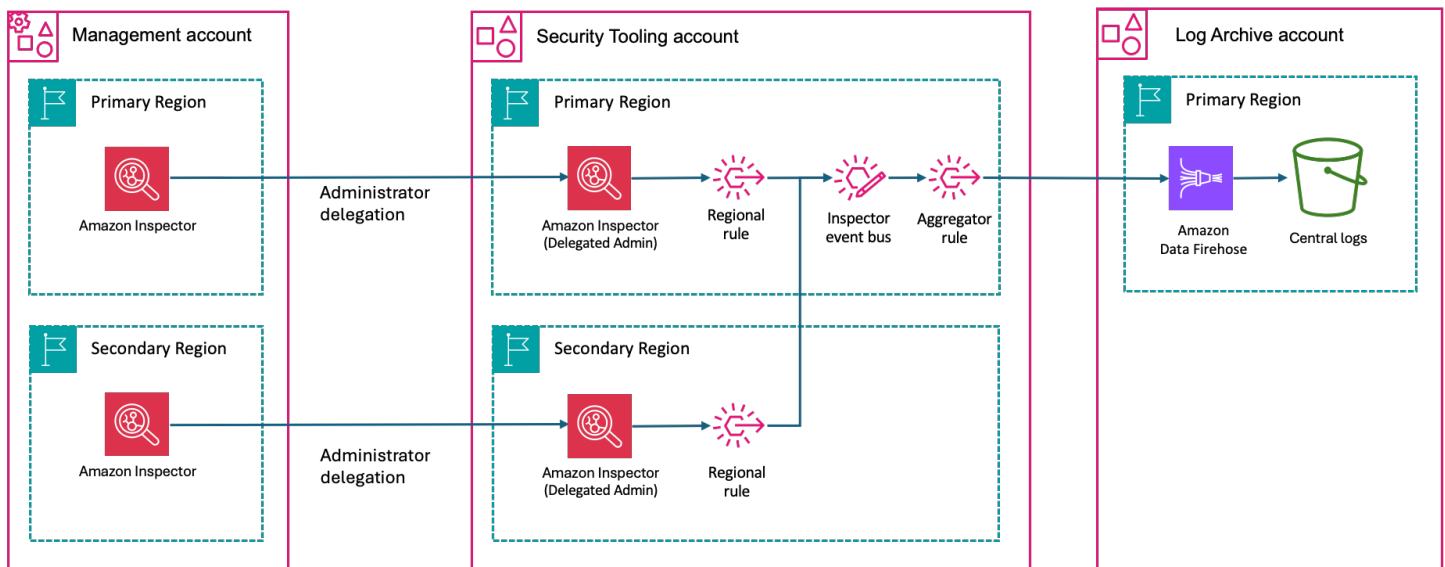
1. Enable Amazon Inspector in each Region in the management account.
2. Designate the delegate admin to the Security Tooling account (in the Security OU).

3. Ensure that Amazon Inspector is enabled for all member accounts and new accounts, and that all scans are activated.

When working in multi-Regional deployment in Amazon Inspector you must aggregate all findings in a centralized bucket to follow AWS best practices. This bucket is deployed in the Log Archive account in the Region selected as primary. To centralize Amazon Inspector findings, you must create an Amazon EventBridge rule in each of the Regions of the security tooling account to capture all aggregated findings per Region. Rules deployed in non-primary Regions should point to an event bus in the primary Region. This bus serves as an aggregator of all the findings. A last EventBridge rule (aggregator rule) should point to an Amazon Data Firehose in the Log Archive account in the primary Region. This Firehose stream has the centralized logging bucket as a destination. This allows Amazon Inspector to aggregate findings for all Regions and accounts in your AWS organization.

Architecture

The following diagram shows the high-level architecture of the delegated administrator configuration and the finding aggregation architecture.



AWS CloudTrail

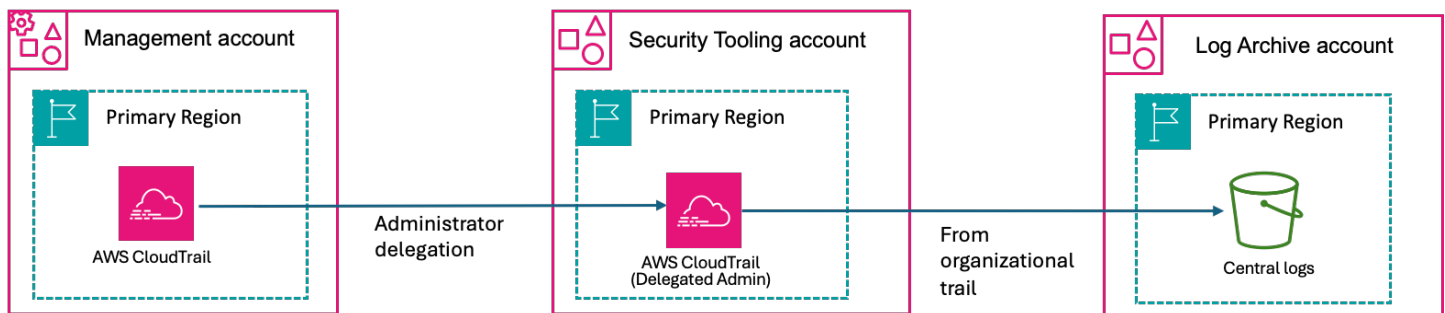
[AWS CloudTrail](#) is a managed governance, compliance, and auditing service. It automatically records and logs every API call made across your AWS account. For architectural best practices, refer to the [AWS CloudTrail](#) section in this guide.

Multi-Region considerations

The [AWS SRA best practices for CloudTrail](#) states that a multi-Region organizational trail should be created and configured to deliver all CloudTrail management events from the management account and all member accounts. With this organizational trail, all management events in all Regions from all the accounts are captured so there is no additional configuration needed. The organizational trail should be created in the primary Region of your AWS organization.

Architecture

The following diagram shows the high-level architecture of the CloudTrail configuration and event aggregation in a multi-account environment for the primary Region.



AWS Config

AWS Config provides a detailed view of the configuration of AWS resources in your AWS account. This includes how the resources are related to one another and how they were configured in the past so that you can see how the configurations and relationships change over time. For architectural best practices, refer to the [AWS Config](#) section in this guide.

Multi-Region considerations

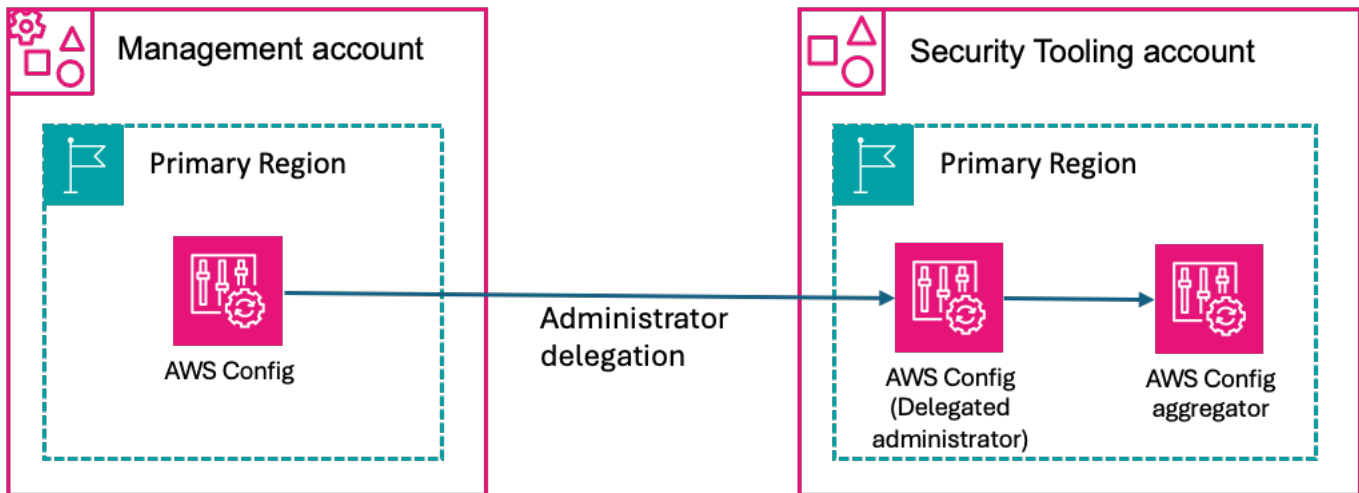
As described in [AWS SRA best practices for AWS Config](#), the recorder should be deployed in all accounts and Regions, and the organization aggregator should be configured as multi-Region. With this configuration, the multi-Region requirement is already met as AWS Config will track resources from all Regions in all accounts. These recorded changes are aggregated in the organizational aggregator for further analysis. This recorder is deployed in the delegated administrator account for AWS Config, which would be the Security Tooling account.

Additionally, you should configure the config findings of aggregation to a centralized bucket in the primary Region in the Logging Account. Each recorder in every account and Region must be configured to use the centralized bucket as the target for config logs.

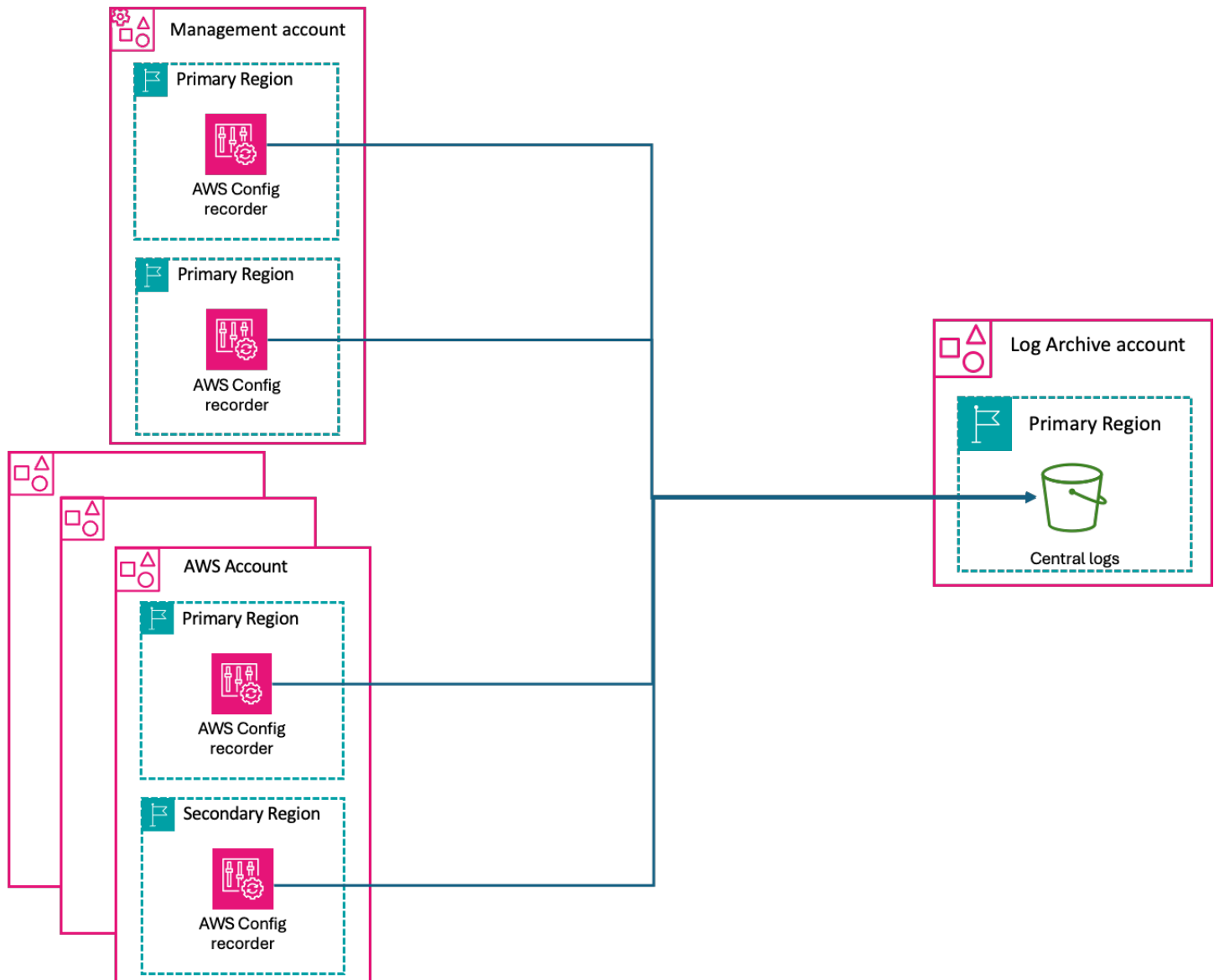
Architecture

The following diagrams show the high-level overview of the delegated administrator, the aggregator, and the recorder log centralization configuration.

Delegated administrator and aggregator configuration:



Log centralization configuration:



IAM Access Analyzer

[AWS Identity and Access Management Access Analyzer](#) is an automated reasoning tool that helps security and operations teams implement the principle of least privilege. It continuously evaluates your AWS environment to identify unintended public or cross-account exposure, map internal access, and pinpoint unused permissions. For architectural best practices, refer to the [IAM Access Analyzer](#) section in this guide.

Multi-Region considerations

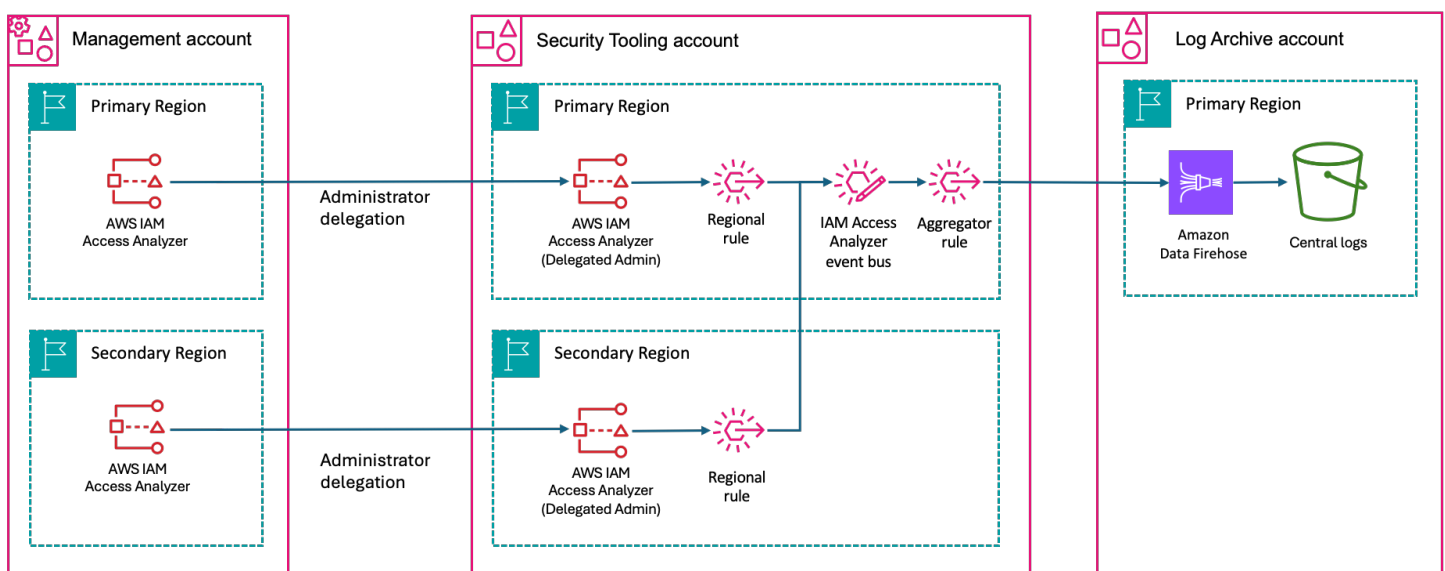
When working with IAM Access Analyzer, you must consider that it is a Regional service. This means that for every Region in which you deploy workloads, you should perform the following actions:

1. Enable IAM Access Analyzer in each region in the management account.
2. Designate the delegate admin to the Security Tooling account (in the Security OU).
3. Ensure that analyzers (external, internal, and unused) are enabled for all member accounts.

When working in multi-Regional deployment in IAM Access Analyzer, you must aggregate all findings in a centralized bucket to follow AWS best practices. This bucket is deployed in the Log Archive account in the Region selected as primary. To centralize IAM Access Analyzer findings, you must create an Amazon EventBridge rule in each of the Regions of the Security Tooling account to capture all aggregated findings per Region. Rules deployed in non-primary Regions should point to an event bus in the primary Region. This bus serves as an aggregator of all the findings. A last EventBridge rule (aggregator rule) should point to Amazon Data Firehose in the Log Archive account in the primary Region. This Firehose stream will have the centralized logging bucket as a destination, enabling IAM Access Analyzer finding aggregation for all Regions and accounts in your AWS organization.

Architecture

The following diagram shows the high-level architecture of the delegated administrator configuration and the finding aggregation architecture.



IAM Identity Center

[AWS IAM Identity Center](#) is the recommended service for centrally managing single sign-on (SSO) access to multiple AWS accounts and cloud applications. It allows you to securely connect your existing corporate directory or create users natively, providing your team with one portal to access all their assigned resources. For architectural best practices, refer to the [AWS IAM Identity Center](#) section in the *AWS Security Reference Architecture (AWS SRA) – identity management* guide.

Multi-Region considerations

IAM Identity Center supports multi-Region by replicating workforce identities, permission sets, and other metadata in your organization instance of IAM Identity Center connected to an external identity provider (IdP), such as Microsoft Entra ID and Okta, from its current primary Region to additional Regions. You can deploy AWS managed applications in your preferred Regions, close to application users and datasets for improved user experience or to meet data residency requirements. Your applications deployed in additional Regions access replicated workforce identities locally for optimal performance and reliability. When you replicate your workforce identities to an additional Region, your workforce gets an active AWS access portal endpoint in that Region. This means that in the unlikely event of an IAM Identity Center service disruption in its primary Region, your workforce can still access their AWS accounts through the AWS access portal in an additional Region by using already provisioned permissions. You can continue to manage IAM Identity Center configurations from the primary Region, maintaining centralized control.

Replicating IAM Identity Center to additional AWS Regions provides two key benefits:

- **Improved resiliency of AWS account access** – Your workforce can access their AWS accounts even if the IAM Identity Center instance experiences a service disruption in its primary Region.
- **Enhanced flexibility in choosing deployment Regions for AWS managed applications** – You can deploy AWS managed applications in your preferred Regions to meet application data residency requirements and improve performance through proximity to users. Applications deployed in additional Regions to access replicated workforce identities locally for optimal performance and reliability.

The replication is asynchronous, meaning that changes in the primary Region are not replicated in real time to the secondary Region.

There are some prerequisites:

- Multi-Region is only available on organization instances.
- Your identity source must be an external IdP, such as Okta.
- Your instance must be encrypted with a multi-region customer managed KMS key in the same account.
- Your IdP must support multiple SAML ACS URLs

Design consideration:

- When choosing an additional Region, pick one geographically distant from your primary for maximum resiliency so if the primary Region goes down; a distant Region is unlikely to be affected by the same disruption. If data residency or compliance drives the decision, choose the Region where your regulated datasets live. Where neither constraint applies, choose the Region closest to your users. Before finalizing, confirm that the AWS managed applications your organization uses are available in that Region.

Architecture

For the multi-Region set up process, refer to the [IAM Identity Center documentation](#).

AWS Security Hub

[AWS Security Hub](#) is a unified cloud security and compliance service that aggregates, normalizes, and prioritizes security alerts across your AWS accounts, Regions, and third-party tools. It serves as a central dashboard to streamline compliance management and automate incident response. For architectural best practices, see [Introduction to AWS Security Hub](#).

Multi-Region considerations

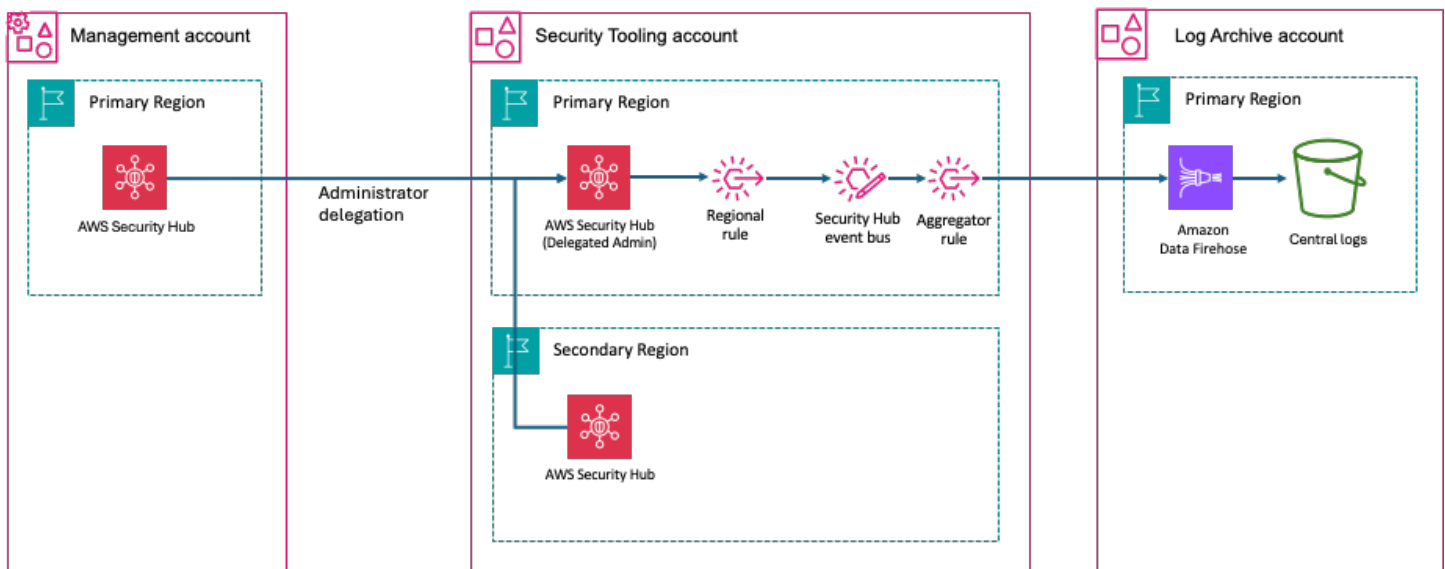
When working with AWS Security Hub, you must consider that it is a Regional service. This means that for every Region in which you deploy workloads you should perform the following actions:

1. Enable Security Hub in the management account in the home Region.
2. Designate the delegated admin to the Security Tooling account (in the Security OU).
3. Enable Security Hub for all member accounts across all active Regions.

When working in multi-Regional deployment with AWS Organizations integration, Security Hub natively aggregates all findings, resources, and trends from all member accounts and all linked Regions into the delegated administrator's home Region via [cross-Region aggregation](#). Security Hub has a built-in cross-Region aggregation feature. This means findings, resources and trends from each Region in each member account are sent directly to the delegated administrator's home Region. There is no need for EventBridge rules in each Region to aggregate findings. In addition to new data, Security Hub also replicates updates to data between the linked Regions and the home Region. Updates that occur in a linked Region are replicated to the home Region. Updates that occur in the home Region are replicated back to the linked Region. If there are conflicting updates in the home Region and the linked Region, then the most recent update is used. To centralize findings in a logging bucket to follow AWS best practices, you only need to create a single EventBridge rule in the delegated administrator's home region to capture all aggregated findings. This rule should point to Amazon Data Firehose in the Log Archive account in the primary Region. This Firehose stream has the centralized logging bucket as a destination, enabling Security Hub finding aggregation for all Regions and accounts in your AWS organization.

Architecture

The following diagram shows the high-level architecture of the delegated administrator configuration and the finding aggregation architecture.



AWS Security Hub CSPM

AWS Security Hub CSPM continuously audits your AWS environment against security best practices, evaluates compliance, and identifies misconfigurations. For architectural best practices, see [Introduction to AWS Security Hub CSPM](#).

Multi-Region considerations

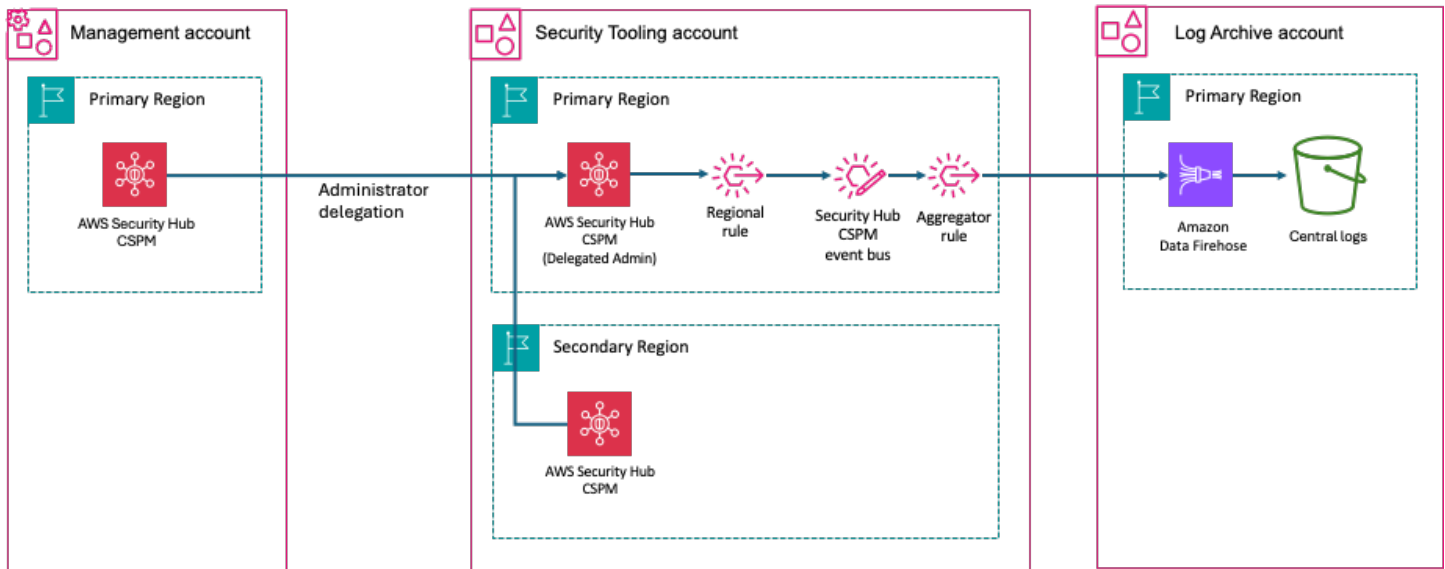
When working with Security Hub CSPM, you must consider that it is a Regional service. This means that for every Region in which you deploy workloads, you should perform the following actions:

1. Enable Security Hub CSPM in the management account in the home Region.
2. Designate the delegated admin to the Security Tooling account (in the Security OU).
3. Enable [central configuration](#) from the delegated administrator account. This allows the delegated administrator to configure Security Hub CSPM settings (standards, controls, and enablement) across multiple accounts, OUs, and Regions from the home region.
4. Create configuration policies from the delegated administrator account to enforce standards and controls across all centrally managed accounts and Regions.
5. Configure cross-Region aggregation in the delegated administrator account by designating a home Region and linking all other active Regions. This aggregates findings, insights, control compliance statuses, and security scores from all linked Regions and all member accounts into the delegated administrator's home region.

When working in multi-Regional deployment with AWS Organizations integration, Security Hub CSPM natively aggregates all findings from all member accounts and all linked Regions into the delegated administrator's home region via cross-Region aggregation. Unlike other AWS services, Security Hub CSPM has a built-in cross-Region aggregation feature. This means findings from each Region in each member account are sent directly to the delegated administrator's home Region. There is no intermediate aggregation step in the management account and no need for EventBridge rules in each Region to aggregate findings. To centralize findings in a logging bucket to follow AWS best practices, you only need to create a single Amazon EventBridge rule in the delegated administrator's home Region to capture all aggregated findings. This rule should point to Amazon Data Firehose in the Log Archive account in the primary Region. This Firehose stream has the centralized logging bucket as a destination, enabling Security Hub CSPM finding aggregation for all Regions and accounts in your AWS organization.

Architecture

The following diagram shows the high-level architecture of the delegated administrator configuration, cross-Region aggregation, and the finding centralization architecture. Security Hub CSPM has a native cross-Region aggregation feature. All findings from all linked Regions flow natively to the home Region.



AWS Backup

AWS Backup is a fully managed, policy-based service that centralizes and automates data protection across AWS services and hybrid environments. It eliminates the need for custom backup scripts or manual processes, allowing you to easily configure backup policies, retention schedules, and compliance monitoring from a single place.

AWS Backup cross-account management provides two distinct delegated capabilities. The first is cross-account jobs monitoring, which is configured in the AWS Backup console and allows the delegated administrator to monitor backup, restore, and copy jobs across all member accounts in the organization. The second is backup policy management, which is configured separately in the AWS Organizations console (delegated administrator for AWS Organizations) and allows the delegated admin to create, modify, delete, attach, and detach backup policies across the organization. To delegate both capabilities to a member account, a two-step process is required. First registering the account in the AWS Backup console and then delegating policy permissions through the AWS Organizations console.

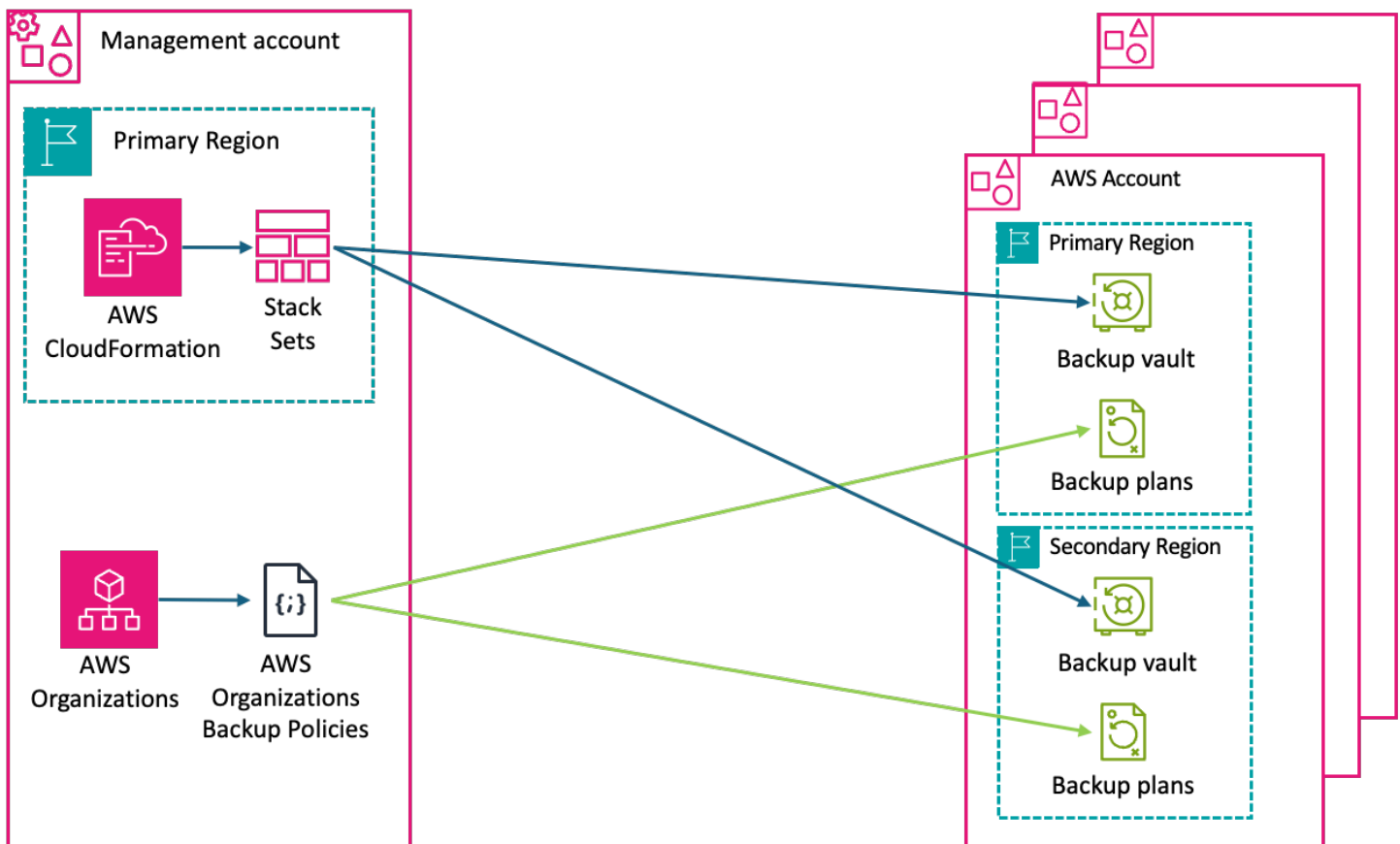
You must delegate the administrator account for monitoring features just in one Region, and it will be activated in all of the active Regions.

Multi-Region considerations

In AWS Backup you must consider that some of the resources involved are Regional (like backup plans and vaults), but Organizations backup policies are global. Delegating the administrator account for cross-account monitoring in one Region activates it across all active Regions. For more information, see the [AWS SRA best practices checklist](#).

Architecture

The following diagram shows a high-level overview of the AWS Backup architecture and deployment for a multi-Region environment.



There are two flows:

- **Deploy AWS Backup vaults** – For this task you can rely on AWS CloudFormation stack sets to deploy AWS Backup vaults in the selected Regions. For more information, see [Managing stacks across accounts and Regions with StackSets](#).

- **Deploy AWS Backup policies** – AWS Organizations backup policies will allow you to deploy backup plans at scale in all AWS accounts and Regions in your organization. In these backup plans, you set up the main AWS Backup vault and the cross-Region action to the secondary AWS Backup vault. For more information, see [Backup policies](#) in the Organizations documentation.

AI/ML for security

Artificial intelligence and machine learning (AI/ML) is transforming businesses. AI/ML has been a focus for Amazon for over 20 years, and many of the capabilities customers use with AWS, including security services, are driven by AI/ML. This creates a built-in differentiated value, because you can build securely on AWS without requiring your security or application development teams to have expertise in AI/ML.

AI is an advanced technology that allows machines and systems to gain intelligence and prediction capability. AI systems learn from past experience through data that it consumes or is trained on. ML is one of the most important aspects of AI. ML is the ability of computers to learn from data without being explicitly programmed. In traditional programming, the programmer writes rules that define how the program should work on a computer or machine. In ML, the model learns the rules from data. ML models can discover hidden patterns in the data or make accurate predictions on new data that weren't used during training. Multiple AWS services use AI/ML to learn from huge datasets and make security inferences.

- [Amazon Macie](#) is a data security service that uses ML and pattern matching to discover and help protect your sensitive data. Macie automatically detects a large and growing list of sensitive data types, including personally identifiable information (PII) such as names, addresses, and financial information such as credit card numbers. It also gives you constant visibility into your data that's stored in Amazon Simple Storage Service (Amazon S3). Macie uses natural language processing (NLP) and ML models that are trained on different types of datasets to understand your existing data and to assign business values to prioritize business-critical data. Macie then generates [sensitive data findings](#).
- [Amazon GuardDuty](#) is a threat detection service that uses ML, anomaly detection, and integrated threat intelligence to continuously monitor for malicious activity and unauthorized behavior to help protect your AWS accounts, instances, serverless and container workloads, users, databases, and storage. GuardDuty incorporates ML techniques that are highly effective at discerning potentially malicious user activity from anomalous but benign operational behavior within AWS accounts. This capability continuously models API invocations within an account and incorporates probabilistic predictions to more accurately isolate and alert on highly suspicious user behavior. This approach helps identify malicious activity associated with known threat tactics, including discovery, initial access, persistence, privilege escalation, defense evasion, credential access, impact, and data exfiltration. To learn more about how GuardDuty uses machine learning, see

the AWS re:Inforce 2023 breakout session [Developing new findings using machine learning in Amazon GuardDuty \(TDR310\)](#).

Provable security

AWS develops automated reasoning tools that use mathematical logic to answer critical questions about your infrastructure and to detect misconfigurations that could potentially expose your data. This capability is called *provable security* because it provides higher assurance in the security of the cloud and in the cloud. Provable security uses automated reasoning, which is a specific discipline of AI that applies logical deduction to computer systems. For example, automated reasoning tools can analyze policies and network architecture configurations, and prove the absence of unintended configurations that could potentially expose vulnerable data. This approach provides the highest level of assurance possible for the critical security characteristics of the cloud. For more information, see [Provable Security Resources](#) on the AWS website. The following AWS services and features currently use automated reasoning to help you achieve provable security for your applications:

- [Amazon Verified Permissions](#) is a scalable permissions management and fine-grained authorization service for the applications that you build. Verified Permissions uses [Cedar](#), which is an open-source language for access control that was built by using automated reasoning and differential testing. Cedar is a language for defining permissions as policies that describe who should have access to which resources. It is also a specification for evaluating those policies. Use Cedar policies to control what each user of your application is permitted to do and which resources they may access. Cedar policies are *permit* or *forbid* statements that determine whether a user can act on a resource. Policies are associated with resources, and you can attach multiple policies to a resource. *Forbid* policies override *permit* policies. When a user of your application attempts to perform an action on a resource, your application makes an authorization request to the Cedar policy engine. Cedar evaluates the applicable policies and returns an ALLOW or DENY decision. Cedar supports authorization rules for any type of principal and resource, allows for role-based and attribute-based access control, and supports analysis through automated reasoning tools that can help optimize your policies and validate your security model.
- [AWS Identity and Access Management Access Analyzer](#) helps you streamline permissions management. You can use this feature to set fine-grained permissions, verify intended permissions, and refine permissions by removing unused access. IAM Access Analyzer generates a fine-grained policy based on the access activity captured in your logs. It also provides over 100 policy checks to help you author and validate your policies. IAM Access Analyzer uses provable

security to analyze access paths and provide comprehensive findings for public and cross-account access to your resources. This tool is built on [Zelkova](#), which translates IAM policies into equivalent logical statements and runs a suite of general-purpose and specialized logical solvers (satisfiability modulo theories) against the problem. IAM Access Analyzer applies Zelkova repeatedly to a policy with increasingly specific queries to characterize classes of behaviors the policy allows, based on the content of the policy. The analyzer doesn't examine access logs to determine whether an external entity accessed a resource within your zone of trust. It generates a finding when a resource-based policy allows access to a resource, even if the resource wasn't accessed by the external entity. To learn more about satisfiability modulo theories, see [Satisfiability Modulo Theories](#) in *Handbook of Satisfiability*.*

- [Amazon S3 Block Public Access](#) is a feature of Amazon S3 that allows you to block possible misconfigurations that could lead to public access of your buckets and objects. You can enable Amazon S3 Block Public Access for access points, buckets, accounts, and the AWS organization (which affects both existing and new buckets in the account). Public access is granted to buckets and objects through access control lists (ACLs), bucket policies, or both. The determination of whether a given policy or ACL is considered public is made by using the Zelkova automated reasoning system. Amazon S3 uses Zelkova to check each bucket policy and warns you if an unauthorized user is able to read or write to your bucket. If a bucket is flagged as public, some public requests are allowed to access the bucket. If a bucket is flagged as not public, **all** public requests are denied. Zelkova is able to make such determinations because it has a precise mathematical representation of IAM policies. It creates a formula for each policy and proves a theorem about that formula.
- [Amazon VPC Network Access Analyzer](#) is a feature of Amazon VPC that helps you understand potential network paths to your resources, and identifies potential unintended network access. Network Access Analyzer helps you verify network segmentation, identify internet accessibility, and verify trusted network paths and network access. This feature uses automated reasoning algorithms to analyze the network paths that a packet can take between resources in an AWS network. It then produces findings for paths that match your Network Access Scopes, which define outbound and inbound traffic patterns. Network Access Analyzer performs a static analysis of a network configuration, meaning that no packets are transmitted in the network as part of this analysis.
- [Amazon VPC Reachability Analyzer](#) is a feature of Amazon VPC that lets you debug, understand, and visualize connectivity in your AWS network. Reachability Analyzer is a configuration analysis tool that enables you to perform connectivity testing between a source resource and a destination resource in your virtual private clouds (VPCs). When the destination is reachable, Reachability Analyzer produces hop-by-hop details of the virtual network path between the

source and the destination. When the destination isn't reachable, Reachability Analyzer identifies the blocking component. Reachability Analyzer uses automated reasoning to identify feasible paths by building a model of the network configuration between a source and destination. It then checks for reachability based on the configuration. It doesn't send packets or analyze the data plane.

* Biere, A. M. Heule, H. van Maaren, and T. Walsh. 2009. *Handbook of Satisfiability*. IOS Press, NLD.

Building your security architecture – a phased approach

The multi-account security architecture recommended by the AWS SRA is a baseline architecture to help you inject security early into your design process. Each organization's cloud journey is unique. To successfully evolve your cloud security architecture, you need to envision your desired target state, understand your current cloud readiness, and adopt an agile approach to close any gaps. The AWS SRA provides a reference target state for your security architecture. Transforming incrementally enables you to demonstrate value quickly while minimizing the need to make far-reaching predictions.

The [AWS Cloud Adoption Framework](#) (AWS CAF) recommends four iterative and incremental cloud transformation phases: [envision, align, launch, and scale](#). As you enter the launch phase and focus on delivering pilot initiatives in production, you should focus on building a strong security architecture as a foundation for the scale phase so that you have the technical ability to migrate and operate your most business-critical workloads with confidence. This phased approach is applicable if you are a startup, a small or medium company that wants to expand their business, or an enterprise that's acquiring new business units or undergoing mergers and acquisitions. The AWS SRA helps you achieve that security baseline architecture so that you can apply security controls uniformly across your expanding organization in AWS Organizations. The baseline architecture consists of multiple AWS accounts and services. Planning and implementation should be a multi-phase process so that you can iterate over smaller milestones to reach the bigger goal of setting up your baseline security architecture. This section describes the typical phases of your cloud journey based on a structured approach. These phases align with the [AWS Well-Architected Framework security design principles](#).

Phase 1: Build your OU and account structure

A prerequisite to a strong security foundation is a well-designed AWS organization and account structure. As explained previously in the [SRA building blocks](#) section of this guide, having multiple AWS accounts helps you isolate different business and security functions by design. This might seem like unnecessary work in the beginning, but it's an investment to help you scale quickly and securely. That section also explains how you can use AWS Organizations to manage multiple AWS accounts, and how to use trusted access and delegated administrator features to centrally manage AWS services across these multiple accounts.

You can use [AWS Control Tower](#) as outlined earlier in this guide to orchestrate your landing zone. If you are currently using a single AWS account, see the [Transitioning to multiple AWS accounts](#) guide

to migrate to multiple accounts as early as you can. For example, if your startup company is currently ideating and prototyping your product in a single AWS account, you should think about adopting a multi-account strategy before you launch your product in the market. Similarly, small, medium, and enterprise organizations should start to build their multi-account strategy as soon as they plan their initial production workloads. Start with your foundation OUs and AWS accounts, and then add your workload-related OUs and accounts.

For AWS account and OU structure recommendations beyond what's provided in the AWS SRA, see the [Multi-account strategy for small and medium businesses](#) blog post. As you're finalizing your OU and account structure, consider the high-level, organization-wide security controls that you would want to enforce by using service control policies (SCPs), resource control policies (RCPs), and declarative policies.

Design consideration:

- Do not replicate your company's reporting structure when you design your OU and account structure. Your OUs should be based on workload functions and a common set of security controls that apply to the workloads. Don't try to design your complete account structure from the beginning. Focus on the foundational OUs, and then add workload OUs as you need them. You can [move accounts between OUs](#) to experiment with alternative approaches during the early stages of your design. However, this might result in some overhead around managing logical permissions, depending on SCPs, RCPs, declarative policies, and IAM conditions that are based on OU and account paths.

Implementation example:

- The [AWS SRA code library](#) provides a sample implementation of [Account Alternate Contacts](#). This solution sets the billing, operations, and security alternate contacts for all accounts within an organization.

Phase 2: Implement a strong identity foundation

As soon as you have created multiple AWS accounts, you should give your teams access to the AWS resources within those accounts. There are two general categories of identity management: [workforce identity and access management](#) and [customer identity and access management](#) (CIAM). Workforce IAM is for organizations where employees and automated workloads need to log into AWS to do their jobs. CIAM is used when an organization needs a way to authenticate users to

provide access to the organization's applications. You need a workforce IAM strategy first, so your teams can build and migrate applications. You should always use IAM roles instead of IAM users to provide access to human or machine users. Follow the AWS SRA guidance on how to use AWS IAM Identity Center within the [Org Management](#) and [Shared Services](#) accounts to centrally manage single sign-on (SSO) access to your AWS accounts. The guidance also provides design considerations for using IAM federation when you cannot use IAM Identity Center.

As you work with IAM roles to provide user access to AWS resources, you should use IAM Access Analyzer and IAM access advisor as outlined in the [Security Tooling](#) and [Org Management](#) sections of this guide. These services help you achieve least privilege, which is an important preventive control that helps you build a good security posture.

Design consideration:

- To achieve least privilege, design processes to regularly review and understand the relationships between your identities and the permissions they require to function properly. As you learn, fine-tune those permissions and gradually trim them down to the least permissions possible. For scalability, this should be a shared responsibility between your central security and application teams. Use features such as [resource-based policies](#), [permission boundaries](#), [attribute-based access controls](#), and [session policies](#) to help application owners define fine-grained access control.

Implementation examples:

- The [AWS SRA code library](#) provides two sample implementations that apply to this phase:
 - [IAM Password Policy](#) sets the account password policy for users to align with common compliance standards.
 - [Access Analyzer](#) configures an organization-level analyzer within a delegated administrator account and an account-level analyzer within each account.

Phase 3: Maintain traceability

When your users have access to AWS and start building, you will want to know who is doing what, when, and from where. You will also want visibility into potential security misconfigurations, threats, or unexpected behaviors. A better understanding of security threats enables you to prioritize the appropriate security controls. To monitor AWS activity, follow the AWS SRA recommendations for setting up an organization trail by using [AWS CloudTrail](#) and centralizing

your logs within the [Log Archive](#) account. For security event monitoring, use AWS Security Hub CSPM, Amazon GuardDuty, AWS Config, and Amazon Security Lake as outlined in the [Security Tooling account](#) section.

Design consideration:

- As you start using new AWS services, make sure to enable [service-specific logs](#) for the service and store them as part of your central log repository.

Implementation examples:

- The [AWS SRA code library](#) provides the following sample implementations that apply to this phase:
 - [Organization CloudTrail](#) creates an organization trail and sets defaults to configure data events (for example, in Amazon S3 and AWS Lambda) to reduce duplicating the CloudTrail that's configured by AWS Control Tower. This solution provides options for configuring management events.
 - [AWS Config Control Tower Management Account](#) enables AWS Config in the Management account to monitor resource compliance.
 - [Conformance Pack Organization Rules](#) deploys a conformance pack to the accounts and specified Regions within an organization.
 - [AWS Config Aggregator](#) deploys an aggregator by delegating administration to a member account other than the Audit account.
 - [Security Hub CSPM Organization](#) configures Security Hub CSPM within a delegated administrator account for the accounts and governed Regions within the organization.
 - [GuardDuty Organization](#) configures GuardDuty within a delegated administrator account for the accounts within an organization.

Phase 4: Apply security at all layers

At this point, you should have:

- The appropriate security controls for your AWS accounts.
- A well-defined account and OU structure with preventive controls defined through SCPs, RCPs, declarative policies, and least privilege IAM roles and policies.

- The ability to log AWS activities by using AWS CloudTrail; to detect security events by using AWS Security Hub CSPM, Amazon GuardDuty, and AWS Config; and to perform advanced analytics on a purpose-built data lake for security by using Amazon Security Lake.

In this phase, plan to apply security at other layers of your AWS organization, as described in the section, [Apply security services across your AWS organization](#). You can build security controls for your networking layer by using services such as AWS WAF, AWS Shield, AWS Firewall Manager, AWS Network Firewall, AWS Certificate Manager (ACM), Amazon CloudFront, Amazon Route 53, and Amazon VPC, as outlined in the [Network account](#) section. As you move down your technology stack, apply security controls that are specific to your workload or application stack. Use VPC endpoints, Amazon Inspector, AWS Systems Manager, AWS Secrets Manager, and Amazon Cognito as outlined in the [Application account](#) section.

Design consideration:

- As you design your defense in depth (DiD) security controls, consider scaling factors. Your central security team won't have the bandwidth or full understanding of how every application behaves in your environment. Empower your application teams to be responsible and accountable for identifying and designing the right security controls for their applications. The central security team should focus on providing the right tools and consultation to enable the application teams. To understand the scaling mechanisms that AWS uses to adopt a more shift-left approach to security, see the blog post [How AWS built the Security Guardians program, a mechanism to distribute security ownership](#).

Implementation examples:

- The [AWS SRA code library](#) provides the following sample implementations that apply to this phase:
 - [EC2 Default EBS Encryption](#) configures the default Amazon EBS encryption in Amazon EC2 to use the default AWS KMS key within the provided AWS Regions.
 - [S3 Block Account Public Access](#) configures the account-level Block Public Access (BPA) settings in Amazon S3 for accounts within the organization.
 - [Firewall Manager](#) demonstrates how to configure a security group policy and AWS WAF policies for accounts within an organization.
 - [Inspector Organization](#) configures Amazon Inspector within a delegated administrator account for accounts and governed Regions within the organization.

Phase 5: Protect data in transit and at rest

Your business and customer data are valuable assets that you need to protect. AWS provides various security services and features to protect data in motion and at rest. Use Amazon CloudFront with AWS Certificate Manager, as outlined in the [Network account](#) section, to protect data in motion that's collected over the internet. For data in motion within internal networks, use an Application Load Balancer with AWS Private Certificate Authority, as explained in the [Application account](#) section. AWS KMS and AWS CloudHSM help you provide cryptographic key management to protect data at rest.

Phase 6: Prepare for security events

As you operate your IT environment you will encounter security events, which are changes in the everyday operation of your IT environment that indicate a possible security policy violation or a failure of security control. Proper traceability is critical so that you are aware of a security event as quickly as possible. It is equally important to be prepared to triage and respond to such security events so that you can take proper action before the security event escalates. Preparation helps you triage a security event quickly to understand its potential impact.

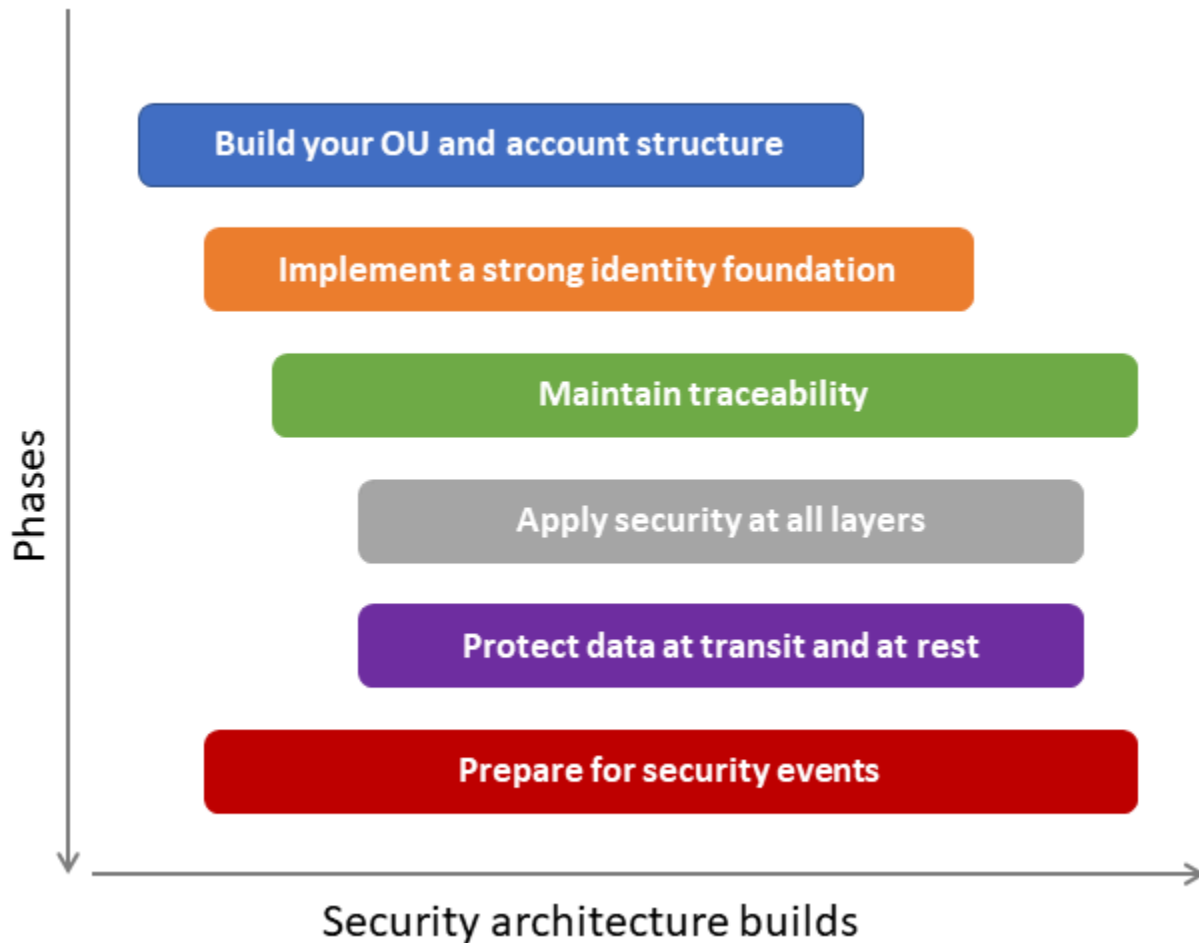
The AWS SRA, through the design of the [Security Tooling account](#) and the [deployment of common security services within all AWS accounts](#), provides you with the ability to detect security events across your AWS organization. [Amazon Detective](#) within the Security Tooling account helps you triage a security event and identify the root cause. During a security investigation, you have to be able to review relevant logs to record and understand the full scope and timeline of the incident. Logs are also required for alert generation when specific actions of interest happen. The AWS SRA recommends a central [Log Archive account](#) for immutable storage of all security and operational logs. You can query logs by using [CloudWatch Logs Insights](#) for data that's stored in CloudWatch log groups, and [Amazon Athena](#) and [Amazon OpenSearch Service](#) for data that's stored in Amazon S3. Use Amazon Security Lake to automatically centralize security data from the AWS environment, software as a service (SaaS) providers, on premises, and other cloud providers. [Set up subscribers](#) in the Security Tooling account or any dedicated account, as outlined by the AWS SRA, to query those logs for investigation.

[AWS Security Incident Response](#) helps you automate security incident response, investigation, and remediation. It provides pre-built playbooks and workflows to help you respond to security events quickly and consistently. When the proactive response feature is enabled, Security Incident Response [integrates with Security Hub CSPM and GuardDuty](#) to automatically trigger response

workflows when security findings are detected. The service helps you standardize and automate your incident response processes across your AWS organization. If you need additional assistance, you can open a service-supported case to engage with the AWS Customer Incident Response Team (CIRT).

Design considerations:

- You should start preparing to detect and respond to security events from the very beginning of your cloud journey. To better utilize limited resources, assign data and business criticality to your AWS resources so that when you detect a security event you can prioritize the triage and response based on the criticality of the resources involved.
- The phases for building your cloud security architecture, as discussed in this section, are sequential in nature. However, you don't have to wait for the full completion of one phase before you start the next phase. We recommend that you adopt an iterative approach, where you start working on multiple phases in parallel and evolve each phase as you evolve your cloud security posture. As you go through the different phases, your design will evolve. Consider tailoring the suggested sequence shown in the following diagram to your particular needs.



Implementation example:

- The [AWS SRA code library](#) provides a sample implementation of a [Detective Organization](#), which automatically enables Amazon Detective by delegating administration to an account (for example, Audit or Security Tooling) and configures Detective for existing and future AWS Organizations accounts.

AWS SRA best practices checklist

This section distills the AWS SRA best practices detailed throughout this guide into a checklist that you can follow as you build your version of the security architecture on AWS. Use this list as a reference point and not as a replacement for reviewing the guide. The checklist is grouped by AWS service. If you want to programmatically validate your existing AWS environment against the AWS SRA best practices checklist, you can use [SRA Verify](#).

SRA Verify is a security assessment tool that helps you assess your organization's alignment to the AWS SRA across multiple AWS accounts and Regions. It directly maps to AWS SRA recommendations by providing automated checks that validate your implementation against the AWS SRA guidance. The tool helps you verify that your security services are properly configured according to the reference architecture. It provides detailed findings and actionable remediation steps to help ensure that your AWS environment follows security best practices. SRA Verify is designed to run in AWS CodeBuild in the organization audit (Security Tooling) account. You can also run it locally or extend it by using the SRA Verify library.

Note

SRA Verify contains checks for several services, but might not contain a check for every consideration of the AWS SRA. For more information, review the guides in the [AWS SRA library](#).

AWS Organizations

- AWS Organizations is enabled with [all features](#).
- [Service control policies](#) (SCPs) are used to define access control guidelines for IAM principals.
- [Resource control policies](#) (RCPs) are used to define access control guidelines for AWS resources.
- [Declarative policies](#) are used to centrally declare and enforce your desired configuration for a given AWS service at scale across your organization.
- Three foundational OUs are created (Security, Infrastructure, and Workload) to group member accounts that provide foundation services.
- The [Security Tooling account](#) is created under the Security OU. This account provides centralized management of AWS security services and other third-party security tools.

- The [Log Archive account](#) is created under the Security OU. This account provides a tightly controlled central log repository of AWS services and application logs.
- The [Network account](#) is created under the Infrastructure OU. This account manages the gateway between your application and the broader internet. It isolates the networking services, configuration, and operation from the individual application workloads, security, and other infrastructure.
- The [Shared Service account](#) is created under the Infrastructure OU. This account supports the services that multiple applications and teams use to deliver their outcomes.
- The [Application account](#) is created under the Workloads OU. This account hosts the primary infrastructure and services to run and maintain an enterprise application. This guide provides a representation, but in the real world there will be multiple OUs and member accounts segregated by applications, development environments, and other security considerations.
- Alternate contact information for billing, operations, and security for all member accounts are configured.

AWS CloudTrail

- An organization trail is configured that enables delivery of CloudTrail management events in the management account and all member accounts in an AWS organization.
- The organization trail is configured as multi-Region trail.
- The organization trail is configured to capture events from global resources.
- Additional trails to capture specific data events are configured as necessary to monitor sensitive AWS resource activities.
- The Security Tooling account is set as a delegated administrator of the organization trail.
- The organization trail is configured to be automatically enabled for all new member accounts.
- The organization trail is configured to publish logs to a centralized S3 bucket that is hosted in the Log Archive account.
- The organization trail has log file validation enabled to verify the integrity of log files.
- The organization trail is integrated with CloudWatch Logs for retention of logs.
- The organization trail is encrypted by using a customer managed key.
- The central S3 bucket that is used for the log repository in the Log Archive account is encrypted with a customer managed key.

- The central S3 bucket used for the log repository in the Log Archive account is configured with S3 Object Lock for immutability.
- Versioning is enabled for the central S3 bucket that is used for the log repository in the Log Archive account.
- The central S3 bucket that is used for the log repository in the Log Archive account has a [resource policy](#) defined that restricts object upload only by organization trail through the resource Amazon Resource Name (ARN).

AWS Security Hub CSPM

- Security Hub CSPM is enabled for all member accounts and the management account.
- AWS Config is enabled for all member accounts as a prerequisite for Security Hub CSPM.
- The Security Tooling account is set as a delegated administrator of Security Hub CSPM.
- Amazon GuardDuty and Amazon Detective have the same delegated administrator account as Security Hub CSPM for smooth service integration.
- Central configuration is used to set up and manage Security Hub CSPM across multiple AWS accounts and AWS Regions.
- All OU and member accounts are designated as *centrally managed* by the delegated administrator of Security Hub CSPM.
- Security Hub CSPM is automatically enabled for all new member accounts.
- Security Hub CSPM is automatically enabled for configuration of new standards.
- Security Hub CSPM findings from all Regions are aggregated to a single home Region.
- Security Hub CSPM findings from all member accounts are aggregated within the Security Tooling account.
- The [AWS Foundational Best Practices](#) (FSBP) standard in Security Hub CSPM is enabled for all member accounts.
- The [CIS AWS Foundation Benchmark](#) standard in Security Hub CSPM is enabled for all member accounts.
- Other Security Hub CSPM standards are enabled as applicable.
- Security Hub CSPM findings are consumed by Security Hub for exposure correlation.
- A Security Hub CSPM automation rule is used to enrich findings with resource context.
- The Security Hub CSPM automated response and remediation feature is used to create custom EventBridge rules to take automatic actions against specific findings.

- An Amazon CloudWatch telemetry enablement rule is created to ingest Security Hub CSPM findings into CloudWatch, for the entire organization.

AWS Config

- The AWS Config recorder is enabled for all member accounts and the management account.
- The AWS Config recorder is enabled for all Regions.
- The AWS Config delivery channel S3 bucket is centralized in the Log Archive account.
- The AWS Config delegated administrator account is set to the Security Tooling account.
- AWS Config has an organization aggregator set up. The aggregator includes all Regions.
- AWS Config conformance packs are deployed uniformly to all member accounts from the delegated administrator account.
- AWS Config rule findings are automatically sent to Security Hub CSPM.

Amazon GuardDuty

- GuardDuty detector is enabled for all member accounts and the management account.
- GuardDuty detector is enabled for all Regions.
- GuardDuty detector is automatically enabled for all new member accounts.
- GuardDuty delegated administration is set to the Security Tooling account.
- GuardDuty foundational data sources such as CloudTrail management events, VPC flow logs, and Route 53 Resolver DNS query logs are enabled.
- GuardDuty S3 Protection is enabled.
- GuardDuty Malware Protection for EBS volumes is enabled.
- GuardDuty Malware Protection for S3 is enabled.
- GuardDuty RDS Protection is enabled.
- GuardDuty Lambda Protection is enabled.
- GuardDuty EKS Protection is enabled.
- GuardDuty EKS Runtime Monitoring is enabled.
- GuardDuty findings automatically flow to Security Hub CSPM and Security Hub.
- GuardDuty is integrated with Amazon Detective for finding investigation.

- GuardDuty findings exported to Amazon S3 are encrypted with a customer managed KMS key.
- GuardDuty Extended Threat Detection is enabled.
- GuardDuty findings are exported to a central S3 bucket in the Log Archive account for retention and encrypted with a customer managed KMS key.

IAM

- IAM users are not used.
- Centralized management of root access for member accounts is enforced.
- The centralized privileged root user task for management account is enforced from the delegated administrator.
- Centralized root access management is delegated to the Security Tooling account.
- All member account root credentials are removed.
- All member and management AWS account password policies are set according to the organization's security standard.
- IAM access advisor is used to review last used information for IAM groups, users, roles, and policies.
- Permission boundaries are used to restrict maximum possible permissions for IAM roles.

IAM Access Analyzer

- IAM Access Analyzer is enabled for all member accounts and the management account.
- The IAM Access Analyzer delegated administrator is set to the Security Tooling account.
- The IAM Access Analyzer external access analyzer is configured with the organization zone of trust in every Region.
- The IAM Access Analyzer external access analyzer is configured with the account zone of trust in every Region.
- The IAM Access Analyzer internal access analyzer is configured with the organization zone of trust in every Region.
- The IAM Access Analyzer internal access analyzer is configured with the account zone of trust in every Region.
- The IAM Access Analyzer unused access analyzer for the current account is created.

- The IAM Access Analyzer unused access analyzer for the current organization is created.

Amazon Detective

- Detective is enabled for all member accounts.
- Detective is automatically enabled for all new member accounts.
- Detective is enabled for all Regions.
- The Detective delegated administrator is set to the Security Tooling account.
- The Detective, GuardDuty, and Security Hub CSPM delegated administrator is set to the same Security Tooling account.
- Detective is integrated with Security Lake for storage and analysis of raw logs.
- Detective is integrated with GuardDuty for ingesting findings.
- Detective is ingesting Amazon EKS audit logs for analysis.
- Detective is ingesting Security Hub CSPM logs for analysis.

AWS Firewall Manager

- Firewall Manager security policies are set.
- The Firewall Manager delegated administrator is set to the Security Tooling account.
- AWS Config is enabled as a prerequisite.
- Multiple Firewall Manager administrators are set with restricted scope per OU, account, and Region.
- A Firewall Manager AWS WAF security policy is defined.
- A Firewall Manager AWS WAF centralized logging policy is defined.
- A Firewall Manager Shield Advanced security policy is defined.
- A Firewall Manager security group security policy is defined.
- A Firewall Manager security policy is defined for AWS Network Firewall.
- A Firewall Manager security policy is defined for Route 53 DNS Firewall.

Amazon Inspector

- Amazon Inspector is enabled for all member accounts.

- Amazon Inspector is automatically enabled for any new member account.
- The Amazon Inspector delegated administrator is set to the Security Tooling account.
- Amazon Inspector EC2 vulnerability scanning is enabled.
- Amazon Inspector ECR image vulnerability scanning is enabled.
- Amazon Inspector Lambda function and layers vulnerability scanning is enabled.
- Amazon Inspector Lambda code scanning is enabled.
- Amazon Inspector code security scanning is enabled.

Amazon Macie

- Macie is enabled for applicable member accounts.
- Macie is automatically enabled for applicable new member accounts.
- The Macie delegated administrator is set to the Security Tooling account.
- Macie findings are exported to a central S3 bucket in the log Archive account.
- S3 buckets that store Macie findings are encrypted with a customer managed key.
- The Macie policy and classification policy are published to Security Hub CSPM.

Amazon Security Lake

- Security Lake organization configuration is enabled.
- The Security Lake delegated administrator is set to the Log Archive account.
- The Security Lake organization configuration is enabled for new member accounts.
- The Security Tooling account is set up as a data access subscriber to conduct analysis of logs.
- The Security Tooling account is set up as a data query subscriber to conduct analysis of logs.
- A CloudTrail management log source is enabled for Security Lake in all or specified active member accounts.
- A VPC flow log source is enabled for Security Lake in all or specified active member accounts.
- A Route 53 log source is enabled for Security Lake in all or specified active member accounts.
- CloudTrail data event for an S3 log source is enabled for Security Lake in all or specified active member accounts.

- A Lambda execution log source is enabled for Security Lake in all or specified active member accounts.
- An Amazon EKS audit log source is enabled for Security Lake in all or specified active member accounts.
- A Security Hub findings log source is enabled for Security Lake in all or specified active member accounts.
- An AWS WAF log source is enabled for Security Lake in all or specified active member accounts.
- Security Lake SQS queues in the delegated administrator account is encrypted with a customer managed key.
- The Security Lake SQS dead-letter queue in the delegated administrator account is encrypted with a customer managed key.
- The Security Lake S3 bucket is encrypted with a customer managed key.
- The Security Lake S3 bucket has a resource policy that restricts direct access only by Security Lake.

AWS WAF

- All CloudFront distributions are associated with AWS WAF.
- All Amazon API Gateway REST APIs are associated with AWS WAF.
- All Application Load Balancers are associated with AWS WAF.
- All AWS AppSync GraphQL APIs are associated with AWS WAF.
- All Amazon Cognito user pools are associated with AWS WAF.
- All AWS App Runner services are associated with AWS WAF.
- All AWS Verified Access instances are associated with AWS WAF.
- All AWS Amplify applications are associated with AWS WAF.
- AWS WAF logging is enabled.
- AWS WAF logs are centralized in an S3 bucket in the Log Archive account.

AWS Shield Advanced

- Shield Advanced subscription is enabled and set to auto-renew for all application accounts that have public-facing resources.

- Shield Advanced is configured for all CloudFront distributions.
- Shield Advanced is configured for all Application Load Balancers.
- Shield Advanced is configured for all Elastic IP addresses associated with Network Load Balancers.
- Shield Advanced is configured for all Elastic IP addresses associated with EC2 instances.
- Shield Advanced is configured for all Route 53 hosted zones.
- Shield Advanced is configured for all Elastic IP addresses.
- Shield Advanced is configured for all Global Accelerators.
- CloudWatch alarms are configured for CloudFront and Route 53 resources that are protected by Shield Advanced.
- Shield Response Team (SRT) access is configured.
- Shield Advanced proactive engagement is enabled.
- Shield Advanced proactive engagement contacts are configured.
- Shield Advanced protected resources have a custom AWS WAF rule configured.
- Shield Advanced protected resources have automatic application-layer DDoS mitigation enabled.

AWS Security Incident Response

- AWS Security Incident Response is enabled for the whole AWS organization.
- The AWS Security Incident Response delegated administrator is set to the Security Tooling account.
- The proactive response and alert triaging workflow is enabled.
- AWS Customer Incident Response Team (CIRT) containment actions are authorized.

AWS Audit Manager

- Audit Manager is enabled for all member accounts.
- Audit Manager is automatically enabled for new member accounts.
- The Audit Manager delegated administrator is set to the Security Tooling account.
- AWS Config is enabled as prerequisite for Audit Manager.
- A customer managed key is used for data stored in Audit Manager.

- The default assessment report destination is configured.

AWS Security Hub

- AWS Security Hub is enabled for all member accounts and the management account.
- The Security Tooling account is set as a delegated administrator for Security Hub.
- Security Hub is configured to enable all Regions, OUs, and accounts automatically, including future Regions and accounts.
- Cross-Region aggregation is set up to aggregate findings, resources, and trends from multiple Regions into a single home Region.
- Security Hub CSPM, Amazon GuardDuty, Amazon Inspector, and Amazon Macie are enabled as building block services for Security Hub.
- Security Hub coverage findings are used to validate that security services are uniformly enabled across all member accounts.
- Findings are formatted in Open Cybersecurity Schema Framework (OCSF).
- EventBridge integration is configured for automated response and remediation workflows.

AWS Network Firewall

- AWS Network Firewall is deployed in the inspection VPC within the Network account.
- All traffic between VPCs passes through the inspection VPC for Network Firewall inspection.
- The Network Firewall subnet is dedicated exclusively to firewall endpoints (no other workloads deployed in the firewall subnet).
- Stateful inspection, intrusion prevention, and web filtering rules are configured.
- Network Firewall activity is visible in real time through CloudWatch metrics.
- Network Firewall logs are sent to Amazon S3, CloudWatch, or Amazon Data Firehose.
- AWS Firewall Manager is used to centrally configure and deploy Network Firewall rules across the organization.
- Firewall endpoints are deployed in every Availability Zone that contains protected subnets.

Amazon Route 53 Resolver DNS Firewall

- DNS Firewall is used to prevent DNS exfiltration of data from VPCs that require DNS-level protection.
- DNS Firewall rule groups are configured to block or allow queries to specific domains.
- DNS Firewall blocks resolution requests to unauthorized private hosted zones, VPC endpoint names, and public or private EC2 instance names.
- DNS Firewall rule groups are managed centrally through AWS Firewall Manager or AWS Resource Access Manager (AWS RAM).

AWS Key Management Service

- Customer managed keys are used for encryption of all sensitive data at rest.
- Separate KMS keys are created per service and per account where appropriate.
- Key policies are defined to restrict usage to intended services and principals only.
- Automatic annual key rotation is enabled for all customer managed symmetric keys.
- Key administration is separated from key usage through distinct IAM permissions.
- Key policies use condition keys (such as `kms:ViaService`) to restrict which services can use a key.
- KMS key usage is audited through AWS CloudTrail.
- AWS managed keys are acceptable only for non-sensitive or public-classified data.

AWS Private Certificate Authority

- A private CA hierarchy (root CA and subordinate CAs) is created in the Security Tooling account.
- The root CA is protected with stringent security controls in the Security Tooling account.
- Subordinate CAs are shared with Application accounts through AWS RAM for issuing end-entity certificates.
- Private certificates are used for internal application communications (TLS between services and load balancers).
- Certificate lifecycle management (issuance, renewal, revocation) is automated through AWS Certificate Manager (ACM) integration.

- CA hierarchy design follows the principle of limited revocable trust with separate CAs per domain of responsibility.

AWS IAM Identity Center

- IAM Identity Center is enabled in the Org Management account.
- Delegated administration for IAM Identity Center is configured to the Shared Services account.
- IAM Identity Center is integrated with a corporate identity provider (IdP) via SAML 2.0 or SCIM.
- Permission sets are centrally managed and provisioned to member accounts.
- Multi-factor authentication (MFA) is enforced for all IAM Identity Center users.
- Access to the delegated administrator account for IAM Identity Center is tightly controlled.
- IAM Identity Center is used instead of IAM users for all human access to AWS accounts.
- IAM Identity Center multi-Region replication is enabled for workforce identity management across multiple AWS Regions.

AWS Systems Manager

- Systems Manager is deployed across all member accounts using delegated administrator functionality.
- All EC2 instances are registered as managed instances through SSM Agent.
- Session Manager is used for interactive access to instances instead of SSH or RDP (no inbound ports required).
- Patch Manager is used to automate patching for operating systems and applications.
- Systems Manager Automation runbooks are used for standardized remediation actions.
- Systems Manager Explorer is configured with cross-account data synchronization through AWS Organizations.
- VPC endpoints are provisioned for Systems Manager to enable private network connectivity.
- Compliance data from Systems Manager is integrated with AWS Config and Security Hub CSPM.

AWS Secrets Manager

- All application credentials, database passwords, and API keys are stored in Secrets Manager (not hardcoded in code or environment variables).
- Automatic rotation is configured for all secrets that support it.
- Fine-grained IAM policies and resource-based policies control access to each secret.
- Secrets are encrypted with customer managed KMS keys for sensitive workloads.
- Secret access is monitored through AWS CloudTrail.
- AWS Config rules are configured to detect changes to secrets.
- Secrets Manager is integrated with Amazon Relational Database Service (Amazon RDS) for automatic database credential management.
- Secrets are managed locally in the account closest to where they are used.

IAM resources

Although AWS Identity and Access Management (IAM) is not a service that is included in a traditional architecture diagram, it touches every aspect of the AWS organization, AWS accounts, and AWS services. You cannot deploy any AWS services without creating IAM entities and granting permissions first. A full explanation of IAM is beyond the scope of this document, but this section provides important summaries of best practice recommendations and pointers to additional resources.

- For IAM best practices, see [Security best practices in IAM](#) in the AWS documentation, [IAM articles](#) in the AWS Security blog, and [AWS re:Invent presentations](#).
- The AWS Well-Architected security pillar outlines key steps in the [permissions management](#) process: define permissions guardrails, grant least privilege access, analyze public and cross-account access, share resources securely, reduce permissions continuously, and establish an emergency access process.
- The following table and its accompanying notes provide a high-level overview of recommended guidance on types of available IAM permission policies and how to use them in your security architecture. To learn more, see the [AWS re:Invent 2020 video on choosing the right mix of IAM policies](#).

Use case or policy	Effect	Managed by	Purpose	Pertains to	Affects	Deployed in
Service control policies (SCPs)	Restrict	Central team, such as platform or security team [1]	Guardrails, governance	Organization, OU, account	All principals in Organization, OU, and accounts	Org Management account [2]
Resource control policies (RCPs)	Restrict	Central team, such as platform	Guardrails, governance	Organization, OU, account	Resources in member accounts [12]	Org Management account [2]

		or security team [1]				
Baseline account automation policies (the IAM roles used by the platform to operate an account)	Grant and restrict	Central team, such as platform, security, or IAM team [1]	Permissions for (baseline) non-workload automation roles [3]	Single account [4]	Principals used by automation within a member account	Member accounts
Baseline human policies (the IAM roles that grant users permissions to perform their work)	Grant and restrict	Central team, such as platform, security, or IAM team [1]	Permissions for human roles [5]	Single account [4]	Federated principals [5] and IAM users [6]	Member accounts

Permissions boundaries (maximum permissions that an empowered developer can assign to another principal)	Restrict	Central team, such as platform, security, or IAM team [1]	Guardrails for application roles (must be applied)	Single account [4]	Individual roles for an application or workload in this account [7]	Member accounts
Machine role policies for applications (role attached to infrastructure deployed by developers)	Grant and restrict	Delegated to developers [8]	Permission for the application or workload [9]	Single account	A principal in this account	Member accounts
Resource policies	Grant and restrict	Delegated to developers [8,10]	Permissions to resources	Single account	A principal in an account [11]	Member accounts

Central root user management	Grant and restrict	Central team, such as platform, security, or IAM team [1]	Centrally manage member account root users at scale	Organization	All root users in member accounts	Org management account, delegated administrator account
-------------------------------------	--------------------	---	---	--------------	-----------------------------------	---

Notes from the table:

1. Enterprises have many centralized teams (such as cloud platform, security operations, or identity and access management teams) that divide the responsibilities of these independent controls, and peer review one another's policies. The examples in the table are placeholders. You will need to determine the most effective separation of duties for your enterprise.
2. To use SCPs, you must [enable all features](#) within AWS Organizations.
3. Common baseline roles and policies are generally needed to enable automation, such as permissions for the pipeline, deployment tools, monitoring tools (for example, AWS Lambda and AWS Config Rules), and other permissions. This configuration is typically delivered when the account is provisioned.
4. Although these pertain to a resource (such as a role or a policy) in a single account, they can be replicated or deployed to multiple accounts by using [AWS CloudFormation StackSets](#).
5. Define a core set of baseline human roles and policies that are deployed to all member accounts by a central team (often during account provisioning). Examples include the developers in the platform team, the IAM team, and security audit teams.
6. Use identity federation (instead of local IAM users) whenever possible.
7. Permissions boundaries are used by delegated administrators. This IAM policy defines the maximum permissions and overrides other policies (including "*" : "*" policies that allow all actions on resources). Permissions boundaries should be required in baseline human policies as a condition to create roles (such as workload performance roles) and to attach policies. Additional configurations such as SCPs enforce the attachment of the permissions boundary.
8. This assumes that sufficient guardrails (for example, SCPs and permissions boundaries) have been deployed.

9. These optional policies could be delivered during account provisioning or as part of the application development process. The permission to create and attach these policies will be governed by the application developer's own permissions.
10. In addition to local account permissions, a centralized team (such as the cloud platform team or the security operations team) often manages some resource-based policies to enable cross-account access to operate the accounts (for example, to provide access to S3 buckets for logging).
11. A resource-based IAM policy can refer to any principal in any account to allow or deny access to its resources. It can even refer to anonymous principals to enable public access.
12. RCPs apply to resources for a subset of AWS services. For more information, see [List of AWS services that support RCPs](#) in the AWS Organizations documentation.

Ensuring that IAM identities have only those permissions that are necessary for a well-delineated set of tasks is critical for reducing the risk of malicious or unintentional abuse of permissions. Establishing and maintaining a [least privilege model](#) requires a deliberate plan to continually update, evaluate, and mitigate excess privilege. Here are some additional recommendations for that plan:

- Use your organization's governance model and established risk appetite to establish specific guardrails and permissions boundaries.
- Implement least privilege through a *continually iterative process*. This is not a one-time exercise.
- Use SCPs to reduce actionable risk. These are intended to be broad guardrails, not narrowly targeted controls.
- Use permissions boundaries to delegate IAM administration in a safer way.
 - Make sure that the delegated administrators attach the appropriate IAM boundary policy to the roles and users they create.
- As a defense-in-depth approach (in conjunction with identity-based policies), use resource-based IAM policies to deny broad access to resources.
- Use IAM access advisor, AWS CloudTrail, IAM Access Analyzer, and related tooling to regularly analyze historical usage and permissions granted. Immediately remediate obvious over-permissions.
- Scope broad actions to specific resources where applicable instead of using an asterisk as a wildcard to indicate all resources.

- Implement a mechanism to quickly identify, review, and approve IAM policy exceptions based upon requests.

Code repository for AWS SRA examples

To help you get started building and implementing the guidance in the AWS SRA, an infrastructure as code (IaC) repository at <https://github.com/aws-samples/aws-security-reference-architecture-examples> accompanies this guide. This repository contains code to help developers and engineers deploy some of the guidance and architecture patterns presented in this document. This code is drawn from AWS Professional Services consultants' first-hand experience with customers. The templates are general in nature—their goal is to illustrate an implementation pattern rather than provide a complete solution. The AWS service configurations and resource deployments are deliberately very restrictive. You might need to modify and tailor these solutions to suit your environment and security needs.

The AWS SRA code repository provides code samples with both AWS CloudFormation and Terraform deployment options. The solution patterns support two environments: one requires AWS Control Tower and the other uses AWS Organizations without AWS Control Tower. The solutions in this repository that require AWS Control Tower have been deployed and tested within an AWS Control Tower environment by using AWS CloudFormation and [Customizations for AWS Control Tower \(CfCT\)](#). Solutions that don't require AWS Control Tower have been tested within an AWS Organizations environment by using AWS CloudFormation. The CfCT solution helps customers quickly set up a secure, multi-account AWS environment based on AWS best practices. It helps save time by automating the setup of an environment for running secure and scalable workloads while implementing an initial security baseline through the creation of accounts and resources. AWS Control Tower also provides a baseline environment to get started with a multi-account architecture, identity and access management, governance, data security, network design, and logging. The solutions in the AWS SRA repository provide additional security configurations to implement the patterns described in this document.

Here is a summary of the solutions in the [AWS SRA repository](#). Each solution includes a README .md file with details.

- The [CloudTrail Organization](#) solution creates an organization trail within the Org Management account and delegates administration to a member account such as the Audit or Security Tooling account. This trail is encrypted with a customer managed key created in the Security Tooling account and delivers logs to an S3 bucket in the Log Archive account. Optionally, data events can be enabled for Amazon S3 and AWS Lambda functions. An organization trail logs events for all AWS accounts in the AWS organization while preventing member accounts from modifying the configurations.

- The [GuardDuty Organization](#) solution enables Amazon GuardDuty by delegating administration to the Security Tooling account. It configures GuardDuty within the Security Tooling account for all existing and future AWS organization accounts. The GuardDuty findings are also encrypted with a KMS key and sent to an S3 bucket in the Log Archive account.
- The Security Hub CSPM [Organization](#) solution configures Security Hub CSPM by delegating administration to the Security Tooling account. It configures Security Hub CSPM within the Security Tooling account for all existing and future AWS organization accounts. The solution also provides parameters for synchronizing the enabled security standards across all accounts and Regions as well as configuring a Region aggregator within the Security Tooling account. Centralizing Security Hub CSPM within the Security Tooling account provides a cross-account view of security standards compliance and findings from both AWS services and third-party AWS Partner integrations.
- The [Inspector](#) solution configures Amazon Inspector within the delegated administrator (Security Tooling) account for all accounts and governed Regions under the AWS organization.
- The [Firewall Manager](#) solution configures AWS Firewall Manager security policies by delegating administration to the Security Tooling account and configuring Firewall Manager with a security group policy and multiple AWS WAF policies. The security group policy requires a maximum allowed security group within a VPC (existing or created by the solution), which is deployed by the solution.
- The [Macie Organization](#) solution enables Amazon Macie by delegating administration to the Security Tooling account. It configures Macie within the Security Tooling account for all existing and future AWS organization accounts. Macie is further configured to send its discovery results to a central S3 bucket that is encrypted with a KMS key.
- AWS Config:
 - The [Config Aggregator](#) solution configures an AWS Config aggregator by delegating administration to the Security Tooling account. The solution then configures an AWS Config aggregator within the Security Tooling account for all existing and future accounts in the AWS organization.
 - The [Conformance Pack Organization Rules](#) solution deploys AWS Config Rules by delegating administration to the Security Tooling account. It then creates an organization conformance pack within the delegated administrator account for all existing and future accounts in the AWS organization. The solution is configured to deploy the [Operational Best Practices for Encryption and Key Management](#) conformance pack sample template.
 - The [AWS Config Control Tower Management Account](#) solution enables AWS Config in the AWS Control Tower management account and updates the AWS Config aggregator

within the Security Tooling account accordingly. The solution uses the AWS Control Tower CloudFormation template for enabling AWS Config as a reference to ensure consistency with the other accounts in the AWS organization.

- IAM:

- The [Access Analyzer](#) solution enables IAM Access Analyzer by delegating administration to the Security Tooling account. It then configures an organization-level IAM Access Analyzer within the Security Tooling account for all existing and future accounts in the AWS organization. The solution also deploys IAM Access Analyzer to all member accounts and Regions to support analyzing account-level permissions.
- The [IAM Password Policy](#) solution updates the AWS account password policy within all accounts in an AWS organization. The solution provides parameters for configuring the password policy settings to help you align with industry compliance standards.
- The [EC2 Default EBS Encryption](#) solution enables account-level, default Amazon EBS encryption within each AWS account and AWS Region in the AWS organization. It enforces the encryption of new EBS volumes and snapshots that you create. For example, Amazon EBS encrypts the EBS volumes that are created when you launch an instance and the snapshots that you copy from an unencrypted snapshot.
- The [S3 Block Account Public Access](#) solution enables Amazon S3 account-level settings within each AWS account in the AWS organization. The Amazon S3 Block Public Access feature provides settings for access points, buckets, and accounts to help you manage public access to Amazon S3 resources. By default, new buckets, access points, and objects don't allow public access. However, users can modify bucket policies, access point policies, or object permissions to allow public access. Amazon S3 Block Public Access settings override these policies and permissions so that you can limit public access to these resources.
- The [Detective Organization](#) solution automates enabling Amazon Detective by delegating administration to an account (such as the Audit or Security Tooling account) and configuring Detective for all existing and future AWS Organizations accounts.
- The [Shield Advanced](#) solution automates the deployment of AWS Shield Advanced to provide enhanced DDoS protection for your applications on AWS.
- The [AMI Bakery Organization](#) solution helps automate the process for building and managing standard, hardened Amazon Machine Image (AMI) images. This ensures consistency and security across your AWS instances, and simplifies deployment and maintenance tasks.
- The [Patch Manager](#) solution helps streamline patch management across multiple AWS accounts. You can use this solution to update AWS Systems Manager Agent (SSM Agent) on all managed instances, and to scan and install critical and important security patches and bug fixes on

Windows and Linux tagged instances. The solution also configures the Default Host Management Configuration setting to detect the creation of new AWS accounts and automatically deploy the solution to those accounts.

Contributors

Primary author:

- Avik Mukherjee, AWS Senior Security Solution Architect

Current Contributors:

- Alberto Sagrado Amador, AWS Security Delivery Consultant
- Samuel Ortega Sancho, AWS Senior Delivery Consultant
- Kishore Vinjam, AWS Principal Partner Solution Architect
- Marc Luescher, AWS Senior Solution Architect

Reviewing:

- Eric Rose, AWS Principal Security Solution Architect
- Manigandan Shri AWS Senior Delivery Consultant
- Nihal Salim, AWS Delivery Consultant

Technical writing:

- Lilly AbouHarb, AWS Senior Technical Writer

Previous contributors

- Neal Rothleder, AWS Principal Scientist
- Hart Rossman, AWS VP, AWS Security
- Jason Hurst, AWS CIRT Senior Security Investigator
- Itay Meller, AWS Senior Specialist SA
- Josh Du Lac, AWS Enterprise Security Strategist
- Rodney Underkoffler, AWS Specialist Senior SA
- Farhan Farooq, AWS Senior Solutions Architect
- Prashob Krishnan, AWS Principal Technical Account Manager

- Meg Peddada, AWS Senior Security SA
- Ashwin Phadke, AWS Senior Solutions Architect
- Sowjanya Rajavaram, AWS Senior Security Strategy SA
- Tomek Jakubowski, AWS Security Engineering Manager
- Ross Warren, AWS Partner Solution Architect
- Scott Conklin, AWS Senior Solution Architect
- Ilya Epshteyn, AWS Director, Identity Solutions

Appendix: AWS security, identity, and compliance services

For an introduction or a refresher, see [Security, identity, and compliance on AWS](#) on the AWS website for a list of the AWS services that help you secure your workloads and applications in the cloud. These services are grouped into five categories: data protection, identity & access management, network & application protection, threat detection & continuous monitoring, and compliance & data privacy.

Data protection – AWS provides services that help you protect your data, accounts, and workloads from unauthorized access.

- [Amazon Macie](#) – Discover, classify, and protect sensitive data with machine learning-powered security features.
- [AWS KMS](#) – Create and control the keys used to encrypt your data.
- [AWS CloudHSM](#) – Manage your hardware security modules (HSMs) in the AWS Cloud.
- [AWS Certificate Manager](#) – Provision, manage, and deploy SSL/TLS certificates for use with AWS services.
- [AWS Secrets Manager](#) – Rotate, manage, and retrieve database credentials, API keys, and other secrets through their lifecycle.
- AWS Private CA - Create private certificate authority (CA) hierarchies, including root and subordinate CAs.

Identity & access management – AWS identity services enable you to securely manage identities, resources, and permissions at scale.

- [IAM](#) – Securely control access to AWS services and resources.
- IAM Access Analyzer – Use [provable security](#) to implement least privilege by providing capabilities to set, verify, and refine permissions.
- [IAM Identity Center](#) – Centrally manage SSO access to multiple AWS accounts and business applications.
- [Amazon Cognito](#) – Add user sign-up, sign-in, and access control to your web and mobile applications.
- [AWS Directory Service](#) – Use managed Microsoft Active Directory in the AWS Cloud.

- [AWS RAM](#) – Share AWS resources simply and securely.
- [AWS Organizations](#) – Implement policy-based management for multiple AWS accounts.
- [Amazon Verified Permissions](#) – Manage scalable, fine-grained permissions and authorization in your custom applications.

Network & application protection – These categories of services enable you to enforce fine-grained security policy at network control points across your organization. AWS services help you inspect and filter traffic to help prevent unauthorized resource access at the host-level, network-level, and application-level boundaries.

- [AWS Shield](#) – Safeguard your web applications that run on AWS with managed DDoS protection.
- [AWS WAF](#) – Protect your web applications from common web exploits, and ensure availability and security.
- [AWS Firewall Manager](#) – Configure and manage AWS WAF rules across AWS accounts and applications from a central location.
- [AWS Systems Manager](#) – Configure and manage Amazon EC2 and on-premises systems to apply OS patches, create secure system images, and configure secure operating systems.
- [Amazon VPC](#) – Provision a logically isolated section of AWS where you can launch AWS resources in a virtual network that you define.
- [AWS Network Firewall](#) – Deploy essential network protections for your VPCs.
- [Amazon Route 53 DNS Firewall](#) – Protect your outbound DNS requests from your VPCs.
- [AWS Verified Access](#) – Provide secure access to your applications without requiring virtual private networks (VPNs).
- [Amazon VPC Lattice](#) – Simplify service-to-service connectivity, security, and monitoring.
- [AWS Transit Gateway](#) - Connect VPCs, AWS accounts, and on-premises networks to a single gateway
- [Network Access Analyzer](#) - Identify unintended network access to your resources on AWS.

Threat detection & continuous monitoring – AWS monitoring and detection services provide guidance to help identify potential security incidents within your AWS environment.

- [AWS Security Hub CSPM](#) – View and manage security alerts and automate compliance checks from a central location.

- [AWS Security Hub](#) – Correlate and enrich security findings to prioritize critical security issues across your accounts and AWS Regions.
- [Amazon GuardDuty](#) – Protect your AWS accounts and workloads with intelligent threat detection and continuous monitoring.
- [Amazon Inspector](#) – Automate security assessments to help improve the security and compliance of your applications that are deployed on AWS.
- [AWS Config](#) – Record and evaluate the configurations of your AWS resources to enable compliance auditing, resource change tracking, and security analysis.
- [AWS Config Rules](#) – Create rules that automatically take action in response to changes in your environment, such as isolating resources, enriching events with additional data, or restoring configuration to a known good state.
- [AWS Security Incident Response](#) – Automate security incident response, investigation, and remediation with pre-built playbooks and workflows.
- [AWS CloudTrail](#) – Track user activity and API usage to enable governance and operational and risk auditing of your AWS account.
- [Amazon Detective](#) – Analyze and visualize security data to rapidly get to the root cause of potential security issues.
- [AWS Lambda](#) – Run code without provisioning or managing servers so you can scale your programmed, automated response to incidents.

Compliance & data privacy – AWS gives you a comprehensive view of your compliance status and continuously monitors your environment by using automated compliance checks based on the AWS best practices and industry standards your business follows.

- [AWS Artifact](#) – Use a no-cost, self-service portal to get on-demand access to AWS security and compliance reports and select online agreements.
- [AWS Audit Manager](#) – Continuously audit your AWS usage to simplify how you assess risk and compliance with regulations and industry standards.

Document history

The following table describes significant changes to this guide.

Change	Description	Date
Major updates	- Added guidance around building architectures for multi-Region environments. - Various AWS service updates: CloudWatch support for ingesting Security Hub CSPM findings, availability of IAM policy autopilot MCP server, AWS Managed Microsoft AD support for STIG-aligned configurations, AWS Secrets Manager support for hybrid post-quantum key exchange, and AWS Security Incident Response AI-powered investigative agent - Updated AWS Audit Manager to note that service is not available to new customers - Added CloudWatch Unified Data Store as the recommended primary option for centralized log collection and analytics across the organization. Amazon Security Lake	June 30, 2026

is recommended as the secondary option.

- Removed all references to AWS CloudTrail Lake following service deprecation.
- Added new services to the checklist: AWS Security Hub, AWS Network Firewall, Route 53 Resolver DNS Firewall, AWS KMS, AWS Private CA, AWS IAM Identity Center, AWS Systems Manager, and AWS Secrets Manager.
- In the checklist, added new checks for existing services: AWS Security Hub CSPM, Amazon GuardDuty, and AWS Firewall Manager
- Updated the appendix with new AWS services

Content restructure and updates

December 22, 2025

- Added guidance for [AWS Security Hub](#) and [AWS Nitro Enclaves](#).
- Restructured the AWS SRA to focus on the core architecture and moved the deep dive sections to separate guides for [identity management](#), [perimeter security](#), [cyber forensics](#), [generative AI](#), and [IoT](#).
- Updated existing guidance to include additional details for AWS CloudTrail, AWS Config, Amazon Detective, AWS Firewall Manager, Amazon GuardDuty, IAM Access Analyzer, Amazon Security Lake, AWS Shield Advanced, and AWS Audit Manager.

Major updates

August 29, 2025

- Added information about new IAM centralized root user access management, resource control policies (RCPs), and declarative policies.
- Updated references to new Security Hub CSPM.
- Included new service features for Amazon GuardDuty and Security Hub CSPM.
- Added AWS Security Incident Response service guidance.
- Updated IAM deep dive guidance to include VPC Lattice for machine-to-machine identity management.
- Added a new deep dive guidance: SRA for IoT.

Additions and clarifications

September 12, 2024

- In the Security Tooling account section, updated the AWS KMS guidance.
- In the Customer identity management section, expanded the information about authorizing API Gateway.
- Updated the Generative AI section to add a design consideration for OU and account design. Removed explicit callout to prompt injection attack as the security controls referenced is more at infrastructure layer and not at application layer.
- In the [Code repository](#) section, added information about the new [Patch Manager solution](#).

Major updates

June 7, 2024

- Added two sections for deep dive architectural guidance: Generative AI using Amazon Bedrock and Identity management.
- Updated the IAM Access Analyzer, Amazon Inspector , AWS WAF, AWS Config, Amazon Security Lake, and AWS Security Hub CSPM sections with new service features.
- Updated the [AWS SRA code repository](#) section to include the new Terraform deployment option and the addition of AWS Shield Advanced and AMI Bakery solutions.

Major updates	- Updated the Network account and Application account sections to add architectural guidance for Amazon Verified Permissions, AWS Verified Access, and Amazon VPC Lattice. - Added deep dive architectural guidance based on security functionality. - Added new guidance around how AWS services use AI/ML to provide better security outcomes. - Added guidance on how plan your security architecture in a phased manner.	November 4, 2023
Security Lake addition	Updated the Security Tooling account and Log Archive account sections to add design guidance related to Amazon Security Lake.	September 22, 2023
Minor updates	- Updated existing guidance to reflect new AWS service features and best practices. - Updated architectural guidance for AWS CloudTrail, AWS IAM Identity Center, and edge security.	May 11, 2023
Survey	Added a short survey to gain a better understanding of how you use the AWS SRA in your organization.	December 14, 2022

Source files for reference architecture diagrams	Added a downloadable file that provides the architecture diagrams for this guide in editable PowerPoint format.	November 17, 2022
Updates to Security foundations section	Updated the information about Well-Architected pillars and security design principles.	September 27, 2022
Added new guidance, updated and clarified existing guidance	• Added information about how to use the AWS SRA and key implementation guidelines. • Added architectural guidance for additional AWS services such as AWS Artifact, Amazon Inspector, AWS RAM, Amazon Route 53, AWS Control Tower, AWS Audit Manager, Directory Service, Amazon Cognito, and Network Access Analyzer. • Updated existing guidance to reflect new AWS service features and best practices.	July 25, 2022
Initial publication	—	June 23, 2021